

Controles Críticos de Seguridad del CIS®

Versión 8.1

Marzo de 2026

Esta traducción fue realizada utilizando ChatGPT.

Agradecimientos

CIS desea agradecer a los numerosos expertos en seguridad que ofrecen voluntariamente su tiempo y talento para apoyar los Controles de Seguridad Críticos del CIS® (CIS Controls®) y otros trabajos del CIS. Los productos de CIS representan el esfuerzo de un verdadero ejército de voluntarios de toda la industria, que generosamente dedican su tiempo y talento en nombre de una experiencia en línea más segura para todos.

Licencia Creative Commons

Este trabajo está licenciado bajo una Licencia Internacional de Creative Commons Atribución-NoComercial-SinDerivadas 4.0 (el enlace se encuentra en <https://creativecommons.org/licenses/by-nc-nd/4.0/legalcode>).

Para aclarar aún más la licencia Creative Commons relacionada con el contenido de los CIS Controls®, usted está autorizado a copiar y redistribuir el contenido como un marco de referencia para su uso, dentro de su organización y fuera de ella, únicamente para fines no comerciales, siempre que (i) se otorgue el crédito correspondiente a CIS, y (ii) se proporcione un enlace a la licencia. Además, si usted remezcla, transforma o crea a partir de los CIS Controls, no podrá distribuir los materiales modificados. Los usuarios del marco de referencia de los CIS Controls también deben consultar (<http://www.cisecurity.org/controls/>) al referirse a los CIS Controls, para garantizar que estén utilizando la orientación más actualizada. El uso comercial de los CIS Controls está sujeto a la aprobación previa del Center for Internet Security, Inc. (CIS®).

Marzo de 2026

Contenido

Descripción general

Introducción	1
Evolución de los Controles CIS	1
Esta versión de los Controles CIS	3
El ecosistema de los Controles CIS (“No se trata solo de la lista”)	4
Cómo comenzar	5
Clases de activos	8

Controles Críticos de Seguridad del CIS

Control 1: Inventario y Control de Activos Empresariales	14
¿Por qué es crítico este Control?	14
Procedimientos y herramientas	15
Salvaguardass	16
Control 2: Inventario y Control de Activos de Software	18
¿Por qué es crítico este Control?	18
Procedimientos y herramientas	19
Salvaguardass	20
Control 3: Protección de Datos	22
¿Por qué es crítico este Control?	22
Procedimientos y herramientas	23
Salvaguardass	24
Control 4: Configuración Segura de Activos Empresariales y Software	27
¿Por qué es crítico este Control?	27
Procedimientos y herramientas	28
Salvaguardass	29

Control 5: Gestión de Cuentas	33
¿Por qué es crítico este Control?	33
Procedimientos y herramientas	34
Salvaguardass	35
Control 6: Gestión del Control de Acceso	36
¿Por qué es crítico este Control?	36
Procedimientos y herramientas	37
Salvaguardass	38
Control 7: Gestión Continua de Vulnerabilidades	40
¿Por qué es crítico este Control?	41
Procedimientos y herramientas	42
Salvaguardass	43
Control 8: Gestión de Registros de Auditoría	44
¿Por qué es crítico este Control?	44
Procedimientos y herramientas	45
Salvaguardass	46
Control 9: Protección de Correo Electrónico y Navegador Web	48
¿Por qué es crítico este Control?	48
Procedimientos y herramientas	49
Salvaguardass	50
Control 10: Defensas contra Malware	52
¿Por qué es crítico este Control?	52
Procedimientos y herramientas	52
Salvaguardass	53
Control 11: Recuperación de Datos	55
¿Por qué es crítico este Control?	55
Procedimientos y herramientas	55
Salvaguardass	56
Control 12: Gestión de Infraestructura de Red	58
¿Por qué es crítico este Control?	58
Procedimientos y herramientas	58
Salvaguardass	59
Control 13: Monitoreo y Defensa de Red	62
¿Por qué es crítico este Control?	62
Procedimientos y herramientas	63
Salvaguardass	64

Control 14: Concientización sobre Seguridad y Capacitación en Habilidades 67

¿Por qué es crítico este Control? 67

Procedimientos y herramientas 68

Salvaguardass 69

Control 15: Service Provider Management 72

¿Por qué es crítico este Control? 72

Procedimientos y herramientas 73

Salvaguardass 74

Control 16: Application Software Security 76

¿Por qué es crítico este Control? 76

Procedimientos y herramientas 77

Salvaguardass 79

Control 17: Incident Response Management 84

¿Por qué es crítico este Control? 84

Procedimientos y herramientas 85

Salvaguardass 86

Control 18: Penetration Testing 89

¿Por qué es crítico este Control? 89

Procedimientos y herramientas 90

Salvaguardass 91

Apéndice

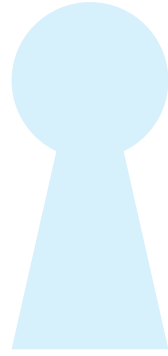
Acrónimos y Abreviaciones A1

Registro de Cambios A3

Glosario A4

Recursos y Referencias A9

Resumen



Introducción

Los Controles Críticos de Seguridad CIS® (Controles CIS®) comenzaron como una actividad comunitaria de base destinada a identificar los ciberataques reales más comunes e importantes que afectan diariamente a las organizaciones, traducir ese conocimiento y experiencia en acciones positivas y constructivas para los defensores, y luego compartir esa información con una audiencia más amplia. Los objetivos originales eran modestos: ayudar a las personas y organizaciones a enfocar su atención y comenzar con los pasos más importantes para defenderse de los ataques que realmente importan.

Liderados por el Center for Internet Security® (CIS®), los Controles CIS han evolucionado hasta convertirse en una comunidad internacional compuesta por individuos e instituciones voluntarias que:

- Comparten información sobre ataques y atacantes, identifican causas raíz y traducen esa información en clases de acciones defensivas.
- Crean y comparten herramientas, ayudas de trabajo e historias de adopción y resolución de problemas.
- Mapean los Controles CIS con marcos regulatorios y de cumplimiento para asegurar su alineación y otorgarles prioridad y enfoque colectivo.
- Identifican problemas y barreras comunes (como evaluaciones iniciales y hojas de ruta de implementación), y los resuelven como comunidad.

Los Controles CIS reflejan el conocimiento combinado de expertos de todos los sectores del ecosistema (empresas, gobiernos, individuos), con diversos roles (respondedores y analistas de amenazas, tecnólogos, operadores y defensores de tecnología de la información (TI), descubridores de vulnerabilidades, desarrolladores de herramientas, proveedores de soluciones, usuarios, formuladores de políticas, auditores, etc.), y de múltiples sectores (gobierno, energía, defensa, finanzas, transporte, academia, consultoría, seguridad, TI, etc.), que se han unido para crear, adoptar y respaldar los Controles CIS.

Evolución de los Controles CIS

Los Controles CIS comenzaron como muchas iniciativas similares: reunimos expertos, compartimos y debatimos hasta llegar a acuerdos. Esto puede ser muy valioso, dependiendo de las personas involucradas y su experiencia. Al documentar y compartir los resultados, todas las organizaciones pueden beneficiarse del trabajo de personas a las que no podrían contratar ni conocer. El resultado (y la confianza en él) mejora si se seleccionan expertos con un amplio rango de conocimientos, se aporta consistencia al proceso y se garantiza el uso de la mejor información disponible (especialmente sobre ataques). Aun así, uno sigue dependiendo del buen juicio de un grupo relativamente pequeño de personas, capturado de forma informal y narrativa.

En CIS, hemos recorrido un camino de varios años para aportar más datos, rigor y transparencia al proceso de recomendaciones de mejores prácticas (los CIS Benchmarks® y los Controles CIS). Todos estos elementos son esenciales para madurar una ciencia que respalde la defensa cibernética; y todos son necesarios para permitir la adaptación y “negociación” de acciones de seguridad aplicables a casos específicos y conforme a marcos de seguridad, regulaciones y esquemas similares de supervisión.

En las primeras versiones de los Controles CIS, utilizábamos una lista estándar de ataques públicamente conocidos como una prueba sencilla e informal de la utilidad de recomendaciones específicas. A partir de 2013, trabajamos con el equipo del Verizon Data Breach Investigations Report (DBIR) para mapear los resultados de su análisis de datos a gran escala directamente con los Controles CIS, como una forma de alinear sus resúmenes de ataques con un programa estándar de mejora defensiva.

Recientemente, CIS publicó el Community Defense Model (CDM), nuestro enfoque más orientado a datos hasta la fecha. En su versión inicial, el CDM analiza las conclusiones del DBIR más reciente de Verizon, junto con datos del Multi-State Information Sharing and Analysis Center® (MS-ISAC®), para identificar los cinco tipos de ataques más importantes. Describimos esos ataques utilizando el marco MITRE ATT&CK® (Adversarial Tactics, Techniques, and Common Knowledge) para crear patrones de ataque (o combinaciones específicas de tácticas y técnicas usadas en esos ataques). Esto nos permite analizar el valor de acciones defensivas individuales (es decir, los Safeguards¹) frente a esos ataques. Específicamente, también proporciona una forma coherente y explicable de observar el valor de seguridad de un conjunto determinado de acciones defensivas a lo largo del ciclo de vida del atacante, y servir como base para estrategias como defensa en profundidad. Los detalles de este análisis están disponibles en el sitio web de CIS. En resumen, hemos dado un paso importante para identificar el valor de seguridad de los Controles CIS o cualquier subconjunto de ellos. Aunque estas ideas aún están evolucionando, en CIS estamos comprometidos con la idea de recomendaciones de seguridad basadas en datos y presentadas con transparencia. Para más información, visite: <https://www.cisecurity.org/controls/v8-1/>.

Estas actividades garantizan que las Mejores Prácticas de Seguridad CIS (que incluyen los Controles CIS y los CIS Benchmarks) sean más que una lista de “cosas buenas por hacer” o “cosas que podrían ayudar”; en cambio, representan un conjunto prescriptivo, priorizado y altamente enfocado de acciones, con una red de apoyo comunitario que las hace implementables, utilizables, escalables y alineadas con todos los requisitos de seguridad del sector o del gobierno.

“Salvaguardas” se conocían como «Sub-Controles» antes de la Versión 8 de los Controles CIS.

Esta versión de los Controles CIS

La versión 8.1 (v8.1) de los Controles CIS es una actualización iterativa de la versión 8.0. Como parte de nuestro proceso de evolución, establecemos “principios de diseño” que guían cualquier actualización menor o mayor del documento. Los principios para esta revisión son: contexto, coexistencia y consistencia.

- **Contexto**

- Actualizamos los Controles CIS con nuevas clases de activos para que coincidan mejor con las partes específicas de la infraestructura empresarial a las que aplica cada Salvaguarda. Las nuevas clases requieren nuevas definiciones, por lo que también se mejoraron varias descripciones para ofrecer mayor detalle, aplicabilidad y claridad.

- **Coexistencia**

- Los Controles CIS siempre han mantenido alineación con los estándares y marcos del sector en evolución, y lo seguirán haciendo. Esto beneficia a todos los usuarios de los Controles y es un principio esencial de su funcionamiento. La publicación del CSF 2.0 de NIST requirió nuevas asignaciones y funciones de seguridad actualizadas.

- **Consistencia**

- Tradicionalmente, cualquier actualización iterativa de los Controles CIS debe minimizar el impacto sobre sus usuarios. Esto significa que no se modificaron los Grupos de Implementación en esta versión, y el espíritu de cada Salvaguarda se mantiene. Además, las nuevas clases de activos y sus definiciones se aplicaron de forma consistente a lo largo de los Controles, incorporando pequeñas actualizaciones. With these principles in mind, we’ve scoped the CIS Controls v8.1 to the following updates

- **Con estos principios en mente, el alcance de la versión 8.1 incluye**

- Reasignación de mapeos de funciones de seguridad del NIST CSF para coincidir con la versión 2.0.
- Inclusión de nuevas y ampliadas definiciones en el glosario para palabras reservadas utilizadas en los Controles (por ejemplo, plan, proceso, datos sensibles).
- Revisión de las clases de activos, junto con nuevos mapeos para las Salvaguardas.

- Corrección de errores tipográficos menores en las descripciones.

Aclaraciones añadidas a algunas descripciones poco desarrolladas. Una mejora clave en el mapeo de la versión 8.1 es la adición de la función de seguridad “Gobernanza”. Una gobernanza eficaz proporciona la estructura necesaria para orientar un programa de ciberseguridad hacia el logro de los objetivos empresariales. Los Controles están diseñados para ser lo suficientemente completos como para proteger programas de cualquier tamaño, y lo suficientemente prescriptivos como para facilitar su implementación. Con la actualización a la versión 8.1, ahora se identifican explícitamente temas de gobernanza como recomendaciones que pueden implementarse para mejorar la gobernanza del programa. Esto ayudará a los adoptantes a identificar mejor los elementos de gobernanza y contar con evidencia para demostrar cumplimiento.

Los Controles CIS buscan optimizar el proceso de diseño, implementación, medición y gestión de la seguridad empresarial. Esto implica simplificar el lenguaje para reducir duplicidades, enfocarse en acciones medibles con métricas definidas, y asegurar que cada Salvaguarda sea clara y concisa. CIS continúa equilibrando la necesidad de enfrentar los desafíos actuales de ciberseguridad con el mantenimiento de una estrategia defensiva estable y fundamental, evitando tecnologías excesivamente complejas o inaccesibles. La tecnología está en constante cambio, y el equipo de Controles CIS es consciente de los desarrollos en inteligencia artificial, realidad aumentada y computación ambiental, los cuales están remodelando nuestra infraestructura empresarial de formas sutiles y radicales. Estamos atentos y ya trabajando en ideas para la versión 9 de los Controles CIS.

El Ecosistema de los Controles CIS (“No se trata de la lista”)

Ya sea que utilice los Controles CIS u otro método para guiar su programa de mejora en seguridad, debe reconocer que “no se trata de la lista”. Se pueden obtener listas creíbles de recomendaciones de seguridad de muchas fuentes: lo mejor es ver la lista como un punto de partida. Es importante observar el ecosistema que se desarrolla en torno a la lista. ¿Dónde puedo obtener capacitación, información complementaria, explicaciones? ¿Cómo han implementado y utilizado estas recomendaciones otras organizaciones? ¿Existe un mercado de herramientas y servicios de proveedores para elegir? ¿Cómo mediré el progreso o madurez? ¿Cómo se alinea esto con los numerosos marcos regulatorios y de cumplimiento que me aplican? El verdadero poder de los Controles CIS no está en crear la mejor lista, sino en aprovechar la experiencia de una comunidad de individuos y organizaciones para lograr mejoras reales en seguridad mediante el intercambio de ideas, herramientas, lecciones y acciones colectivas.

Para respaldar esto, CIS actúa como catalizador y centro de intercambio para ayudarnos a aprender unos de otros. Desde la versión 6, ha habido una explosión de información complementaria, productos y servicios disponibles tanto desde CIS como de la industria en general. Envíe un correo electrónico a controlsinfo@cisecurity.org para obtener los siguientes tipos de ayudas de trabajo y otros materiales de apoyo:

- Mapeos desde los Controles CIS hacia una amplia variedad de marcos formales de gestión de riesgos (como NIST®, FISMA, ISO, etc.)
- Casos de uso de adopción empresarial
- Lista de referencias continuas a los Controles CIS en normas nacionales e internacionales, legislación y regulaciones estatales y nacionales, asociaciones comerciales y profesionales, etc.
- Información personalizada para pequeñas y medianas empresas
- Medición y métricas para los Controles CIS
- Referencias a documentos técnicos de proveedores y otros materiales que respaldan los Controles CIS
- Documentación sobre alineación con el Marco de Ciberseguridad del NIST®

Cómo comenzar



Históricamente, los Controles CIS se ordenaban en secuencia para enfocar las actividades de ciberseguridad de una organización, con un subconjunto de los primeros seis controles conocidos como “higiene cibernética”. Sin embargo, esto resultó ser demasiado simplista. Las organizaciones, especialmente las pequeñas, podían tener dificultades con algunas Salvaguardas tempranas y no llegar nunca a implementar controles posteriores (por ejemplo, tener una estrategia de respaldo para recuperarse de un ataque de ransomware). Como resultado, a partir de la versión 7.1, creamos los Grupos de Implementación (IG, por sus siglas en inglés) como nuestra nueva guía recomendada para priorizar

la implementación.

Los IG de los Controles CIS son categorías autoevaluadas para las organizaciones. Cada IG identifica un subconjunto de los Controles CIS que la comunidad ha evaluado en general como aplicables para una organización con un perfil de riesgo y recursos similares. Estos IG representan una vista transversal de los Controles CIS adaptada a diferentes tipos de organizaciones.

Específicamente, definimos IG1 como “higiene cibernética esencial”, el conjunto fundamental de Salvaguardas de defensa cibernética que toda organización debería aplicar para protegerse contra los ataques más comunes (<https://www.cisecurity.org/controls/v8-1/>). Cada IG se construye sobre el anterior: IG2 incluye IG1, e IG3 incluye todas las Salvaguardas de IG1 e IG2.

Uso o transición desde versiones anteriores de los Controles CIS

Dado que el panorama de amenazas cibernéticas cambia continuamente, creemos que la versión 8 y sus actualizaciones representan los controles más completos que hemos producido hasta ahora. También entendemos que las organizaciones que ya usan versiones anteriores como parte clave de su estrategia defensiva pueden mostrarse reacias a migrar a la versión 8. Nuestra recomendación es que si está utilizando la versión 7 o 7.1, está siguiendo un plan de seguridad efectivo y utilizable, y con el tiempo debería considerar avanzar hacia la última iteración. Si está usando la versión 6 (o anterior), le recomendamos planificar una transición a la versión 8 lo antes posible.

Para versiones anteriores, solo se proporcionaban herramientas básicas para facilitar la transición, como un registro de cambios en hoja de cálculo. Para la versión 8, hemos adoptado un enfoque mucho más integral y trabajado con numerosos socios para garantizar que el ecosistema de los Controles CIS esté listo para respaldar su transición. Más información en: <https://www.cisecurity.org/controls/v8-1/>.

Estructura de los Controles CIS

La presentación de cada Control en este documento incluye los siguientes elementos:

- Descripción general. Un resumen de la intención del Control y su utilidad como acción defensiva.
- ¿Por qué es crítico este Control? Una descripción de la importancia de este Control para bloquear, mitigar o identificar ataques, y una explicación de cómo los atacantes explotan activamente su ausencia.
- Procedimientos y herramientas. Una descripción más técnica de los procesos y tecnologías que permiten la implementación y automatización de este Control.
- Descripciones de Salvaguardas. una tabla con las acciones específicas que las organizaciones deben tomar para implementar el Control.

Grupos de Implementación



IG1

Una organización IG1 es pequeña o mediana, con experiencia limitada en TI y ciberseguridad para proteger sus activos y personal. Su principal preocupación es mantener las operaciones del negocio, ya que tienen poca tolerancia al tiempo de inactividad. La sensibilidad de los datos que intentan proteger es baja y se enfoca principalmente en la información de empleados y financiera.

Las Salvaguardas seleccionadas para IG1 deben ser implementables con conocimientos limitados de ciberseguridad y orientadas a prevenir ataques generales no dirigidos. También suelen estar diseñadas para funcionar con hardware y software comerciales comunes de oficina o uso doméstico.



IG2 (Incluye IG1)

Una organización IG2 emplea personas responsables de gestionar y proteger la infraestructura TI. Estas organizaciones respaldan múltiples departamentos con perfiles de riesgo diferentes según sus funciones y misiones. Algunas unidades pequeñas pueden tener cargas de cumplimiento normativo. Las organizaciones IG2 suelen almacenar y procesar información confidencial de clientes o de la empresa y pueden tolerar interrupciones breves del servicio. Una gran preocupación es la pérdida de confianza pública si ocurre una violación de seguridad.

Las Salvaguardas seleccionadas para IG2 ayudan a los equipos de seguridad a manejar una mayor complejidad operativa. Algunas Salvaguardas dependerán de tecnología empresarial y experiencia especializada para ser correctamente instaladas y configuradas.

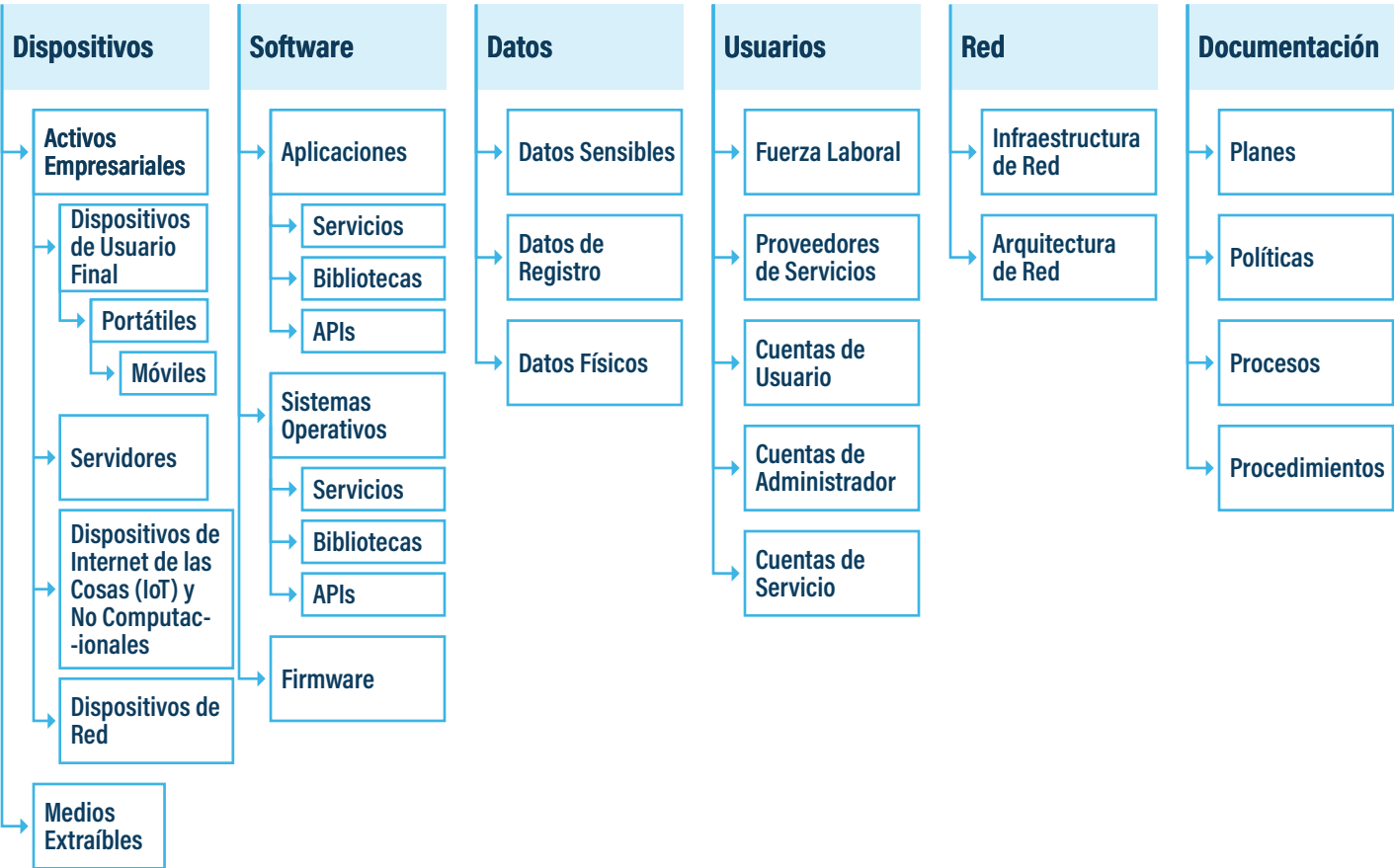


IG3 (Incluye IG1 and IG2)

Una organización IG3 emplea expertos en seguridad que se especializan en diversas áreas de la ciberseguridad (por ejemplo, gestión de riesgos, pruebas de penetración, seguridad de aplicaciones). Los activos y datos de IG3 contienen información o funciones sensibles sujetas a regulaciones y cumplimiento. Una organización IG3 debe atender a la disponibilidad de servicios, así como la confidencialidad e integridad de datos sensibles. Los ataques exitosos pueden causar un daño significativo al bienestar público.

Las Salvaguardas seleccionadas para IG3 deben contrarrestar ataques dirigidos por adversarios sofisticados y reducir el impacto de ataques de día cero.

Clases de Activos



Devices Dispositivos

Los dispositivos son activos empresariales (activos de procesamiento y almacenamiento de datos), dispositivos de usuario final, dispositivos portátiles, dispositivos móviles, servidores, dispositivos del Internet de las Cosas y dispositivos no informáticos, dispositivos de red y medios removibles. Los dispositivos pueden encontrarse en espacios físicos, infraestructura virtual o entornos en la nube. Los dispositivos pueden conectarse de forma remota a estos sistemas.

- **Activos Empresariales:** Activos con el potencial de almacenar o procesar datos. Para efectos de este documento, los activos empresariales incluyen dispositivos de usuario final, dispositivos de red, dispositivos no informáticos/IoT y servidores, en entornos físicos, virtuales y en la nube.
- **Dispositivos de Usuario Final:** Activos de tecnología de la información (TI) utilizados por miembros de una empresa durante horas laborales o fuera de ellas. Incluyen equipos de escritorio y estaciones de trabajo, así como dispositivos portátiles y móviles como laptops, teléfonos inteligentes y tabletas. Para efectos de este documento, los dispositivos de usuario final son un subconjunto de los activos empresariales.

- **Dispositivos Portátiles:** Dispositivos de usuario final transportables con capacidad de conectarse de manera inalámbrica a una red. Pueden incluir laptops que requieran hardware externo para conectividad y dispositivos móviles como teléfonos inteligentes y tabletas. Para efectos de este documento, los dispositivos portátiles son un subconjunto de los dispositivos de usuario final.
 - **Dispositivos Móviles:** Dispositivos pequeños de usuario final emitidos por la empresa con capacidad inalámbrica intrínseca, como teléfonos inteligentes y tabletas. Para efectos de este documento, los dispositivos móviles son un subconjunto de los dispositivos portátiles.
- **Servidores:** Dispositivo o sistema que proporciona recursos, datos, servicios o programas a otros dispositivos en una red de área local o red de área amplia. Los servidores pueden proporcionar recursos y utilizarlos de otro sistema al mismo tiempo. Pueden encontrarse en centros de datos, entornos de nube pública, privada o híbrida, incluyendo contenedores temporales o cargas de trabajo sin servidor. Ejemplos incluyen servidores web, de aplicaciones, de correo y de archivos. Para efectos de este documento, los servidores son un subconjunto de los activos empresariales.
- **Dispositivos IoT y No Informáticos:** Dispositivos con sensores, software y otras tecnologías integradas. Estos dispositivos pueden conectarse, almacenar e intercambiar datos con otros dispositivos y sistemas. La conexión a internet puede ser intermitente, inexistente o persistente. Ejemplos incluyen relojes inteligentes, impresoras, pantallas inteligentes, dispositivos domésticos inteligentes, altavoces, sistemas de control industrial y sensores de seguridad física. Para efectos de este documento, son un subconjunto de los activos empresariales.
- **Dispositivos de Red:** Dispositivos electrónicos necesarios para la comunicación e interacción entre dispositivos en una red informática. Incluyen puntos de acceso inalámbricos, firewalls, gateways físicos/virtuales, enrutadores y switches. Estos dispositivos pueden ser físicos, virtuales o basados en la nube. Para efectos de este documento, son un subconjunto de los activos empresariales. Se enumeran bajo Activos Empresariales debido a que se gestionan como otros dispositivos, pero también cumplen una función dual en la Clase de Activos de Red cuando están relacionados con la comunicación por red.
- **Medios Removibles:** Cualquier tipo de dispositivo de almacenamiento que puede extraerse de una computadora mientras el sistema está en funcionamiento y permite transferir datos entre sistemas. Ejemplos incluyen CDs, DVDs, discos Blu-ray, discos duros externos, tarjetas SD, cintas de respaldo, disquetes y unidades USB.

Software

Conjuntos de datos e instrucciones utilizados para dirigir a una computadora a completar una tarea específica. Los activos de software incluyen sistemas operativos y aplicaciones. Ambos pueden contener servicios, bibliotecas o Interfaces de Programación de Aplicaciones (API).

- **Aplicaciones:** Programa o conjunto de programas que se ejecutan sobre un sistema operativo en un activo empresarial. Ejemplos incluyen aplicaciones web, de base de datos, en la nube y móviles. En este documento, las aplicaciones se consideran un activo de software.
- **Sistemas Operativos:** Software en activos empresariales que gestiona el hardware y los recursos de software de la computadora y proporciona servicios comunes para los programas. Ejemplos: Windows, Ubuntu, MacOS, Android y z/OS. Se consideran un activo de software.
 - **Servicios:** Programas especializados que realizan tareas críticas bien definidas para el sistema operativo. Usualmente inician con el sistema operativo, se ejecutan en segundo plano y pueden ser detenidos o iniciados por usuarios. Ejemplos: gestión de comunicaciones de red, usuarios, permisos de archivos, seguridad del sistema e interacción con dispositivos.
 - **Biblioteca:** Conjunto de código precompilado reutilizable que incluye clases, procedimientos, scripts, datos de configuración, etc., utilizado para desarrollar programas y aplicaciones de software. Están diseñadas para ayudar tanto al programador como al compilador del lenguaje en la construcción y ejecución eficiente del software.
 - **Interfaz de Programación de Aplicaciones (API):** Conjunto de reglas e interfaces para que los componentes de software interactúen de manera estandarizada. Permiten que las aplicaciones accedan y se comuniquen con recursos internos y externos.
- **Firmware:** Software almacenado en la memoria no volátil del dispositivo, como ROM o memoria flash, utilizado para permitir que diferentes tipos de hardware se comuniquen con el sistema operativo. A menudo se actualiza fuera del proceso de actualización del sistema operativo o de las aplicaciones empresariales.

Datos

Colección de hechos que pueden ser examinados, considerados y utilizados para la toma de decisiones. Aunque los datos pueden ser físicos, los Controles CIS están enfocados principalmente en la protección de datos digitales que pueden ser almacenados, transferidos y procesados por activos empresariales.

- **Datos Sensibles:** Datos físicos o digitales almacenados, procesados o gestionados por la empresa que deben mantenerse privados, precisos, fiables y disponibles. Su divulgación o destrucción no autorizada puede causar daño a la empresa o sus clientes, por ejemplo, mediante una filtración de datos o violación de políticas, contratos o regulaciones.

- **Datos de Registro (Log):** Archivos generados por computadora que registran eventos ocurridos dentro de la empresa. Ejemplos: registros del sistema operativo, detección de malware, base de datos, aplicación, red, firewall, servidor web o control de acceso (como cerraduras electrónicas, sistemas de alarma).
- **Datos Físicos:** Datos almacenados en documentos físicos o en medios removibles físicos (por ejemplo, unidades USB, cintas de respaldo). Pueden ser sensibles o no.

Usuarios

Empleados, proveedores externos, contratistas, proveedores de servicios, consultores u otra persona autorizada para acceder a un activo empresarial.

También incluye cuentas de usuario, administrador y servicio.

- **Personal:** Todas las personas empleadas o contratadas por una organización con acceso a sus sistemas de información, activos o recursos. Incluye empleados presenciales y remotos, excluyendo proveedores de servicios y consultores.
- **Proveedores de Servicios:** Entidad que ofrece plataformas, software y servicios a otras empresas. Ejemplos: consultores de TI, proveedores de servicios gestionados (MSP), plataformas SaaS y proveedores de servicios en la nube. Los proveedores y terceros también se consideran proveedores de servicios. Estos servicios pueden ser pagos o gratuitos. Algunas relaciones pueden o no requerir contratos o acuerdos de nivel de servicio (SLA). Ejemplos: análisis de datos, bloqueo de tráfico, etc.
- **Cuentas de Usuario:** Identidad compuesta por credenciales (usuario, contraseña) que define a un usuario en un sistema. Administra la información, configuraciones, archivos y permisos de acceso del usuario. Para este documento, se refiere a cuentas “estándar” con privilegios limitados para tareas generales.
- **Cuentas de Administrador:** Cuentas para usuarios con privilegios elevados, utilizadas para gestionar aspectos de una computadora, dominio o toda la infraestructura TI de la empresa. Debe asignarse una cuenta de administrador por usuario. Subtipos comunes incluyen cuentas root, administrador local, administrador de dominio y administrador de dispositivos de red o seguridad.
- **Cuentas de Servicio:** Creadas específicamente para ejecutar aplicaciones, servicios y tareas automatizadas en un sistema operativo. También pueden ser usadas solo para ser propietarias de datos o archivos de configuración. Cada cuenta de servicio debe usarse para un propósito específico y tener un propietario responsable. No deben usarse para tareas generales de cómputo.

Red

Una red es un conjunto de dispositivos interconectados que intercambian datos. Red es un superconjunto de infraestructura de red y arquitectura de red.

- **Infraestructura de Red:** Conjunto de recursos de red que proporcionan conectividad, gestión, operaciones comerciales y comunicación. Consiste en hardware, software, sistemas y dispositivos, y permite el cómputo y la comunicación entre usuarios, servicios, aplicaciones y procesos. Puede estar en la nube, física o virtual.
- **Arquitectura de Red:** Se refiere al diseño físico y lógico de una red. Define cómo está organizada, incluyendo las conexiones entre dispositivos y software, así como los datos que se transmiten entre ellos. Esto incluye diagramas de arquitectura de red y diagramas de arquitectura de seguridad.

Documentación

Políticas, procesos, procedimientos, planes, diagramas y otros materiales escritos (físicos o digitales). Ejemplos: métodos de gobernanza de una empresa, procesos seguidos por usuarios, o descripción de la arquitectura de red.

- **Plan:** Implementa políticas y puede incluir grupos de políticas, procesos y procedimientos.
- **Política:** Declaración oficial de gobernanza que establece objetivos específicos de un programa de seguridad de la información.
- **Proceso:** Conjunto de tareas y actividades generales para lograr metas relacionadas con la seguridad.
- **Procedimiento:** Conjunto ordenado de pasos a seguir para cumplir una tarea específica. Proporciona la manera aprobada de realizar una acción en un entorno tecnológico y organizacional determinado.

Controles Críticos de Seguridad del CIS



Inventario y Control de Activos Empresariales

Salvaguardass: 5	IG1: 2/5	IG2: 4/5	IG3: 5/5
------------------	----------	----------	----------

Descripción general

Administrar activamente (inventariar, rastrear y corregir) todos los activos empresariales (dispositivos de usuario final, incluidos los portátiles y móviles; dispositivos de red; dispositivos no informáticos/Internet de las Cosas (IoT); y servidores) conectados a la infraestructura de forma física, virtual, remota y aquellos en entornos de nube, para conocer con precisión la totalidad de los activos que deben ser monitoreados y protegidos dentro de la empresa. Esto también apoyará la identificación de activos no autorizados y no gestionados para su eliminación o remediación.

¿Por qué este Control es crítico?

Las organizaciones no pueden defender lo que no saben que tienen. El control gestionado de todos los activos empresariales también desempeña un papel fundamental en el monitoreo de seguridad, la respuesta a incidentes, la copia de seguridad y la recuperación del sistema.

Las organizaciones deben conocer qué datos son críticos para ellas, y una gestión adecuada de activos ayudará a identificar aquellos activos empresariales que contienen o gestionan estos datos críticos, para así aplicar los controles de seguridad adecuados.

Los atacantes externos escanean continuamente el espacio de direcciones de internet de las empresas objetivo, ya sea en instalaciones físicas o en la nube, identificando activos potencialmente desprotegidos conectados a la red de la empresa. Los atacantes pueden aprovechar los nuevos activos que se instalan pero que no están configurados ni parcheados de manera segura. Internamente, los activos no identificados también pueden tener configuraciones de seguridad débiles que los hacen vulnerables al malware basado en la web o en correos electrónicos; y los adversarios pueden aprovechar esas configuraciones débiles para moverse dentro de la red una vez dentro.

Los activos adicionales que se conectan a la red de la empresa (por ejemplo, sistemas de demostración, sistemas de prueba temporales, redes para invitados) deben ser identificados y/o aislados para evitar que el acceso de adversarios afecte la seguridad de las operaciones empresariales.

Las organizaciones grandes, complejas y dinámicas comprensiblemente enfrentan dificultades para gestionar entornos complejos y de rápido cambio. Sin embargo, los atacantes han demostrado tener la capacidad, paciencia y disposición para “inventariar y controlar” los activos empresariales a gran escala para aprovechar oportunidades.

Otro desafío es que los dispositivos portátiles de usuario final se conectan periódicamente a una red y luego desaparecen, haciendo que el inventario de activos disponibles sea muy dinámico. Asimismo, los entornos en la nube y las máquinas virtuales pueden ser difíciles de rastrear en los inventarios de activos cuando se apagan o se ponen en pausa.

Otro beneficio de una gestión completa de activos empresariales es apoyar la respuesta a incidentes, tanto al investigar el origen del tráfico de red desde un activo en la red, como al identificar todos los activos potencialmente vulnerables o afectados de tipo o ubicación similar durante un incidente.

Procedimientos y herramientas

Este Control del CIS requiere acciones tanto técnicas como procedimentales, unidas en un proceso que contabilice y gestione el inventario de los activos empresariales y todos los datos asociados a lo largo de su ciclo de vida. También se vincula con la gobernanza empresarial mediante el establecimiento de responsables de datos/activos para cada componente de un proceso de negocio. Las organizaciones pueden utilizar productos empresariales integrales a gran escala para mantener inventarios de activos de TI. Las empresas más pequeñas pueden aprovechar herramientas de seguridad ya instaladas en los activos empresariales o utilizadas en la red para recopilar esta información. Esto incluye realizar escaneos de descubrimiento en la red con un escáner de vulnerabilidades; revisar registros de antimalware, portales de seguridad de endpoints, registros de red de switches o registros de autenticación; y gestionar los resultados en una hoja de cálculo o base de datos.

Mantener una vista actual y precisa de los activos empresariales es un proceso continuo y dinámico. Incluso en grandes organizaciones, rara vez existe una única fuente de verdad, ya que los activos empresariales no siempre son provistos o instalados por el departamento de TI. La realidad es que se necesita “colaboración colectiva” de diversas fuentes para determinar un conteo confiable de activos empresariales. Las organizaciones pueden escanear activamente de forma regular, enviando distintos tipos de paquetes para identificar los activos conectados a la red. Además de las fuentes mencionadas anteriormente para empresas pequeñas, las grandes pueden recopilar datos de portales en la nube y registros de plataformas empresariales como: Active Directory (AD), inicio de sesión único (SSO), autenticación multifactor (MFA), red privada virtual (VPN), sistemas de detección de intrusiones (IDS) o inspección profunda de paquetes (DPI), gestión de dispositivos móviles (MDM), y herramientas de escaneo de vulnerabilidades. Las bases de datos de inventario de propiedades, el seguimiento de órdenes de compra y listas de inventario locales son otras fuentes de datos para determinar qué dispositivos están conectados. Existen herramientas y métodos que normalizan estos datos para identificar dispositivos únicos entre estas fuentes.

- Para orientación específica sobre la nube, consulte la Guía Complementaria sobre Controles CIS en la Nube: CIS Controls Cloud Companion Guide: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

- Para orientación sobre tabletas y teléfonos inteligentes, consulte la Guía Complementaria sobre Controles CIS para Móviles: CIS Controls Mobile Companion Guide: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>
- Para orientación sobre IoT, consulte la Guía Complementaria sobre Controles CIS para el Internet de las Cosas: CIS Controls Internet of Things Companion Guide: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>
- Para orientación sobre Sistemas de Control Industrial (ICS), consulte la Guía de Implementación de Controles CIS para ICS: CIS Controls ICS Implementation Guide: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

Salvaguardas

Salvaguardas 1.1: Establecer y Mantener un Inventario Detallado de Activos Empresariales

Tipo de Activo:	Dispositivos	Función de Seguridad:	Identificar	IG1	IG2	IG3
------------------------	--------------	------------------------------	-------------	-----	-----	-----

Establecer y mantener un inventario preciso, detallado y actualizado de todos los activos empresariales con el potencial de almacenar o procesar datos, incluyendo: dispositivos de usuario final (incluidos los portátiles y móviles), dispositivos de red, dispositivos no informáticos/dispositivos IoT y servidores. Asegurar que el inventario registre la dirección de red (si es estática), la dirección de hardware, el nombre del equipo, el propietario del activo empresarial, el departamento correspondiente a cada activo y si el activo ha sido aprobado para conectarse a la red. Para dispositivos móviles de usuario final, herramientas tipo MDM pueden apoyar este proceso, cuando sea apropiado. Este inventario incluye activos conectados a la infraestructura de forma física, virtual, remota, así como aquellos en entornos de nube. Además, incluye activos que se conectan regularmente a la infraestructura de red de la empresa, incluso si no están bajo el control de la misma. Revisar y actualizar el inventario de todos los activos empresariales semestralmente, o con mayor frecuencia.

Salvaguardas 1.2: Abordar Activos No Autorizados

Tipo de Activo:	Dispositivos	Función de Seguridad:	Responder	IG1	IG2	IG3
------------------------	--------------	------------------------------	-----------	-----	-----	-----

Asegurar que exista un proceso para abordar los activos no autorizados de manera semanal. La empresa puede optar por retirar el activo de la red, denegar su conexión remota a la red o poner el activo en cuarentena.

Salvavidas 1.3: Utilizar una Herramienta de Descubrimiento Activo

Tipo de Activo:	Dispositivos	Función de Seguridad:	Detectar	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----

Utilizar una herramienta de descubrimiento activo para identificar los activos conectados a la red de la empresa. Configurar la herramienta de descubrimiento activo para que se ejecute diariamente o con mayor frecuencia.

Salvavidas 1.4: Utilizar el Registro de Protocolo de Configuración Dinámica de Host (DHCP) para Actualizar el Inventario de Activos Empresariales

Tipo de Activo:	Dispositivos	Función de Seguridad:	Identificar	IG2	IG3
-----------------	--------------	-----------------------	-------------	-----	-----

Utilizar el registro DHCP en todos los servidores DHCP o herramientas de gestión de direcciones de Protocolo de Internet (IP) para actualizar el inventario de activos de la empresa. Revisar y utilizar los registros para actualizar el inventario de activos empresariales semanalmente, o con mayor frecuencia.

Salvavidas 1.5: Usar una Herramienta de Descubrimiento Pasivo de Activos

Tipo de Activo:	Dispositivos	Función de Seguridad:	Detectar	IG3
-----------------	--------------	-----------------------	----------	-----

Usar una herramienta de descubrimiento pasivo para identificar los activos conectados a la red de la empresa. Revisar y utilizar los escaneos para actualizar el inventario de activos empresariales al menos semanalmente, o con mayor frecuencia.

CONTROL 2

Inventario y Control de Activos de Software

Salvaguardass: 7

IG1: 3/7

IG2: 6/7

IG3: 7/7

Descripción general

Gestionar activamente (inventariar, rastrear y corregir) todo el software (sistemas operativos y aplicaciones) en la red para que solo el software autorizado esté instalado y pueda ejecutarse, y para que el software no autorizado y no gestionado sea detectado y se impida su instalación o ejecución.

¿Por qué es crítico este Control?

Un inventario completo de software es una base fundamental para prevenir ataques. Los atacantes escanean continuamente las empresas objetivo en busca de versiones vulnerables de software que puedan ser explotadas remotamente. Por ejemplo, si un usuario abre un sitio web malicioso o un archivo adjunto con un navegador vulnerable, un atacante puede instalar programas de acceso encubierto y bots que le otorguen control a largo plazo sobre el sistema. Los atacantes también pueden usar este acceso para moverse lateralmente a través de la red. Una de las principales defensas contra estos ataques es actualizar y aplicar parches al software. Sin embargo, sin un inventario completo de activos de software, una empresa no puede determinar si tiene software vulnerable o si existen posibles violaciones de licencias.

Incluso si un parche aún no está disponible, una lista completa de software permite a una empresa protegerse contra ataques conocidos hasta que el parche sea liberado. Algunos atacantes sofisticados utilizan “exploits de día cero”, que aprovechan vulnerabilidades previamente desconocidas para las cuales aún no se ha publicado un parche por parte del proveedor del software. Estos errores de diseño proporcionan cero días a los desarrolladores para corregir los problemas antes de que los atacantes puedan explotarlos. Dependiendo de la gravedad del exploit, una empresa puede implementar medidas de mitigación temporales para protegerse contra ataques hasta que el parche esté disponible.

La gestión de activos de software también es importante para identificar riesgos de seguridad innecesarios. Una empresa debe revisar su inventario de software para identificar cualquier activo empresarial que ejecute software innecesario para sus fines comerciales. Por ejemplo, un activo empresarial puede venir con software predeterminado instalado que representa un riesgo de seguridad potencial y no proporciona ningún beneficio para la empresa. Es fundamental inventariar, entender, evaluar y gestionar todo el software conectado a la infraestructura de una empresa.

Procedimientos y herramientas

Las listas de permitidos (allowlisting) pueden implementarse mediante una combinación de herramientas comerciales de listas blancas, políticas o herramientas de ejecución de aplicaciones que vienen integradas en suites antimalware y sistemas operativos populares. Existen ampliamente disponibles herramientas comerciales de inventario de software que se utilizan en muchas empresas actualmente. Las mejores de estas herramientas proporcionan una verificación de inventario de cientos de software comunes utilizados en las empresas. Las herramientas extraen información sobre el nivel de parches de cada programa instalado para asegurar que sea la versión más reciente y utilizan nombres de aplicaciones estandarizados, como los encontrados en la especificación Common Platform Enumeration (CPE).

Las funciones que implementan listas blancas están incluidas en muchas suites modernas de seguridad para endpoints e incluso implementadas de forma nativa en ciertas versiones de sistemas operativos principales. Además, las soluciones comerciales integran cada vez más antimalware, antispyware, cortafuegos personal y sistemas de detección y prevención de intrusos basados en host (IDS/IPS), junto con funcionalidades de permitir o bloquear aplicaciones. En particular, la mayoría de las soluciones de seguridad para endpoints pueden examinar el nombre, la ubicación en el sistema de archivos y/o el hash criptográfico de un ejecutable dado para determinar si la aplicación debe permitirse ejecutarse en la máquina protegida. Las herramientas más eficaces ofrecen listas de permitidos personalizadas basadas en la ruta del ejecutable, hash o coincidencia mediante expresiones regulares. Algunas incluso incluyen una función de aplicaciones no maliciosas pero no aprobadas que permite a los administradores definir reglas para la ejecución de software específico para ciertos usuarios y en horarios determinados.

- Para orientación específica sobre la nube, consulte la Guía Complementaria de la Nube de los Controles CIS: CIS Controls Cloud Companion Guide: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>
- Para orientación sobre tabletas y teléfonos inteligentes, consulte la Guía Complementaria Móvil de los Controles CIS: CIS Controls Mobile Companion Guide: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>
- Para orientación sobre IoT, consulte la Guía Complementaria del Internet de las Cosas de los Controles CIS: CIS Controls Internet of Things Companion Guide: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>
- Para orientación sobre Sistemas de Control Industrial (ICS), consulte la Guía de Implementación de ICS de los Controles CIS: CIS Controls ICS Implementation Guide: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

Salvaguardass

Salvaguardas 2.1: Establecer y Mantener un Inventario de Software

Tipo de Activo:	Software	Función de Seguridad:	Identificar	IG1	IG2	IG3
-----------------	----------	-----------------------	-------------	-----	-----	-----

Establecer y mantener un inventario detallado de todo el software con licencia instalado en los activos empresariales. El inventario de software debe documentar el título, el editor, la fecha de instalación/uso inicial y el propósito empresarial de cada entrada; cuando corresponda, incluir el Localizador Uniforme de Recursos (URL), tienda(s) de aplicaciones, versión(es), mecanismo de implementación, fecha de desactivación y número de licencias. Revisar y actualizar el inventario de software semestralmente, o con mayor frecuencia.

Salvaguardas 2.2: Garantizar que el Software Autorizado esté Actualmente Soportado

Tipo de Activo:	Software	Función de Seguridad:	Identificar	IG1	IG2	IG3
-----------------	----------	-----------------------	-------------	-----	-----	-----

Garantizar que solo el software actualmente soportado esté designado como autorizado en el inventario de software para los activos empresariales. Si un software no cuenta con soporte, pero es necesario para el cumplimiento de la misión de la empresa, documentar una excepción que detalle los controles de mitigación y la aceptación del riesgo residual. Para cualquier software sin soporte que no cuente con documentación de excepción, designarlo como no autorizado. Revisar la lista de software para verificar el soporte del software al menos mensualmente, o con mayor frecuencia.

Salvaguardas 2.3: Abordar el Software No Autorizado

Tipo de Activo:	Software	Función de Seguridad:	Responder	IG1	IG2	IG3
-----------------	----------	-----------------------	-----------	-----	-----	-----

Asegurar que el software no autorizado sea eliminado de los activos empresariales o cuente con una excepción documentada. Revisar mensualmente, o con mayor frecuencia.

Salvaguardas 2.4: Utilizar Herramientas Automatizadas de Inventario de Software

Tipo de Activo:	Software	Función de Seguridad:	Detectar	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Utilizar herramientas de inventario de software, cuando sea posible, en toda la empresa para automatizar el descubrimiento y la documentación del software instalado.

Salvaguardas 2.5: Lista de Permitidos para el Software Autorizado

Tipo de Activo: Software	Función de Seguridad: Proteger	IG2	IG3
--------------------------	--------------------------------	-----	-----

Utilizar controles técnicos, como listas de permitidos para aplicaciones, para garantizar que solo el software autorizado pueda ejecutarse o ser accedido. Reevaluar semestralmente, o con mayor frecuencia.

Salvaguardas 2.6: Lista de Permitidos para Bibliotecas Autorizadas

Tipo de Activo: Software	Función de Seguridad: Proteger	IG2	IG3
--------------------------	--------------------------------	-----	-----

Utilizar controles técnicos para garantizar que solo las bibliotecas de software autorizadas, como archivos específicos .dll, .ocx y .so, puedan cargarse en un proceso del sistema. Bloquear la carga de bibliotecas no autorizadas en un proceso del sistema. Reevaluar semestralmente, o con mayor frecuencia.

Salvaguardas 2.7: Lista de Permitidos para Scripts Autorizados

Tipo de Activo: Software	Función de Seguridad: Proteger	IG3
--------------------------	--------------------------------	-----

Utilizar controles técnicos, como firmas digitales y control de versiones, para garantizar que solo los scripts autorizados, como archivos específicos .ps1 y .py, puedan ejecutarse. Bloquear la ejecución de scripts no autorizados. Reevaluar semestralmente, o con mayor frecuencia.

CONTROL 3

Protección de Datos

Salvaguardass: 14	IG1: 6/14	IG2: 12/14	IG3: 14/14
-------------------	-----------	------------	------------

Descripción general

Desarrollar procesos y controles técnicos para identificar, clasificar, manejar de forma segura, retener y eliminar datos.

¿Por qué es crítico este Control?

Los datos ya no se encuentran únicamente dentro de los límites de una empresa; están en la nube, en dispositivos portátiles de los usuarios finales que trabajan desde casa y, con frecuencia, se comparten con socios o servicios en línea que podrían almacenarlos en cualquier parte del mundo. Además de los datos sensibles que una empresa posee relacionados con finanzas, propiedad intelectual y datos de clientes, también pueden existir numerosas regulaciones internacionales para la protección de datos personales. La privacidad de los datos ha cobrado una importancia creciente, y las empresas están comprendiendo que la privacidad trata sobre el uso y manejo adecuados de los datos, no solo sobre el cifrado. Los datos deben ser gestionados adecuadamente durante todo su ciclo de vida. Estas normas de privacidad pueden ser complejas para empresas multinacionales de cualquier tamaño; sin embargo, existen fundamentos que se pueden aplicar a todas.

Una vez que los atacantes han penetrado la infraestructura de una empresa, una de sus primeras tareas es localizar y exfiltrar datos. Las empresas podrían no ser conscientes de que están saliendo datos sensibles de su entorno porque no están monitoreando los flujos de salida de datos.

Aunque muchos ataques ocurren en la red, otros implican el robo físico de dispositivos portátiles de usuarios finales, ataques a proveedores de servicios u otros socios que almacenan datos sensibles. Otros activos sensibles de la empresa también pueden incluir dispositivos no informáticos que proporcionan gestión y control de sistemas físicos, como los sistemas SCADA (Supervisory Control and Data Acquisition, por sus siglas en inglés).

La pérdida de control por parte de la empresa sobre datos protegidos o sensibles representa un impacto empresarial grave y, a menudo, reportable. Aunque algunos datos se ven comprometidos o se pierden como resultado de robo o espionaje, la gran mayoría son consecuencia de normas de gestión de datos mal comprendidas y errores de los usuarios. La adopción de cifrado de datos, tanto en tránsito como en reposo, puede mitigar el compromiso de datos y, aún más importante, es un requisito normativo para la mayoría de los datos controlados.

Procedimientos y herramientas

Es importante que una empresa desarrolle un proceso de gestión de datos que incluya un marco de gestión de datos, directrices de clasificación de datos y requisitos para la protección, manejo, retención y eliminación de datos. También debe existir un proceso para responder a brechas de datos que se integre con el plan de respuesta a incidentes, y con los planes de cumplimiento y comunicación. Para definir los niveles de sensibilidad de los datos, las empresas deben catalogar sus tipos clave de datos y la criticidad general (impacto ante su pérdida o corrupción) para la empresa. Este análisis se utilizaría para crear un esquema general de clasificación de datos para la empresa. Las empresas pueden utilizar etiquetas como “Sensible”, “Confidencial” y “Público”, y clasificar sus datos de acuerdo con estas etiquetas.

Una vez definida la sensibilidad de los datos, se debe desarrollar un inventario o mapeo de datos que identifique el software que accede a los datos con diversos niveles de sensibilidad y los activos empresariales que alojan esas aplicaciones. Idealmente, la red debería estar segmentada de manera que los activos empresariales con el mismo nivel de sensibilidad se encuentren en la misma red y estén separados de los activos con diferentes niveles de sensibilidad. Si es posible, se deben utilizar firewalls para controlar el acceso a cada segmento, y aplicar reglas de acceso de usuarios que permitan el acceso únicamente a aquellos con una necesidad empresarial.

Para un tratamiento más exhaustivo de este tema, sugerimos los siguientes recursos para ayudar a la empresa con la protección de datos:

- NIST® SP 800-88r1 Guía de Sanitización de Medios: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r1.pdf>
- NIST® FIPS 140-2: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.140-2.pdf>
- NIST® FIPS 140-3: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.140-3.pdf>
- Para orientación específica sobre la nube, consulte la Guía complementaria para la nube de los Controles CIS: CIS Controls Cloud Companion Guide: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>
- Para orientación sobre tabletas y teléfonos inteligentes, consulte la Guía complementaria para dispositivos móviles de los Controles CIS: CIS Controls Mobile Companion Guide: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

Salvaguardass

Salvaguardas 3.1: Establecer y Mantener un Proceso de Gestión de Datos

Tipo de Activo:	Datos	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----	-----

Establecer y mantener un proceso documentado de gestión de datos. En dicho proceso, abordar la sensibilidad de los datos, el propietario de los datos, el manejo de los datos, los límites de retención de datos y los requisitos de eliminación, según los estándares de sensibilidad y retención de la empresa. Revisar y actualizar la documentación anualmente, o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvaguardas 3.2: Establecer y Mantener un Inventario de Datos

Tipo de Activo:	Datos	Función de Seguridad:	Identificar	IG1	IG2	IG3
-----------------	-------	-----------------------	-------------	-----	-----	-----

Establecer y mantener un inventario de datos basado en el proceso de gestión de datos de la empresa. Como mínimo, se debe inventariar la información sensible. Revisar y actualizar el inventario al menos una vez al año, con prioridad en los datos sensibles.

Salvaguardas 3.3: Configurar Listas de Control de Acceso a Datos

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----	-----

Configurar listas de control de acceso a datos según la necesidad de conocimiento del usuario. Aplicar listas de control de acceso a datos, también conocidas como permisos de acceso, a sistemas de archivos locales y remotos, bases de datos y aplicaciones.

Salvaguardas 3.4: Hacer Cumplir la Retención de Datos

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----	-----

Retener los datos conforme al proceso documentado de gestión de datos de la empresa. La retención de datos debe incluir tanto los plazos mínimos como los máximos.

Salvaguardas 3.5: Eliminar los Datos de Forma Segura

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----	-----

Eliminar los datos de forma segura, según lo estipulado en el proceso documentado de gestión de datos de la empresa. Asegurar que el proceso y método de eliminación sean acordes con la sensibilidad de los datos.

Salvaguardas 3.6: Cifrar los Datos en Dispositivos del Usuario Final

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----	-----

Cifrar los datos en los dispositivos del usuario final que contengan datos sensibles. Las implementaciones de ejemplo pueden incluir: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.

Salvaguardas 3.7: Establecer y Mantener un Esquema de Clasificación de Datos

Tipo de Activo:	Datos	Función de Seguridad:	Identificar	IG2	IG3
-----------------	-------	-----------------------	-------------	-----	-----

Establecer y mantener un esquema general de clasificación de datos para la empresa. Las empresas pueden utilizar etiquetas como “Sensible”, “Confidencial” y “Público”, y clasificar sus datos de acuerdo con dichas etiquetas. Revisar y actualizar el esquema de clasificación anualmente, o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvaguardas 3.8: Documentar los Flujos de Datos

Tipo de Activo:	Datos	Función de Seguridad:	Identificar	IG2	IG3
-----------------	-------	-----------------------	-------------	-----	-----

Documentar los flujos de datos. La documentación de flujos de datos incluye los flujos de datos con proveedores de servicios y debe basarse en el proceso de gestión de datos de la empresa. Revisar y actualizar la documentación anualmente, o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvaguardas 3.9: Cifrar los Datos en Medios Removibles

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Cifrar los datos en medios removibles..

Salvaguardas 3.10: Cifrar los Datos Sensibles en Reposo

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Cifrar los datos sensibles en tránsito. Las implementaciones de ejemplo pueden incluir: Transport Layer Security (TLS) y Open Secure Shell (OpenSSH).

Salvavidas 3.11: Cifrar los Datos Sensibles en Reposo

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Cifrar los datos sensibles en reposo en servidores, aplicaciones y bases de datos. El cifrado a nivel de almacenamiento, también conocido como cifrado del lado del servidor, cumple con el requisito mínimo de esta Salvavidas. Métodos adicionales de cifrado pueden incluir cifrado a nivel de aplicación, también conocido como cifrado del lado del cliente, donde el acceso al dispositivo de almacenamiento de datos no permite el acceso a los datos en texto plano.

Salvavidas 3.12: Segmentar el Procesamiento y Almacenamiento de Datos Según su Sensibilidad

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Segmentar el procesamiento y almacenamiento de datos según la sensibilidad de los mismos. No procesar datos sensibles en activos empresariales destinados a datos de menor sensibilidad.

Salvavidas 3.13: Implementar una Solución de Prevención de Pérdida de Datos

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG3
-----------------	-------	-----------------------	----------	-----

Implementar una herramienta automatizada, como una herramienta de Prevención de Pérdida de Datos (DLP, por sus siglas en inglés) basada en el host, para identificar todos los datos sensibles almacenados, procesados o transmitidos a través de los activos empresariales, incluidos aquellos ubicados en sitio o en un proveedor de servicios remoto, y actualizar el inventario de datos de la empresa.

Salvavidas 3.14: Registrar el Acceso a Datos Sensibles

Tipo de Activo:	Datos	Función de Seguridad:	Detectar	IG3
-----------------	-------	-----------------------	----------	-----

Registrar el acceso a datos sensibles, incluida su modificación y eliminación.

CONTROL 4

Configuración Segura de Activos Empresariales y Software

Salvaguardass: 12	IG1: 7/12	IG2: 11/12	IG3: 12/12
-------------------	-----------	------------	------------

Descripción general

Establecer y mantener la configuración segura de los activos empresariales (dispositivos de usuario final, incluidos los portátiles y móviles; dispositivos de red; dispositivos no informáticos/IoT; y servidores) y del software (sistemas operativos y aplicaciones).

¿Por qué es crítico este Control?

Tal como se entregan por parte de los fabricantes y distribuidores, las configuraciones predeterminadas para los activos empresariales y el software suelen estar orientadas a facilitar la implementación y el uso, en lugar de la seguridad. Controles básicos, servicios y puertos abiertos, cuentas o contraseñas predeterminadas, configuraciones preestablecidas del Sistema de Nombres de Dominio (DNS), protocolos antiguos (vulnerables) y la preinstalación de software innecesario pueden ser elementos explotables si se dejan en su estado predeterminado. Además, estas actualizaciones de configuración de seguridad deben gestionarse y mantenerse durante todo el ciclo de vida de los activos empresariales y el software. Las actualizaciones de configuración deben ser registradas y aprobadas a través de un proceso de flujo de trabajo de gestión de configuración, con el fin de mantener un registro que pueda ser revisado para cumplimiento, utilizado en la respuesta a incidentes y para respaldar auditorías. Este Control CIS es importante tanto para dispositivos en las instalaciones como para dispositivos remotos, dispositivos de red y entornos en la nube.

Los proveedores de servicios desempeñan un papel clave en las infraestructuras modernas, especialmente para las empresas más pequeñas. A menudo, no están configurados de manera predeterminada en la forma más segura, a fin de proporcionar flexibilidad para que sus clientes apliquen sus propias políticas de seguridad. Por lo tanto, la presencia de cuentas o contraseñas predeterminadas, acceso excesivo o servicios innecesarios son comunes en las configuraciones predeterminadas. Estas condiciones pueden introducir vulnerabilidades que están bajo la responsabilidad de la empresa que utiliza el software, en lugar del proveedor de servicios. Esto también se extiende a la gestión y actualizaciones continuas, ya que algunas plataformas como servicio (PaaS) solo cubren el sistema operativo, por lo que el parcheo y actualización de las aplicaciones hospedadas quedan bajo la responsabilidad de la empresa.

Incluso después de desarrollar y aplicar una configuración inicial robusta, esta debe ser gestionada continuamente para evitar una degradación de la seguridad a medida que el software se actualiza o se parchea, se reportan nuevas vulnerabilidades de seguridad y se realizan ajustes de configuración para permitir la instalación de nuevo software o para soportar nuevos requerimientos operativos.

Procedimientos y herramientas

Existen muchas líneas base de seguridad disponibles para cada sistema. Las empresas deben comenzar con estos puntos de referencia de seguridad, guías o listas de verificación desarrollados, revisados y respaldados públicamente. Algunos recursos incluyen:

- Programa de Benchmarks de CIS®: <http://www.cisecurity.org/cis-benchmarks/>
- Repositorio del Programa Nacional de Listas de Verificación del NIST® (National Institute of Standards and Technology): <https://nvd.nist.gov/ncp/repository>

Las empresas deben complementar o ajustar estas líneas base para satisfacer las políticas de seguridad de la empresa y los requisitos regulatorios de la industria y del gobierno. Las desviaciones de las configuraciones estándar y su justificación deben documentarse para facilitar revisiones o auditorías futuras.

Para una empresa más grande o compleja, existirán múltiples configuraciones de línea base de seguridad según los requisitos de seguridad o la clasificación de los datos en el activo empresarial. A continuación se presenta un ejemplo de pasos para construir una imagen base segura:

- 1 Determinar la clasificación de riesgo de los datos manejados/almacenados en el activo empresarial (por ejemplo, alto, moderado, bajo riesgo).
- 2 Crear un script de configuración de seguridad que establezca los parámetros del sistema para cumplir con los requisitos de protección de los datos utilizados en el activo empresarial. Utilizar puntos de referencia como los descritos anteriormente en esta sección.
- 3 Instalar el software base del sistema operativo.
- 4 Aplicar los parches adecuados del sistema operativo y de seguridad.
- 5 Instalar los paquetes de software de aplicaciones, herramientas y utilidades adecuados.
- 6 Aplicar las actualizaciones apropiadas al software instalado en el paso 4.
- 7 Instalar scripts de personalización local en esta imagen.
- 8 Ejecutar el script de seguridad creado en el paso 2 para establecer el nivel de seguridad apropiado.
- 9 Ejecutar una herramienta que registre o puntúe la configuración del sistema de la imagen base.

- 10 Realizar una prueba de aseguramiento de calidad de seguridad.
- 11 Guardar esta imagen base en una ubicación segura.

Las herramientas de gestión de configuración comerciales y/o gratuitas, como la herramienta de evaluación de configuración de CIS (CIS-CAT®): <https://learn.cisecurity.org/cis-cat-lite>, pueden implementarse para medir la configuración de los sistemas operativos y aplicaciones de las máquinas gestionadas con el fin de detectar desviaciones con respecto a las configuraciones estándar de imagen. Las herramientas comerciales de gestión de configuración utilizan alguna combinación de un agente instalado en cada sistema gestionado o inspección sin agente mediante acceso remoto a cada activo empresarial utilizando credenciales de administrador. Adicionalmente, en ocasiones se utiliza un enfoque híbrido, en el que se inicia una sesión remota, se despliega un agente temporal o dinámico en el sistema objetivo para realizar el análisis, y luego se elimina dicho agente.

Salvaguardass

Salvuardas 4.1: Establecer y Mantener un Proceso de Configuración Segura

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y mantener un proceso documentado de configuración segura para los activos empresariales (dispositivos de usuario final, incluidos los portátiles y móviles, dispositivos no informáticos/IoT y servidores) y el software (sistemas operativos y aplicaciones). Revisar y actualizar la documentación anualmente o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvuardas 4.2: Establecer y Mantener un Proceso de Configuración Segura para la Infraestructura de Red

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y mantener un proceso documentado de configuración segura para los dispositivos de red. Revisar y actualizar la documentación anualmente o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvaviduas 4.3: Configurar el Bloqueo Automático de Sesión en los Activos Empresariales

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----	-----

Configurar el bloqueo automático de sesión en los activos empresariales después de un período definido de inactividad. Para los sistemas operativos de propósito general, el período no debe exceder los 15 minutos. Para los dispositivos móviles de usuario final, el período no debe exceder los 2 minutos.

Salvaviduas 4.4: Implementar y Gestionar un Cortafuegos en los Servidores

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----	-----

Implementar y gestionar un cortafuegos en los servidores, cuando sea compatible. Las implementaciones de ejemplo incluyen un cortafuegos virtual, un cortafuegos del sistema operativo o un agente de cortafuegos de terceros.

Salvaviduas 4.5: Implementar y Gestionar un Cortafuegos en los Dispositivos de Usuario Final

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----	-----

Implementar y gestionar un cortafuegos basado en host o una herramienta de filtrado de puertos en los dispositivos de usuario final, con una regla predeterminada de denegación que bloquee todo el tráfico excepto aquellos servicios y puertos que estén explícitamente permitidos..

Salvaviduas 4.6: Gestionar de Forma Segura los Activos Empresariales y el Software

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----	-----

Gestionar de forma segura los activos empresariales y el software. Las implementaciones de ejemplo incluyen la gestión de configuraciones mediante Infraestructura como Código (IaC) con control de versiones y el acceso a interfaces administrativas a través de protocolos de red seguros, como Secure Shell (SSH) y Hypertext Transfer Protocol Secure (HTTPS). No se deben utilizar protocolos de gestión inseguros, como Telnet (Teletype Network) y HTTP, a menos que sea operacionalmente esencial.

Salvaviduas 4.7: Gestionar las Cuentas Predeterminadas en los Activos Empresariales y el Software

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Gestionar las cuentas predeterminadas en los activos empresariales y el software, como root, administrador y otras cuentas preconfiguradas por el proveedor. Las implementaciones de ejemplo pueden incluir: deshabilitar las cuentas predeterminadas o hacer que no se puedan utilizar.

Salvaviduas 4.8: Desinstalar o Deshabilitar Servicios Innecesarios en los Activos Empresariales y el Software

Tipo de Activo:	Documentación	Función de Seguridad:	Proteger	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Desinstalar o deshabilitar servicios innecesarios en los activos empresariales y el software, como un servicio de uso compartido de archivos no utilizado, un módulo de aplicación web o una función de servicio.

Salvaviduas 4.9: Configurar Servidores DNS Confiables en los Activos Empresariales

Tipo de Activo:	Documentación	Función de Seguridad:	Proteger	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Configurar servidores DNS confiables en la infraestructura de red. Las implementaciones de ejemplo incluyen configurar dispositivos de red para utilizar servidores DNS controlados por la empresa y/o servidores DNS externos de buena reputación.

Salvaviduas 4.10: Hacer Cumplir el Bloqueo Automático de Dispositivos en Dispositivos Portátiles de Usuario Final

Tipo de Activo:	Documentación	Función de Seguridad:	Proteger	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Hacer cumplir el bloqueo automático de dispositivos tras superar un umbral predefinido de intentos fallidos de autenticación local en dispositivos portátiles de usuario final, cuando sea compatible. Para laptops, no se deben permitir más de 20 intentos fallidos de autenticación; para tabletas y teléfonos inteligentes, no más de 10 intentos fallidos. Las implementaciones de ejemplo incluyen Microsoft® InTune Device Lock y el parámetro de configuración Apple® maxFailedAttempts.

Salvaguardas 4.11: Hacer Cumplir la Capacidad de Borrado Remoto en Dispositivos Portátiles de Usuario Final

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Borrar remotamente los datos empresariales de los dispositivos portátiles de usuario final propiedad de la empresa cuando se considere apropiado, como en caso de dispositivos perdidos o robados, o cuando una persona ya no preste servicios a la empresa.

Salvaguardas 4.12: Separar los Espacios de Trabajo Empresariales en Dispositivos Móviles de Usuario Final

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG3
-----------------	-------	-----------------------	----------	-----

Asegurar que se utilicen espacios de trabajo empresariales separados en los dispositivos móviles de usuario final, cuando sea compatible. Las implementaciones de ejemplo incluyen el uso de un Perfil de Configuración de Apple® o un Perfil de Trabajo de Android™ para separar las aplicaciones y los datos empresariales de las aplicaciones y los datos personales.

CONTROL 5

Gestión de Cuentas

Salvaguardass: 6	IG1: 4/6	IG2: IG2	IG3: 6/6
------------------	----------	----------	----------

Descripción general

Utilizar procesos y herramientas para asignar y gestionar la autorización de credenciales para cuentas de usuario, incluidas cuentas de administrador, así como cuentas de servicio, para activos empresariales y software.

¿Por qué es crítico este Control?

Es más fácil para un actor de amenazas externo o interno obtener acceso no autorizado a los activos o datos de una empresa utilizando credenciales válidas de usuario que mediante la “piratería” del entorno. Existen muchas formas de obtener acceso de forma encubierta a cuentas de usuario, entre ellas: contraseñas débiles, cuentas aún activas después de que un usuario haya dejado la empresa, cuentas de prueba inactivas o rezagadas, cuentas compartidas que no se han cambiado en meses o años, cuentas de servicio incrustadas en aplicaciones o scripts, un usuario que tiene la misma contraseña que usa para una cuenta en línea que ha sido comprometida (en una filtración pública de contraseñas), ingeniería social para que el usuario revele su contraseña, o el uso de malware para capturar contraseñas o tokens en la memoria o a través de la red.

Las cuentas administrativas, o con privilegios elevados, son un objetivo particular, ya que permiten a los atacantes agregar otras cuentas o realizar cambios en los activos que podrían hacerlos más vulnerables a otros ataques. Las cuentas de servicio también son sensibles, ya que a menudo son compartidas entre equipos, internos y externos a la empresa, y en ocasiones no se tiene conocimiento de ellas hasta que se revelan en auditorías estándar de gestión de cuentas.

Por último, el registro y monitoreo de cuentas es un componente crítico de las operaciones de seguridad. Si bien el registro y monitoreo de cuentas se abordan en el Control CIS 8 (Gestión de Registros de Auditoría), son importantes en el desarrollo de un programa integral de Gestión de Identidad y Acceso (IAM).

Procedimientos y herramientas

Las cuentas deben ser rastreadas; cualquier cuenta inactiva debe ser deshabilitada y, eventualmente, eliminada del sistema. Deben realizarse auditorías periódicas para asegurar que todas las cuentas activas estén asociadas a usuarios autorizados del activo empresarial. Se debe verificar si se han añadido cuentas nuevas desde la revisión anterior, especialmente cuentas de administrador y cuentas de servicio. Se debe prestar especial atención a la identificación y seguimiento de cuentas administrativas o con altos privilegios y cuentas de servicio.

Los usuarios con acceso de administrador u otros privilegios deben contar con cuentas separadas para esas tareas de mayor autoridad. Estas cuentas solo deben utilizarse al realizar dichas tareas o al acceder a datos especialmente sensibles, con el fin de reducir el riesgo en caso de que su cuenta de usuario normal sea comprometida. Para los usuarios con múltiples cuentas, su cuenta base de usuario, utilizada en el día a día para tareas no administrativas, no debe tener privilegios elevados.

El inicio de sesión único (SSO) es conveniente y seguro cuando una empresa cuenta con muchas aplicaciones, incluidas aplicaciones en la nube, lo que ayuda a reducir la cantidad de contraseñas que un usuario debe gestionar. Se recomienda que los usuarios utilicen aplicaciones de administración de contraseñas para almacenar sus contraseñas de forma segura y se les debe instruir que no las guarden en hojas de cálculo o archivos de texto en sus computadoras. Se recomienda el uso de autenticación multifactor (MFA) para el acceso remoto.

También se debe cerrar automáticamente la sesión de los usuarios después de un período de inactividad, y se les debe capacitar para bloquear su pantalla al abandonar su dispositivo, con el fin de minimizar la posibilidad de que alguien con proximidad física al usuario acceda a su sistema, aplicaciones o datos.

- Un recurso excelente son las Directrices de Identidad Digital del NIST®: <https://pages.nist.gov/800-63-3/>
- Para orientación sobre la creación y uso de contraseñas, consulte la Guía de Políticas de Contraseñas de CIS: <https://www.cisecurity.org/white-papers/cis-password-policy-guide>

Salvaguardass

Salvaguardas 5.1: Establecer y Mantener un Inventario de Cuentas

Tipo de Activo:	Usuarios	Función de Seguridad:	Identificar	IG1	IG2	IG3
-----------------	----------	-----------------------	-------------	-----	-----	-----

Establecer y mantener un inventario de todas las cuentas gestionadas en la empresa. El inventario debe incluir, como mínimo, cuentas de usuario, de administrador y de servicio. El inventario, como mínimo, debe contener el nombre de la persona, nombre de usuario, fechas de inicio/finalización y departamento. Validar que todas las cuentas activas estén autorizadas, en un cronograma recurrente al menos trimestral, o con mayor frecuencia.

Salvaguardas 5.2: Usar Contraseñas Únicas

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Usar contraseñas únicas para todos los activos empresariales. La implementación recomendada incluye, como mínimo, una contraseña de 8 caracteres para cuentas que utilizan Autenticación Multifactor (MFA), y una contraseña de 14 caracteres para cuentas que no utilizan MFA.

Salvavidas 5.3: Deshabilitar Cuentas Inactivas

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Eliminar o deshabilitar cualquier cuenta inactiva después de un período de 45 días de inactividad, cuando sea compatible.

Salvavidas 5.4: Restringir los Privilegios de Administrador a Cuentas de Administrador Dedicadas

Tipo de Activo:	Usuarios	Función de Seguridad::	Proteger	IG1	IG2	IG3
-----------------	----------	------------------------	----------	-----	-----	-----

Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user’s primary, non-privileged account.

Salvavidas 5.5: Establecer y Mantener un Inventario de Cuentas de Servicio

Tipo de Activo:	Usuarios	Función de Seguridad:	Identificar	IG2	IG3
-----------------	----------	-----------------------	-------------	-----	-----

Establecer y mantener un inventario de cuentas de servicio. El inventario debe contener, como mínimo, el departamento responsable, la fecha de revisión y el propósito. Realizar revisiones de cuentas de servicio para validar que todas las cuentas activas estén autorizadas, en un cronograma recurrente al menos trimestral, o con mayor frecuencia.

Salvavidas 5.6: Centralizar la Gestión de Cuentas

Tipo de Activo:	Usuarios	Función de Seguridad:	Gobernar	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Centralizar la gestión de cuentas mediante un directorio o servicio de identidad.

CONTROL 6

Gestión de Control de Acceso

Salvaguardass: 8	IG1: 5/8	IG2: 7/8	IG3: 8/8
------------------	----------	----------	----------

Descripción general

Utilizar procesos y herramientas para crear, asignar, gestionar y revocar credenciales de acceso y privilegios para cuentas de usuario, administrador y de servicio para activos empresariales y software.

¿Por qué es crítico este Control??

Mientras que el Control CIS 5 trata específicamente de la gestión de cuentas, el Control CIS 6 se enfoca en gestionar a qué tienen acceso estas cuentas, asegurando que los usuarios solo tengan acceso a los datos o activos empresariales apropiados para su función, y que exista una autenticación sólida para datos o funciones empresariales críticas o sensibles. Las cuentas deben tener únicamente la autorización mínima necesaria para su función. Desarrollar derechos de acceso consistentes para cada rol y asignar roles a los usuarios es una buena práctica. También es importante desarrollar un programa completo para la provisión y revocación de acceso. Centralizar esta función es lo ideal.

Algunas actividades de los usuarios representan un mayor riesgo para la empresa, ya sea porque se accede desde redes no confiables, o porque se ejecutan funciones administrativas que permiten agregar, cambiar o eliminar otras cuentas, o realizar cambios en la configuración de sistemas operativos o aplicaciones que pueden volverlos menos seguros. Esto también refuerza la importancia del uso de MFA (Autenticación Multifactor) y herramientas de Gestión de Acceso con Privilegios (PAM, por sus siglas en inglés).

Algunos usuarios tienen acceso a activos o datos empresariales que no necesitan para su función; esto puede deberse a un proceso inmaduro que otorga acceso completo a todos los usuarios, o a accesos rezagados a medida que los usuarios cambian de roles dentro de la empresa con el tiempo. Los privilegios de administrador local en los portátiles de los usuarios también son un problema, ya que cualquier código malicioso instalado o descargado por el usuario puede tener un mayor impacto en el activo empresarial si se ejecuta con privilegios de administrador. El acceso de cuentas de usuario, administrador y de servicio debe basarse en el rol empresarial y la necesidad.

Procedimientos y herramientas

Debe existir un proceso mediante el cual se otorguen y revoquen privilegios para las cuentas de usuario. Este proceso, idealmente, debe basarse en el rol y la necesidad dentro de la empresa mediante control de acceso basado en roles. El control de acceso basado en roles es una técnica para definir y gestionar los requisitos de acceso de cada cuenta en función de: necesidad de conocimiento, mínimo privilegio, requisitos de privacidad y/o separación de funciones. Existen herramientas tecnológicas que ayudan a gestionar este proceso. Sin embargo, puede haber accesos más granulares o temporales según las circunstancias.

El uso de MFA debe ser universal para todas las cuentas privilegiadas o de administrador. Existen muchas herramientas con aplicaciones para teléfonos inteligentes que realizan esta función y son fáciles de implementar. Utilizar la función de generador de números es más seguro que simplemente enviar un mensaje de texto (SMS) con un código de un solo uso o enviar una alerta tipo “push” para que el usuario la acepte. Sin embargo, ninguno de estos métodos se recomienda para cuentas privilegiadas. Las herramientas PAM están disponibles para el control de cuentas privilegiadas, y proporcionan una contraseña de un solo uso que debe ser solicitada para cada utilización. Para mayor seguridad en la administración de sistemas, se recomienda el uso de “jump-boxes” o conexiones de terminal fuera de banda.

Una revocación de cuentas integral es importante. Muchas empresas cuentan con procesos consistentes y repetibles para eliminar accesos cuando los empleados dejan la organización. Sin embargo, ese proceso no siempre es consistente para contratistas, y debe incluirse dentro del proceso estándar de revocación de accesos.

Las empresas también deben inventariar y rastrear las cuentas de servicio, ya que un error común es dejar tokens o contraseñas en texto claro en el código, y publicarlos en repositorios de código en la nube de acceso público.

Las cuentas con privilegios elevados no deben usarse para actividades cotidianas, como navegación web o lectura de correos electrónicos. Los administradores deben contar con cuentas separadas que no tengan privilegios elevados para su uso diario en oficina, y solo iniciar sesión con cuentas de administrador al realizar funciones administrativas que requieran ese nivel de autorización. El personal de seguridad debe recopilar periódicamente una lista de procesos en ejecución para determinar si algún navegador o lector de correo está siendo ejecutado con privilegios elevados.

- Un recurso excelente son las Directrices de Identidad Digital del NIST®: <https://pages.nist.gov/800-63-3/>

Rasguardos

Salvaguardas 6.1: Establecer un Proceso para Otorgar Accesos

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y seguir un proceso documentado, preferentemente automatizado, para otorgar acceso a los activos empresariales cuando se contrata a un nuevo empleado o cuando un usuario cambia de rol.

Salvaguardas 6.2: Establecer un Proceso para Revocar Accesos

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y seguir un proceso, preferentemente automatizado, para revocar el acceso a los activos empresariales, deshabilitando inmediatamente las cuentas tras la terminación del vínculo, la revocación de derechos o el cambio de rol de un usuario. La deshabilitación de cuentas, en lugar de su eliminación, puede ser necesaria para preservar los registros de auditoría.

Salvaguardas 6.3: Requerir MFA para Aplicaciones Expuestas Externamente

Tipo de Activo:	Usuarios	Función de Seguridad::	Proteger	IG1	IG2	IG3
-----------------	----------	------------------------	----------	-----	-----	-----

Requerir que todas las aplicaciones empresariales o de terceros expuestas externamente hagan cumplir el uso de MFA, donde sea compatible. La implementación de MFA mediante un servicio de directorio o un proveedor de SSO es una forma satisfactoria de cumplir esta Salvaguarda.

Salvaguardas 6.4: Requerir MFA para el Acceso Remoto a la Red

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Requerir MFA para el acceso remoto a la red.

Salvaguardas 6.5: Requerir MFA para el Acceso Administrativo

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Requerir MFA para todas las cuentas con acceso administrativo, donde sea compatible, en todos los activos empresariales, ya sea que se gestionen localmente o a través de un proveedor de servicios.

Salvaguardas 6.6: Establecer y Mantener un Inventario de Sistemas de Autenticación y Autorización

Tipo de Activo:	Software	Función de Seguridad:	Identificar	IG2	IG3
-----------------	----------	-----------------------	-------------	-----	-----

Establecer y mantener un inventario de los sistemas de autenticación y autorización de la empresa, incluidos aquellos alojados localmente o en un proveedor de servicios remoto. Revisar y actualizar el inventario, como mínimo, una vez al año, o con mayor frecuencia.

Salvaguardas 6.7: Centralizar el Control de Acceso

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Centralizar el control de acceso para todos los activos empresariales a través de un servicio de directorio o un proveedor de SSO, donde sea compatible.

Salvaguardas 6.8: Definir y Mantener el Control de Acceso Basado en Roles

Tipo de Activo:	Usuarios	Función de Seguridad:	Gobernar	IG3
-----------------	----------	-----------------------	----------	-----

Definir y mantener el control de acceso basado en roles, determinando y documentando los derechos de acceso necesarios para cada rol dentro de la empresa con el fin de cumplir exitosamente con sus funciones asignadas. Realizar revisiones del control de acceso a los activos empresariales para validar que todos los privilegios estén autorizados, en un cronograma recurrente al menos una vez al año, o con mayor frecuencia.

CONTROL 7

Gestión Continua de Vulnerabilidades

Salvaguardass: 7	IG1: 4/7	IG2: IG2	IG3: 7/7
------------------	----------	----------	----------

Descripción general

Desarrollar un plan para evaluar y rastrear continuamente las vulnerabilidades en todos los activos empresariales dentro de la infraestructura de la organización, con el fin de remediarlas y minimizar la ventana de oportunidad para los atacantes. Monitorear fuentes públicas y privadas de la industria para obtener nueva información sobre amenazas y vulnerabilidades.

¿Por qué es crítico este Control?

Los defensores cibernéticos enfrentan constantemente desafíos por parte de atacantes que buscan vulnerabilidades dentro de su infraestructura para explotarlas y obtener acceso. Los defensores deben contar con información oportuna sobre amenazas, como actualizaciones de software, parches, avisos de seguridad, boletines de amenazas, etc., y deben revisar regularmente su entorno para identificar estas vulnerabilidades antes que los atacantes. Comprender y gestionar vulnerabilidades es una actividad continua que requiere enfoque, tiempo, atención y recursos.

Los atacantes tienen acceso a la misma información y, a menudo, pueden aprovechar las vulnerabilidades más rápido de lo que una empresa puede remediarlas. Mientras exista un lapso de tiempo entre que se conoce una vulnerabilidad y se aplica un parche, los defensores pueden priorizar cuáles vulnerabilidades tienen mayor impacto en la empresa o es más probable que sean explotadas primero por su facilidad de uso. Por ejemplo, cuando los investigadores o la comunidad reportan nuevas vulnerabilidades, los proveedores deben desarrollar y desplegar parches, indicadores de compromiso (IOC) y actualizaciones. Los defensores deben evaluar el riesgo de la nueva vulnerabilidad para la empresa, realizar pruebas de regresión y aplicar el parche.

Este proceso nunca es perfecto. Los atacantes podrían estar utilizando una vulnerabilidad que aún no es conocida por la comunidad de seguridad. Podrían haber desarrollado un exploit para esta vulnerabilidad, lo que se conoce como exploit de “día cero” (zero-day). Una vez que la vulnerabilidad se da a conocer en la comunidad, se inicia el proceso mencionado anteriormente. Por lo tanto, los defensores deben tener presente que podría existir un exploit activo cuando la vulnerabilidad se difunde ampliamente. A veces, las vulnerabilidades son conocidas dentro de una comunidad cerrada (por ejemplo, el proveedor aún está desarrollando una solución) durante semanas, meses o incluso años antes de su divulgación pública. Los defensores deben ser conscientes de que siempre podrían existir vulnerabilidades que no pueden remediar, por lo que deben aplicar otros controles para mitigarlas.

Las empresas que no evalúan su infraestructura en busca de vulnerabilidades ni abordan proactivamente los fallos descubiertos enfrentan una probabilidad significativa de que sus activos empresariales sean comprometidos. Los defensores enfrentan desafíos particulares para escalar la remediación en toda la empresa y priorizar acciones con prioridades en conflicto, sin afectar el negocio o la misión de la organización.

Procedimientos y herramientas

Existe una gran cantidad de herramientas de escaneo de vulnerabilidades disponibles para evaluar la configuración de seguridad de los activos empresariales. Algunas empresas también han encontrado eficaces los servicios comerciales que utilizan dispositivos de escaneo gestionados de forma remota. Para ayudar a estandarizar las definiciones de vulnerabilidades descubiertas en toda la empresa, es preferible usar herramientas de escaneo que asignen las vulnerabilidades a uno o más de los siguientes esquemas y lenguajes de clasificación de vulnerabilidades, configuraciones y plataformas reconocidos por la industria: Common Vulnerabilities and Exposures (CVE®), Common Configuration Enumeration (CCE), Open Vulnerability and Assessment Language (OVAL®), Common Platform Enumeration (CPE), Common Vulnerability Scoring System (CVSS) y/o Extensible Configuration Checklist Description Format (XCCDF).

- Más información sobre SCAP se encuentra disponible en: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-126r3.pdf>

La frecuencia de las actividades de escaneo debe aumentar a medida que aumenta la diversidad de los activos de una empresa, para tener en cuenta los distintos ciclos de parches de cada proveedor. Las herramientas avanzadas de escaneo de vulnerabilidades pueden configurarse con credenciales de usuario para autenticarse en los activos empresariales y realizar evaluaciones más completas. Estos se denominan “escaneos autenticados”.

Además de las herramientas de escaneo que detectan vulnerabilidades y errores de configuración en toda la red, existen diversas herramientas gratuitas y comerciales que pueden evaluar la configuración y los ajustes de seguridad de los activos empresariales. Estas herramientas pueden proporcionar información detallada sobre cambios no autorizados en la configuración o la introducción inadvertida de debilidades de seguridad por parte de los administradores.

Las empresas eficaces vinculan sus escáneres de vulnerabilidades con sistemas de gestión de tickets que rastrean y reportan el progreso en la corrección de vulnerabilidades. Esto puede ayudar a resaltar vulnerabilidades críticas no mitigadas ante la alta dirección para garantizar su resolución. Las empresas también pueden rastrear cuánto tiempo les tomó remediar una vulnerabilidad después de haber sido identificada o de haberse emitido un parche. Esto puede apoyar los requisitos de cumplimiento internos o del sector. Algunas organizaciones maduras revisan estos informes en reuniones de comités directivos de seguridad informática, que reúnen a líderes de TI y del negocio para priorizar los esfuerzos de remediación según el impacto empresarial.

Al seleccionar qué vulnerabilidades corregir o qué parches aplicar, una empresa debe complementar el Sistema de Puntuación de Vulnerabilidades Comunes (CVSS) del Forum of Incident Response and Security Teams, Inc. (FIRST) con datos sobre la probabilidad de que un actor de amenazas utilice una vulnerabilidad, o el impacto potencial de un exploit para la empresa. La información sobre la probabilidad de explotación también debe actualizarse periódicamente con base en la información de amenazas más reciente. Por ejemplo, la publicación de un nuevo exploit o nueva inteligencia relacionada con la explotación de una vulnerabilidad debe cambiar la prioridad con la que esta se considera para su parcheo. Existen diversos sistemas comerciales disponibles para que una empresa automatice y mantenga este proceso de forma escalable.

Las herramientas de escaneo de vulnerabilidades más eficaces comparan los resultados del escaneo actual con los anteriores para determinar cómo han cambiado las vulnerabilidades en el entorno con el tiempo. El personal de seguridad utiliza estas funciones para realizar análisis de tendencias de vulnerabilidades mes a mes.

Finalmente, debe existir un proceso de aseguramiento de calidad para verificar que las actualizaciones de configuración o los parches se implementen correctamente y en todos los activos empresariales relevantes.

Salvaguardass

Salvuardas 7.1: Establecer y Mantener un Proceso de Gestión de Vulnerabilidades

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y mantener un proceso documentado de gestión de vulnerabilidades para los activos empresariales. Revisar y actualizar la documentación anualmente, o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvuardas 7.2: Establecer y Mantener un Proceso de Remediación

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y mantener una estrategia de remediación basada en riesgos, documentada en un proceso de remediación, con revisiones mensuales o más frecuentes.

Salvuardas 7.3: Realizar la Gestión Automatizada de Parches del Sistema Operativo

Tipo de Activo:	Software	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Realizar actualizaciones del sistema operativo en los activos empresariales mediante la gestión automatizada de parches de forma mensual o más frecuente.

Salvaguardas 7.4: Realizar la Gestión Automatizada de Parches de Aplicaciones

Tipo de Activo:	Software	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Realizar actualizaciones de aplicaciones en los activos empresariales mediante la gestión automatizada de parches de forma mensual o más frecuente.

Salvaguardas 7.5: Realizar Escaneos Automatizados de Vulnerabilidades en Activos Empresariales Internos

Tipo de Activo:	Software	Función de Seguridad:	Identificar	IG2	IG3
-----------------	----------	-----------------------	-------------	-----	-----

Realizar escaneos automatizados de vulnerabilidades en los activos empresariales internos de forma trimestral o más frecuente. Realizar tanto escaneos autenticados como no autenticados.

Salvaguardas 7.6: Realizar Escaneos Automatizados de Vulnerabilidades en Activos Empresariales Expuestos Externamente

Tipo de Activo:	Software	Función de Seguridad:	Identificar	IG2	IG3
-----------------	----------	-----------------------	-------------	-----	-----

Realizar escaneos automatizados de vulnerabilidades en los activos empresariales expuestos externamente. Realizar escaneos de forma mensual o más frecuente.

Salvaguardas 7.7: Remediar las Vulnerabilidades Detectadas

Tipo de Activo:	Software	Función de Seguridad:	Responder	IG2	IG3
-----------------	----------	-----------------------	-----------	-----	-----

Remediar las vulnerabilidades detectadas en el software mediante procesos y herramientas de forma mensual o más frecuente, de acuerdo con el proceso de remediación.

CONTROL 8

Gestión de Registros de Auditoría

Salvaguardass: 12	IG1: 3/12	IG2: 11/12	IG3: 12/12
-------------------	-----------	------------	------------

Descripción general

Recopilar, alertar, revisar y conservar los registros de auditoría de eventos que puedan ayudar a detectar, comprender o recuperarse de un ataque.

¿Por qué es crítico este Control?

La recopilación y el análisis de registros es fundamental para la capacidad de una empresa de detectar rápidamente actividades maliciosas. A veces, los registros de auditoría son la única evidencia de un ataque exitoso. Los atacantes saben que muchas organizaciones mantienen registros de auditoría por razones de cumplimiento, pero rara vez los analizan. Los atacantes aprovechan este conocimiento para ocultar su ubicación, software malicioso y actividades en los equipos de las víctimas. Debido a procesos de análisis de registros deficientes o inexistentes, los atacantes a veces controlan equipos comprometidos durante meses o incluso años sin que nadie en la organización objetivo lo sepa.

Existen dos tipos de registros que generalmente se tratan y configuran de forma independiente: registros del sistema y registros de auditoría. Los registros del sistema suelen proporcionar eventos a nivel del sistema que muestran el inicio/fin de procesos, fallos del sistema, etc. Estos son nativos de los sistemas y requieren menos configuración para activarse. Los registros de auditoría, por lo general, incluyen eventos a nivel de usuario—cuándo un usuario inició sesión, accedió a un archivo, etc.—y requieren más planificación y esfuerzo para su implementación.

Los registros también son fundamentales para la respuesta ante incidentes. Una vez que se ha detectado un ataque, el análisis de registros puede ayudar a las organizaciones a comprender el alcance del ataque. Registros completos pueden mostrar, por ejemplo, cuándo y cómo ocurrió el ataque, qué información fue accedida y si se produjo exfiltración de datos. La conservación de los registros también es fundamental en caso de que se requiera una investigación posterior o si un ataque permaneció sin ser detectado durante un largo período.

Procedures and tools

La mayoría de los activos empresariales y el software ofrecen capacidades de registro. Dichos registros deben estar activados, con los datos enviados a servidores centralizados de registros. Los firewalls, proxies y sistemas de acceso remoto (como redes privadas virtuales (VPN), acceso telefónico, etc.) deben estar configurados para un registro detallado cuando sea beneficioso. La retención de los registros también es importante en caso de que se requiera una investigación de incidentes. Además, todos los activos empresariales deben estar configurados para generar registros de control de acceso cuando un usuario intente acceder a recursos sin los privilegios adecuados. Para evaluar si se está realizando este registro, la empresa debe revisar periódicamente sus registros y compararlos con el inventario de activos empresariales recopilado como parte del Control CIS 1, a fin de garantizar que cada activo gestionado conectado activamente a la red esté generando registros de manera periódica.

Salvaguardass

Salvuardas 8.1: Establecer y Mantener un Proceso de Gestión de Registros de Auditoría

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y mantener un proceso documentado de gestión de registros de auditoría que defina los requisitos de registro de la empresa. Como mínimo, debe abordar la recopilación, revisión y retención de los registros de auditoría de los activos empresariales. Revisar y actualizar la documentación anualmente o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvuardas 8.2: Recopilar Registros de Auditoría

Tipo de Activo:	Datos	Función de Seguridad:	Detectar	IG1	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----	-----

Recopilar los registros de auditoría. Asegurarse de que el registro, según el proceso de gestión de registros de auditoría de la empresa, esté habilitado en todos los activos empresariales.

Salvuardas 8.3: Garantizar un Almacenamiento Adecuado para los Registros de Auditoría

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----	-----

Garantizar que los destinos de registro mantengan una capacidad de almacenamiento adecuada para cumplir con el proceso de gestión de registros de auditoría de la empresa.

Salvavidas 8.4: Estandarizar la Sincronización de Tiempo

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Estandarizar la sincronización de tiempo. Configurar al menos dos fuentes de tiempo sincronizadas en todos los activos empresariales, donde sea compatible.

Salvavidas 8.5: Recopilar Registros de Auditoría Detallados

Tipo de Activo:	Datos	Función de Seguridad:	Detectar	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Configurar el registro detallado de auditoría para los activos empresariales que contienen datos sensibles. Incluir fuente del evento, fecha, nombre de usuario, marca de tiempo, direcciones de origen, direcciones de destino y otros elementos útiles que puedan ayudar en una investigación forense.

Salvavidas 8.6: Recopilar Registros de Auditoría de Consultas DNS

Tipo de Activo:	Datos	Función de Seguridad:	Detectar	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Recopilar registros de auditoría de consultas DNS en los activos empresariales, cuando sea apropiado y compatible.

Salvavidas 8.7: Recopilar Registros de Auditoría de Solicitudes de URL

Tipo de Activo:	Datos	Función de Seguridad:	Detectar	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Recopilar registros de auditoría de solicitudes de URL en los activos empresariales, cuando sea apropiado y compatible.

Salvavidas 8.8: Recopilar Registros de Auditoría de Línea de Comandos

Tipo de Activo:	Datos	Función de Seguridad:	Detectar	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Recopilar registros de auditoría de línea de comandos. Ejemplos de implementación incluyen la recopilación de registros de auditoría de PowerShell®, BASH™ y terminales administrativas remotas.

Salvaviduas 8.9: Centralizar los Registros de Auditoría

Tipo de Activo:	Datos	Función de Seguridad:	Detectar	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Centralizar, en la medida de lo posible, la recopilación y retención de los registros de auditoría en todos los activos empresariales de acuerdo con el proceso documentado de gestión de registros de auditoría. Ejemplos de implementación incluyen principalmente el uso de una herramienta SIEM para centralizar múltiples fuentes de registros.

Salvaviduas 8.10: Conservar los Registros de Auditoría

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Conservar los registros de auditoría en todos los activos empresariales por un mínimo de 90 días.

Salvaviduas 8.11: Realizar Revisiones de los Registros de Auditoría

Tipo de Activo:	Datos	Función de Seguridad:	Detectar	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----

Realizar revisiones de los registros de auditoría para detectar anomalías o eventos anormales que puedan indicar una amenaza potencial. Realizar estas revisiones semanalmente o con mayor frecuencia.

Salvaviduas 8.12: Recopilar Registros del Proveedor de Servicios

Tipo de Activo:	Datos	Función de Seguridad:	Detectar	IG3
-----------------	-------	-----------------------	----------	-----

Recopilar registros del proveedor de servicios, cuando sea compatible. Ejemplos de implementación incluyen la recopilación de eventos de autenticación y autorización, eventos de creación y eliminación de datos, y eventos de gestión de usuarios.

CONTROL 9

Protección del Correo Electrónico y Navegadores Web

Salvaguardass: 7	IG1: 2/7	IG2: 6/7	IG3: 7/7
------------------	----------	----------	----------

Descripción general

Mejorar las protecciones y detecciones contra amenazas provenientes de vectores de correo electrónico y web, ya que representan oportunidades para que los atacantes manipulen el comportamiento humano mediante interacción directa.

¿Por qué es crítico este Control?

Los navegadores web y los clientes de correo electrónico son puntos de entrada muy comunes para los atacantes debido a su interacción directa con los usuarios dentro de una empresa. El contenido puede ser diseñado para atraer o suplantar a los usuarios y lograr que revelen credenciales, proporcionen datos sensibles o abran un canal que permita a los atacantes obtener acceso, aumentando así el riesgo para la empresa. Dado que el correo electrónico y la web son los principales medios mediante los cuales los usuarios interactúan con entornos y usuarios externos y no confiables, se convierten en objetivos clave tanto para código malicioso como para técnicas de ingeniería social. Además, a medida que las empresas migran a soluciones de correo electrónico basadas en la web o al acceso móvil, los usuarios ya no utilizan clientes de correo electrónico tradicionales con funciones completas, los cuales ofrecían controles de seguridad integrados como cifrado de conexión, autenticación robusta y botones para reportar suplantación de identidad (phishing).

Procedimientos y herramientas

Navegador web

Los ciberdelincuentes pueden explotar los navegadores web de múltiples maneras. Si tienen acceso a exploits de navegadores vulnerables, pueden crear páginas web maliciosas que exploten esas vulnerabilidades al ser visitadas con un navegador inseguro o sin parches. Alternativamente, pueden intentar dirigirse a una variedad de complementos de terceros comunes del navegador web que podrían permitirles integrarse con el navegador o incluso directamente con el sistema operativo o una aplicación. Estos complementos, al igual que cualquier otro software dentro de un entorno, deben ser revisados para detectar vulnerabilidades, mantenerse actualizados con los últimos parches o versiones y estar controlados. Muchos provienen de fuentes no confiables, e incluso algunos están diseñados con fines maliciosos. Por lo tanto, es preferible prevenir que los usuarios instalen, intencionadamente o no, malware oculto en estos complementos, extensiones y añadidos. Actualizaciones simples en la configuración del navegador pueden dificultar significativamente la instalación de malware, al limitar la capacidad de instalar complementos/extensiones y evitar la ejecución automática de ciertos tipos de contenido.

La mayoría de los navegadores populares utilizan bases de datos de sitios de phishing y/o malware para proteger contra amenazas comunes. Una buena práctica es activar estos filtros de contenido y habilitar los bloqueadores de ventanas emergentes. Las ventanas emergentes no solo son molestas; también pueden contener malware incrustado o atraer a los usuarios a hacer clic en enlaces utilizando trucos de ingeniería social. Para reforzar el bloqueo de dominios maliciosos conocidos, también se recomienda suscribirse a servicios de filtrado DNS para bloquear intentos de acceso a estos sitios a nivel de red.

Correo electrónico

El correo electrónico representa una de las formas más interactivas en que las personas trabajan con los activos empresariales; capacitar y fomentar el comportamiento correcto es tan importante como las configuraciones técnicas. El correo electrónico es el vector de amenaza más común contra las empresas mediante tácticas como el phishing y el compromiso de correo electrónico empresarial (BEC).

Utilizar una herramienta de filtrado de spam y escaneo de malware en la puerta de enlace del correo electrónico reduce la cantidad de correos maliciosos y archivos adjuntos que ingresan a la red de la empresa. Implementar Domain-based Message Authentication, Reporting, and Conformance (DMARC) ayuda a reducir actividades de spam y phishing. Instalar una herramienta de cifrado para asegurar los correos y comunicaciones agrega una capa adicional de seguridad para el usuario y la red. Además del bloqueo basado en el remitente, también es útil permitir únicamente ciertos tipos de archivos que los usuarios necesiten para su trabajo. Esto requerirá coordinación con diferentes unidades de negocio para entender qué tipos de archivos reciben por correo electrónico y asegurar que no se interrumpan sus procesos.

Dado que las técnicas de phishing por correo electrónico evolucionan constantemente para evadir las reglas de los filtros de spam, es importante capacitar a los usuarios sobre cómo identificar intentos de phishing y notificar al equipo de Seguridad Informática cuando detecten uno. Existen muchas plataformas que realizan pruebas de phishing a los usuarios para ayudar a educarlos sobre diferentes ejemplos y monitorear su progreso a lo largo del tiempo. Compartir este conocimiento con los equipos de Seguridad Informática ayuda a mejorar las capacidades de protección y detección frente a amenazas basadas en correo electrónico.

Salvaguardass

Salvaguardas 9.1: Garantizar el Uso Exclusivo de Navegadores y Clientes de Correo Totalmente Compatibles

Tipo de Activo:	Software	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Garantizar que solo se permita la ejecución de navegadores y clientes de correo electrónico totalmente compatibles en la empresa, utilizando únicamente la versión más reciente proporcionada por el proveedor.

Salvaguardas 9.2: Utilizar Servicios de Filtrado DNS

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----	-----

Utilizar servicios de filtrado DNS en todos los dispositivos de usuario final, incluidos los activos remotos y locales, para bloquear el acceso a dominios maliciosos conocidos.

Salvaguardas 9.3: Mantener y Hacer Cumplir Filtros de URL Basados en la Red

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Hacer cumplir y actualizar los filtros de URL basados en la red para limitar que un activo empresarial se conecte a sitios web potencialmente maliciosos o no aprobados. Ejemplos de implementación incluyen filtrado por categoría, filtrado basado en reputación o mediante el uso de listas de bloqueo. Aplicar los filtros a todos los activos empresariales.

Salvaguardas 9.4: Restringir Extensiones de Navegador y Cliente de Correo Electrónico Innecesarias o No Autorizadas

Tipo de Activo:	Software	Función de Seguridad:	Proteger	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Restringir, ya sea desinstalando o deshabilitando, cualquier complemento, extensión o aplicación adicional de navegador o cliente de correo electrónico que no esté autorizada o sea innecesaria.

Salvaguardas 9.5: Implementar DMARC

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Para reducir la probabilidad de correos electrónicos falsificados o modificados provenientes de dominios válidos, implementar la política y verificación de DMARC, comenzando con la implementación del estándar Sender Policy Framework (SPF) y DomainKeys Identified Mail (DKIM).

Salvaviduas 9.6: Bloquear Tipos de Archivos Innecesarios

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Bloquear los tipos de archivos innecesarios que intenten ingresar a través de la puerta de enlace de correo electrónico de la empresa.

Salvaviduas 9.7: Deploy and Maintain Email Server Anti-Malware Protections

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG3
-----------------	-----	-----------------------	----------	-----

Implementar y mantener protecciones antimalware en el servidor de correo electrónico, como el escaneo de archivos adjuntos y/o entornos aislados (sandboxing).

Defensas Contra Malware

Salvaguardas: 7**IG1: 3/7****IG2: 7/7****IG3: 7/7**

Descripción general

Prevenir o controlar la instalación, propagación y ejecución de aplicaciones, código o scripts maliciosos en los activos empresariales.

¿Por qué es crítico este Control?

El software malicioso (a veces clasificado como virus o troyanos) es un aspecto integral y peligroso de las amenazas en internet. Puede tener diversos propósitos, como capturar credenciales, robar datos, identificar otros objetivos dentro de la red y cifrar o destruir información. El malware está en constante evolución y adaptación, ya que las variantes modernas utilizan técnicas de aprendizaje automático.

El malware ingresa a una empresa aprovechando vulnerabilidades en los dispositivos de usuario final, archivos adjuntos de correo electrónico, páginas web, servicios en la nube, dispositivos móviles y medios extraíbles. A menudo depende de comportamientos inseguros por parte del usuario final, como hacer clic en enlaces, abrir archivos adjuntos, instalar software o perfiles, o insertar unidades flash USB. El malware moderno está diseñado para evadir, engañar o desactivar las defensas.

Las defensas contra malware deben ser capaces de operar en este entorno dinámico mediante automatización, actualizaciones oportunas y rápidas, e integración con otros procesos como la gestión de vulnerabilidades y la respuesta a incidentes. Deben desplegarse en todos los posibles puntos de entrada y activos empresariales para detectar, prevenir la propagación o controlar la ejecución de software o código malicioso.

Procedimientos y herramientas

Una protección eficaz contra malware incluye suites tradicionales de prevención y detección de malware en los puntos finales. Para asegurar que los indicadores de compromiso (IOC) del malware estén actualizados, las empresas pueden recibir actualizaciones automáticas del proveedor para enriquecer otros datos de amenazas o vulnerabilidades. Estas herramientas se gestionan mejor de forma centralizada para proporcionar coherencia en toda la infraestructura.

Poder bloquear o identificar malware es solo una parte de este Control CIS; también se hace hincapié en la recopilación centralizada de registros para apoyar las alertas, la identificación y la respuesta a incidentes. A medida que los actores maliciosos continúan desarrollando sus metodologías, muchos adoptan un enfoque conocido como “vivir de la tierra” (LotL, por sus siglas en inglés) para minimizar la probabilidad de ser detectados. Este enfoque se refiere al comportamiento del atacante que utiliza herramientas o funciones que ya existen en el entorno objetivo. Habilitar el registro de eventos, según las Salvaguardas del Control 8 de CIS, facilitará significativamente que la empresa rastree los eventos para comprender qué ocurrió y por qué ocurrió.

- CIS proporciona una serie de guías para comprender cómo se aplican los Controles CIS a las técnicas más comunes de “vivir de la tierra”: <https://www.cisecurity.org/controls/resources?crc=minimize-your-threats>

Salvaguardas

Salvaguardas 10.1: Implementar y Mantener Software Antimalware

Tipo de Activo:	Dispositivos	Función de Seguridad:	Detectar	IG1	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----	-----

Implementar y mantener software antimalware en todos los activos empresariales.

Salvaguardas 10.2: Configurar Actualizaciones Automáticas de Firmas Antimalware

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----	-----

Configurar actualizaciones automáticas de los archivos de firmas antimalware en todos los activos empresariales.

Salvaguardas 10.3: Deshabilitar la Funcionalidad de Ejecución Automática y Reproducción Automática para Medios Extraíbles

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----	-----

Deshabilitar la funcionalidad de ejecución automática y reproducción automática para medios extraíbles.

Salvaguardas 10.4: Configurar el Escaneo Antimalware Automático de Medios Extraíbles

Tipo de Activo:	Dispositivos	Función de Seguridad:	Detectar	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----

Configurar el software antimalware para que escanee automáticamente los medios extraíbles.

Salvaguardas 10.5: Habilitar Funciones de Protección Contra Explotación

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----

Habilitar funciones de protección contra explotación en los activos empresariales y el software, cuando sea posible, como Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), o Apple® System Integrity Protection (SIP) y Gatekeeper™.

Salvaguardas 10.6: Gestionar Centralizadamente el Software Antimalware

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----

Gestionar centralizadamente el software antimalware.

Salvaguardas 10.7: Utilizar Software Antimalware Basado en Comportamiento

Tipo de Activo:	Dispositivos	Función de Seguridad:	Detectar	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----

Utilizar software antimalware basado en comportamiento.

CONTROL 11

Recuperación de Datos

Salvaguardass: 5	IG1: 4/5	IG2: 5/5	IG3: 5/5
------------------	----------	----------	----------

Descripción general

Establecer y mantener prácticas de recuperación de datos suficientes para restaurar los activos empresariales dentro del alcance a un estado confiable previo al incidente.

¿Por qué es crítico este Control?

En la tríada de ciberseguridad —Confidencialidad, Integridad y Disponibilidad (CIA, por sus siglas en inglés)— la disponibilidad de los datos es, en algunos casos, más crítica que su confidencialidad. Las empresas necesitan muchos tipos de datos para tomar decisiones comerciales, y cuando esos datos no están disponibles o no son confiables, pueden afectar a la organización. Un ejemplo sencillo es la información meteorológica para una empresa de transporte.

Cuando los atacantes comprometen activos, realizan cambios en las configuraciones, agregan cuentas y, con frecuencia, instalan software o scripts. Estos cambios no siempre son fáciles de identificar, ya que los atacantes podrían haber corrompido o reemplazado aplicaciones confiables con versiones maliciosas, o los cambios podrían parecer nombres de cuentas comunes. Los cambios en la configuración pueden incluir agregar o modificar entradas en el registro, abrir puertos, desactivar servicios de seguridad, eliminar registros u otras acciones maliciosas que hacen que un sistema sea inseguro. Estas acciones no tienen que ser maliciosas; errores humanos también pueden causarlas. Por lo tanto, es importante tener copias de seguridad o espejos recientes que permitan recuperar los activos empresariales y los datos a un estado confiable conocido.

En los últimos años ha habido un aumento exponencial del ransomware. No se trata de una amenaza nueva, aunque se ha comercializado y organizado más como un método confiable para que los atacantes obtengan ganancias. Si un atacante cifra los datos de una empresa y exige un rescate para restaurarlos, contar con una copia de seguridad reciente para recuperar el estado confiable puede ser útil. Sin embargo, a medida que el ransomware ha evolucionado, también se ha convertido en una técnica de extorsión, en la cual los datos se exfiltran antes de ser cifrados, y el atacante solicita un pago tanto para restaurar los datos de la empresa como para evitar que sean vendidos o divulgados. En este caso, la restauración solo resolvería el problema de recuperar los sistemas a un estado confiable y continuar las operaciones. Aplicar la orientación contenida en los Controles CIS ayudará a reducir el riesgo de ransomware mediante una mejor higiene cibernética, ya que los atacantes suelen utilizar exploits básicos o antiguos en sistemas inseguros.

Procedimientos y herramientas

Los procedimientos de recuperación de datos deben definirse dentro del proceso de gestión de datos descrito en el Control 3 de CIS, Protección de Datos. Esto debe incluir procedimientos de respaldo basados en el valor, la sensibilidad o los requisitos de retención de los datos. Esto ayudará a desarrollar la frecuencia y el tipo de respaldo (completo vs. incremental).

Una vez por trimestre (o siempre que se introduzca un nuevo proceso o tecnología de respaldo), un equipo de prueba debe evaluar una muestra aleatoria de respaldos e intentar restaurarlos en un entorno de prueba. Las copias restauradas deben verificarse para asegurar que el sistema operativo, la aplicación y los datos del respaldo estén intactos y sean funcionales.

En caso de una infección por malware, los procedimientos de restauración deben utilizar una versión del respaldo que se considere anterior a la infección original.

Salvaguardass

Salvaguardas 11.1: Establecer y Mantener un Proceso de Recuperación de Datos

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y mantener un proceso documentado de recuperación de datos que incluya procedimientos detallados de respaldo. En el proceso, abordar el alcance de las actividades de recuperación de datos, la priorización de la recuperación y la seguridad de los datos de respaldo. Revisar y actualizar la documentación anualmente, o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvaguardas 11.2: Realizar Respaldos Automatizados

Tipo de Activo:	Datos	Función de Seguridad:	Recuperar	IG1	IG2	IG3
-----------------	-------	-----------------------	-----------	-----	-----	-----

Realizar respaldos automatizados de los activos empresariales dentro del alcance. Ejecutar respaldos semanalmente, o con mayor frecuencia, según la sensibilidad de los datos.

Salvaguardas 11.3: Proteger los Datos de Recuperación

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	-------	-----------------------	----------	-----	-----	-----

Proteger los datos de recuperación con controles equivalentes a los de los datos originales. Hacer referencia al cifrado o separación de datos, según los requisitos.

Salvavidas 11.4: Establecer y Mantener una Instancia Aislada de los Datos de Recuperación

Tipo de Activo:	Datos	Función de Seguridad:	Recuperar	IG1	IG2	IG3
-----------------	-------	-----------------------	-----------	-----	-----	-----

Establecer y mantener una instancia aislada de los datos de recuperación. Ejemplos de implementación incluyen el control de versiones de los destinos de respaldo mediante sistemas o servicios fuera de línea, en la nube o fuera del sitio.

Salvavidas 11.5: Probar la Recuperación de Datos

Tipo de Activo:	Datos	Función de Seguridad:	Recuperar	IG2	IG3
-----------------	-------	-----------------------	-----------	-----	-----

Probar la recuperación de respaldos trimestralmente, o con mayor frecuencia, para una muestra de los activos empresariales dentro del alcance.

CONTROL 12

Gestión de la Infraestructura de Red

Salvaguardass: 8	IG1: 1/8	IG2: 7/8	IG3: 8/8
------------------	----------	----------	----------

Descripción general

Establecer, implementar y gestionar activamente (rastrear, reportar, corregir) los dispositivos de red, con el fin de evitar que los atacantes exploten servicios y puntos de acceso vulnerables de la red.

¿Por qué es crítico este Control?

Una infraestructura de red segura es una defensa esencial contra los ataques. Esto incluye una arquitectura de seguridad adecuada, abordar las vulnerabilidades que, en muchos casos, son introducidas mediante configuraciones predeterminadas, monitorear los cambios y reevaluar las configuraciones actuales. La infraestructura de red incluye dispositivos como puertas de enlace físicas y virtuales, cortafuegos (firewalls), puntos de acceso inalámbricos, enrutadores (routers) y conmutadores (switches).

Las configuraciones predeterminadas de los dispositivos de red están orientadas a facilitar la implementación y el uso, no la seguridad. Las posibles vulnerabilidades predeterminadas incluyen servicios y puertos abiertos, cuentas y contraseñas por defecto (incluidas cuentas de servicio), compatibilidad con protocolos antiguos y vulnerables, y la preinstalación de software innecesario. Los atacantes buscan configuraciones predeterminadas vulnerables, brechas o inconsistencias en las reglas del firewall, enrutadores y conmutadores, y utilizan esos huecos para penetrar las defensas. Explotan fallos en estos dispositivos para acceder a las redes, redirigir el tráfico y/o interceptar datos durante su transmisión.

La seguridad de red es un entorno en constante cambio que requiere reevaluaciones periódicas de los diagramas de arquitectura, configuraciones, controles de acceso y flujos de tráfico permitidos. Los atacantes aprovechan el hecho de que las configuraciones de los dispositivos de red se vuelven menos seguras con el tiempo, a medida que los usuarios solicitan excepciones por necesidades específicas del negocio. A veces se implementan estas excepciones, pero no se eliminan cuando ya no son necesarias. En algunos casos, el riesgo de seguridad asociado con una excepción no es analizado ni comparado adecuadamente con la necesidad del negocio, y esto puede cambiar con el tiempo.

Procedimientos y herramientas

Las organizaciones deben asegurarse de que la infraestructura de red esté completamente documentada y que los diagramas de arquitectura estén actualizados. Es importante que los componentes clave de la infraestructura cuenten con soporte del proveedor para parches y actualizaciones de funcionalidades. Se deben actualizar los componentes que han alcanzado el fin de su vida útil (EOL, por sus siglas en inglés) antes de la fecha en que dejarán de recibir soporte, o bien aplicar controles de mitigación para aislarlos. Las empresas deben monitorear las versiones y configuraciones de su infraestructura en busca de vulnerabilidades que requieran actualizar los dispositivos de red a la versión más reciente, segura y estable, sin que ello afecte negativamente la infraestructura.

Un diagrama actualizado de arquitectura de red, incluidos los diagramas de arquitectura de seguridad, es una base importante para la gestión de la infraestructura. A continuación, se debe contar con una gestión completa de cuentas para el control de acceso, el registro (logging) y el monitoreo. Finalmente, la administración de la infraestructura debe realizarse únicamente mediante protocolos seguros, con autenticación robusta (MFA para gestión de acceso privilegiado, PAM) y desde dispositivos administrativos dedicados o redes fuera de banda (out-of-band).

Las herramientas comerciales pueden ser útiles para evaluar los conjuntos de reglas de los dispositivos de filtrado de red, con el fin de determinar si son consistentes o si presentan conflictos. Esto proporciona una verificación automatizada del estado de los filtros de red. Estas herramientas buscan errores en los conjuntos de reglas o en las Listas de Control de Acceso (ACLs) que puedan permitir, por error, el paso de servicios no deseados a través del dispositivo de red. Estas herramientas deben ejecutarse cada vez que se realicen cambios significativos en las reglas de los cortafuegos, las ACLs de los enrutadores u otras tecnologías de filtrado.

- Para orientación sobre trabajo remoto y oficinas pequeñas, consulte la Guía de Seguridad en Redes para Teletrabajo y Oficinas Pequeñas de los Controles CIS:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

Salvaguardass

Salvaguardas 12.1: Asegurar que la Infraestructura de Red Esté Actualizada

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----	-----

Asegurar que la infraestructura de red se mantenga actualizada. Las implementaciones de ejemplo incluyen ejecutar la versión estable más reciente del software y/o utilizar ofertas actuales de red como servicio (NaaS). Revisar las versiones de software mensualmente, o con mayor frecuencia, para verificar el soporte del software.

Salvavidas 12.2: Establecer y Mantener una Arquitectura de Red Segura

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Diseñar y mantener una arquitectura de red segura. Una arquitectura de red segura debe abordar, como mínimo, la segmentación, el principio de menor privilegio y la disponibilidad. Las implementaciones de ejemplo pueden incluir documentación, políticas y componentes de diseño.

Salvavidas 12.3: Gestionar de Forma Segura la Infraestructura de Red

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Gestionar de forma segura la infraestructura de red. Las implementaciones de ejemplo incluyen infraestructura como código con control de versiones, y el uso de protocolos de red seguros como SSH y HTTPS.

Salvavidas 12.4: Establecer y Mantener Diagramas de Arquitectura

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Establecer y mantener diagramas de arquitectura y/o otra documentación del sistema de red. Revisar y actualizar la documentación anualmente, o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvavidas.

Salvavidas 12.5: Centralizar la Autenticación, Autorización y Auditoría (AAA) de la Red

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Centralizar los servicios de AAA (autenticación, autorización y auditoría) de la red.

Salvavidas 12.6: Usar Protocolos Seguros de Gestión y Comunicación de Red

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Adoptar protocolos seguros de gestión de red (por ejemplo, 802.1X) y protocolos seguros de comunicación (por ejemplo, Wi-Fi Protected Access 2 (WPA2) Enterprise o alternativas más seguras).

Salvaviduas 12.7: Asegurar que los Dispositivos Remotos Utilicen una VPN y se Conecten a la Infraestructura de AAA de la Empresa

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----

Requerir que los usuarios se autenticuen en una VPN gestionada por la empresa y en los servicios de autenticación antes de acceder a los recursos empresariales desde dispositivos de usuario final.

Salvaviduas 12.8: Establecer y Mantener Recursos Informáticos Dedicados para Todo el Trabajo Administrativo

Tipo de Activo:	Dispositivos	Función de Seguridad:	Proteger	IG3
-----------------	--------------	-----------------------	----------	-----

Establecer y mantener recursos informáticos dedicados, ya sea físicamente o lógicamente separados, para todas las tareas administrativas o tareas que requieran acceso administrativo. Los recursos informáticos deben estar segmentados de la red principal de la empresa y no deben tener acceso a internet.

Monitoreo y Defensa de la Red

Salvaguardass: 11**IG1: 0/11****IG2: 6/11****IG3: 11/11**

Descripción general

Operar procesos y herramientas para establecer y mantener un monitoreo integral de la red y defensa contra amenazas de seguridad en toda la infraestructura de red y base de usuarios de la empresa.

¿Por qué es crítico este Control?

No se puede confiar en que las defensas de red sean perfectas. Los adversarios continúan evolucionando y madurando, compartiendo o vendiendo información dentro de su comunidad sobre exploits y métodos para eludir los controles de seguridad. Incluso si las herramientas de seguridad funcionan “como se anuncia”, es necesario comprender la postura de riesgo de la empresa para configurarlas, ajustarlas y registrar su actividad de forma eficaz. Frecuentemente, errores de configuración debido a fallas humanas o al desconocimiento de las capacidades de las herramientas dan a las organizaciones una falsa sensación de seguridad.

Las herramientas de seguridad solo pueden ser eficaces si respaldan un proceso de monitoreo continuo que permita al personal recibir alertas y responder rápidamente ante incidentes de seguridad. Las empresas que adoptan un enfoque impulsado únicamente por tecnología experimentarán también más falsos positivos, debido a su dependencia excesiva en las alertas de las herramientas. Identificar y responder a estas amenazas requiere visibilidad de todos los vectores de amenaza en la infraestructura, y aprovechar la intervención humana en los procesos de detección, análisis y respuesta. Es fundamental que las empresas grandes o fuertemente atacadas cuenten con una capacidad operativa de seguridad para prevenir, detectar y responder rápidamente ante amenazas cibernéticas antes de que afecten a la organización.

Este proceso generará informes de actividad y métricas que ayudarán a mejorar las políticas de seguridad y respaldarán el cumplimiento normativo en muchas organizaciones.

Como se ha visto en múltiples ocasiones en la prensa, hay empresas que han sido comprometidas durante semanas, meses o incluso años antes de que se descubra. El principal beneficio de contar con una conciencia situacional integral es aumentar la velocidad de detección y respuesta. Esto es crítico para responder con rapidez cuando se detecta malware, se roban credenciales o se comprometen datos sensibles, con el fin de reducir el impacto para la organización.

Mediante una buena conciencia situacional (es decir, operaciones de seguridad), las empresas identificarán y catalogarán Tácticas, Técnicas y Procedimientos (TTP) de los atacantes, incluidos sus Indicadores de Compromiso (IOC), lo que ayudará a la empresa a adoptar un enfoque más proactivo en la identificación de amenazas o incidentes futuros. La recuperación puede lograrse más rápidamente cuando la respuesta tiene acceso a información completa sobre el entorno y la estructura de la empresa para desarrollar estrategias de respuesta eficaces.

Procedimientos y herramientas

La mayoría de las empresas no necesitan establecer un Centro de Operaciones de Seguridad (SOC) para obtener conciencia situacional. Esto comienza con entender primero las funciones comerciales críticas, las arquitecturas de red y servidores, los datos y flujos de datos, las conexiones con proveedores de servicios y socios comerciales, y los dispositivos y cuentas de los usuarios finales. Esta información orienta el desarrollo de una arquitectura de seguridad, controles técnicos, procedimientos de registro, monitoreo y respuesta.

En el núcleo de este proceso se encuentra un equipo capacitado y organizado que implementa procesos para la detección, análisis y mitigación de incidentes. Estas capacidades pueden ejecutarse internamente, o mediante consultores o un proveedor de servicios gestionados. Las empresas deben considerar las actividades relacionadas con la red, los activos empresariales, las credenciales de usuario y el acceso a los datos. La tecnología desempeñará un papel crucial en la recopilación y análisis de todos los datos, así como en el monitoreo de las redes y activos empresariales tanto internos como externos a la organización. Las empresas deben asegurar visibilidad sobre las plataformas en la nube que podrían no alinearse con la tecnología de seguridad instalada localmente.

Redirigir todos los registros importantes a programas analíticos, como soluciones de Gestión de Información y Eventos de Seguridad (SIEM), puede aportar valor; sin embargo, no proporcionan una imagen completa. Las revisiones semanales de registros son necesarias para ajustar los umbrales e identificar eventos anómalos. Las herramientas de correlación pueden hacer que los registros de auditoría sean más útiles para inspecciones manuales posteriores. Estas herramientas no son un reemplazo para el personal calificado en seguridad de la información ni para los administradores de sistemas. Incluso con herramientas automatizadas de análisis de registros, a menudo se requiere experiencia humana e intuición para identificar y comprender los ataques. A medida que este proceso madura, las organizaciones crearán, mantendrán y evolucionarán una base de conocimientos que les ayudará a comprender y evaluar los riesgos comerciales, desarrollando una capacidad interna de inteligencia de amenazas.

La inteligencia de amenazas es la recopilación de TTP extraídos de incidentes y adversarios. Para lograr esto, un programa de conciencia situacional debe definir y evaluar qué fuentes de información son relevantes para detectar, reportar y gestionar ataques. La mayoría de las organizaciones maduras pueden evolucionar hacia actividades de búsqueda de amenazas (threat hunting), donde personal capacitado revisa manualmente registros del sistema y del usuario, flujos de datos y patrones de tráfico para encontrar anomalías.

Salvaguardass

Salvaguardas 13.1: Centralizar la Generación de Alertas de Eventos de Seguridad

Tipo de Activo:	Red	Función de Seguridad:	Detectar	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Centralizar la generación de alertas de eventos de seguridad en todos los activos empresariales para la correlación y el análisis de registros. La mejor práctica consiste en el uso de una solución SIEM, que incluya alertas de correlación de eventos definidas por el proveedor. Una plataforma de análisis de registros configurada con alertas de correlación relevantes para seguridad también satisface esta Salvaguarda.

Salvaguardas 13.2: Implementar una Solución de Detección de Intrusiones Basada en el Host

Tipo de Activo:	Dispositivos	Función de Seguridad:	Detectar	IG2	IG3
-----------------	--------------	-----------------------	----------	-----	-----

Implementar una solución de detección de intrusiones basada en el host en los activos empresariales, cuando sea apropiado y/o compatible.

Salvaguardas 13.3: Implementar una Solución de Detección de Intrusiones en la Red

Tipo de Activo:	Red	Función de Seguridad:	Detectar	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Implementar una solución de detección de intrusiones en la red en los activos empresariales, cuando sea apropiado. Ejemplos de implementación incluyen el uso de un Sistema de Detección de Intrusos en la Red (NIDS) o un servicio equivalente del proveedor de servicios en la nube (CSP).

Salvaguardas 13.4: Realizar Filtrado de Tráfico Entre Segmentos de Red

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Realizar filtrado de tráfico entre segmentos de red, cuando sea apropiado.

Salvaviduas 13.5: Gestionar el Control de Acceso para Activos Remotos

Tipo de Activo: Dispositivos

Función de Seguridad: Proteger

IG2

IG3

Gestionar el control de acceso para los activos que se conectan remotamente a los recursos empresariales. Determinar el nivel de acceso a los recursos empresariales en función de: si se cuenta con software antimalware actualizado, el cumplimiento de la configuración con el proceso de configuración segura de la empresa, y la verificación de que el sistema operativo y las aplicaciones estén actualizados.

Salvaviduas 13.6: Recopilar Registros de Flujo de Tráfico de Red

Tipo de Activo: Red

Función de Seguridad: Detectar

IG2

IG3

Recopilar registros de flujo de tráfico de red y/o tráfico de red para su revisión y para la generación de alertas, a partir de dispositivos de red.

Salvaviduas 13.7: Implementar una Solución de Prevención de Intrusiones Basada en el Host

Tipo de Activo: Dispositivos

Función de Seguridad: Proteger

IG3

Implementar una solución de prevención de intrusiones basada en el host en los activos empresariales, cuando sea apropiado y/o compatible. Ejemplos de implementación incluyen el uso de un cliente de Detección y Respuesta en el Punto Final (EDR) o un agente IPS basado en el host.

Salvaviduas 13.8: Implementar una Solución de Prevención de Intrusiones en la Red

Tipo de Activo: Red

Función de Seguridad: Proteger

IG3

Implementar una solución de prevención de intrusiones en la red, cuando sea apropiado. Ejemplos de implementación incluyen el uso de un Sistema de Prevención de Intrusos en la Red (NIPS) o un servicio equivalente de un CSP.

Salvaviduas 13.9: Implementar Control de Acceso a Nivel de Puerto

Tipo de Activo: Red

Función de Seguridad: Proteger

IG3

Implementar control de acceso a nivel de puerto. El control de acceso a nivel de puerto utiliza 802.1x u otros protocolos similares de control de acceso a la red, como certificados, y puede incorporar autenticación de usuario y/o dispositivo.

Salvaguardas 13.10: Realizar Filtrado a Nivel de Capa de Aplicación

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG3
-----------------	-----	-----------------------	----------	-----

Realizar filtrado a nivel de capa de aplicación. Ejemplos de implementación incluyen un proxy de filtrado, firewall de capa de aplicación o gateway.

Salvaguardas 13.11: Ajustar los Umbrales de Generación de Alertas de Eventos de Seguridad

Tipo de Activo:	Red	Función de Seguridad:	Detectar	IG3
-----------------	-----	-----------------------	----------	-----

Ajustar los umbrales de alerta de eventos de seguridad mensualmente, o con mayor frecuencia.

CONTROL 14

Concientización sobre Seguridad y Capacitación en Habilidades

Salvaguardass: 9	IG1: 8/9	IG2: 9/9	IG3: 9/9
------------------	----------	----------	----------

Descripción general

Establecer y mantener un programa de concientización sobre seguridad para influir en el comportamiento del personal, de modo que sea consciente de la seguridad y esté adecuadamente capacitado para reducir los riesgos de ciberseguridad para la organización.

¿Por qué es crítico este Control?

Las acciones de las personas juegan un papel fundamental en el éxito o fracaso del programa de seguridad de una empresa. Es más fácil para un atacante persuadir a un usuario para que haga clic en un enlace o abra un archivo adjunto de correo electrónico que instale malware y permita el acceso a la organización, que encontrar un exploit de red para hacerlo directamente.

Los propios usuarios, ya sea de forma intencional o no, pueden causar incidentes como resultado del mal manejo de datos sensibles, enviar un correo electrónico con información confidencial al destinatario equivocado, perder un dispositivo portátil de usuario final, usar contraseñas débiles o reutilizar contraseñas empleadas en sitios públicos.

Ningún programa de seguridad puede abordar eficazmente el riesgo cibernético sin una estrategia para enfrentar esta vulnerabilidad humana fundamental. Los usuarios en todos los niveles de la organización enfrentan diferentes riesgos. Por ejemplo: los ejecutivos gestionan información más sensible; los administradores de sistemas tienen la capacidad de controlar el acceso a sistemas y aplicaciones; y los usuarios en finanzas, recursos humanos y contratos tienen acceso a distintos tipos de información sensible que los pueden convertir en objetivos.

La capacitación debe actualizarse regularmente. Esto aumentará la cultura de seguridad y desincentivará soluciones de trabajo que impliquen riesgos.

Procedimientos y herramientas

Las acciones de las personas juegan un papel fundamental en el éxito o fracaso del programa de seguridad de una empresa de una empresa. Es más fácil para un atacante persuadir a un usuario para que haga clic en un enlace o abra un archivo adjunto de correo electrónico que instale malware y permita el acceso a la organización, que encontrar un exploit de red para hacerlo directamente.

Los propios usuarios, ya sea de forma intencional o no, pueden causar incidentes como resultado del mal manejo de datos sensibles, enviar un correo electrónico con información confidencial al destinatario equivocado, perder un dispositivo portátil de usuario final, usar contraseñas débiles o reutilizar contraseñas empleadas en sitios públicos.

Ningún programa de seguridad puede abordar eficazmente el riesgo cibernético sin una estrategia para enfrentar esta vulnerabilidad humana fundamental. Los usuarios en todos los niveles de la organización enfrentan diferentes riesgos. Por ejemplo: los ejecutivos gestionan información más sensible; los administradores de sistemas tienen la capacidad de controlar el acceso a sistemas y aplicaciones; y los usuarios en finanzas, recursos humanos y contratos tienen acceso a distintos tipos de información sensible que los pueden convertir en objetivos.

La capacitación debe actualizarse regularmente. Esto aumentará la cultura de seguridad y desincentivará soluciones de trabajo que impliquen riesgos.

Procedimientos y herramientas

Un programa eficaz de capacitación en concientización sobre seguridad no debe limitarse a un video pregrabado una vez al año junto con pruebas periódicas de phishing. Si bien la capacitación anual es necesaria, también deben existir mensajes y notificaciones frecuentes y temáticos sobre seguridad. Esto podría incluir mensajes sobre: uso de contraseñas seguras que coincidan con noticias sobre filtraciones masivas de contraseñas, aumento de intentos de phishing durante la temporada de impuestos, o mayor conciencia sobre correos maliciosos de entregas de paquetes durante las festividades.

La capacitación también debe tener en cuenta la postura regulatoria y de amenazas de la organización. Las entidades financieras podrían requerir más formación relacionada con el cumplimiento sobre manejo y uso de datos; las instituciones de salud, sobre datos sanitarios; y los comerciantes, sobre datos de tarjetas de crédito.

La capacitación en ingeniería social, como las pruebas de phishing, también debe incluir la concientización sobre tácticas dirigidas a distintos roles. Por ejemplo, el equipo financiero podría recibir intentos de BEC (compromiso de correo empresarial) haciéndose pasar por ejecutivos que solicitan transferencias bancarias, o correos de socios o proveedores comprometidos que piden cambiar la cuenta bancaria para el próximo pago.

Para una cobertura más amplia sobre este tema, los siguientes recursos son útiles para construir un programa eficaz de concientización sobre seguridad:

- NIST® SP 800-50 Entrenamiento en Concientización sobre Seguridad de la Información: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-50r1.pdf>
- Centro Nacional de Ciberseguridad (Reino Unido): <https://www.ncsc.gov.uk/guidance/10-steps-user-education-and-awareness>
- EDUCAUSE: <https://www.educause.edu/focus-areas-and-initiatives/policy-and-security/cybersecurity-program/awareness-campaigns>
- Alianza Nacional de Ciberseguridad (NCSA): <https://staysafeonline.org/>
- SANS Security Awareness: <https://www.sans.org/security-awareness-training/resources>
- Para obtener orientación sobre cómo configurar routers domésticos, consulte la Guía de Seguridad en Redes para Teletrabajo y Oficinas Pequeñas de los Controles CIS: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

Salvaguardass

Salvaguardas 14.1: Establecer y Mantener un Programa de Concientización sobre Seguridad

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y mantener un programa de concientización sobre seguridad. El propósito de este programa es educar a la fuerza laboral de la empresa sobre cómo interactuar de manera segura con los activos y datos de la organización. Impartir la capacitación al momento de la contratación y, como mínimo, una vez al año. Revisar y actualizar el contenido anualmente o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvaguardas 14.2: Capacitar a los Miembros del Personal para Reconocer Ataques de Ingeniería Social

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Capacitar a los miembros del personal para reconocer ataques de ingeniería social, como el phishing, compromiso del correo electrónico empresarial (BEC), suplantación de identidad (pretexting) y seguimiento físico no autorizado (tailgating).

Salvaguardas 14.3: Capacitar al Personal en Buenas Prácticas de Autenticación

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Capacitar a los miembros del personal en buenas prácticas de autenticación. Los temas de ejemplo incluyen el uso de MFA, la composición de contraseñas y la gestión de credenciales.

Salvaguardas 14.4: Capacitar al Personal en Buenas Prácticas para el Manejo de Datos

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Capacitar a los miembros del personal sobre cómo identificar y almacenar, transferir, archivar y destruir adecuadamente los datos sensibles. Esto también incluye capacitación en buenas prácticas de orden y limpieza, como bloquear la pantalla al alejarse del dispositivo de la empresa, borrar pizarras físicas y virtuales al finalizar reuniones, y almacenar datos y activos de forma segura.

Salvaguardas 14.5: Capacitar al Personal sobre las Causas de Exposición Involuntaria de Datos

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Capacitar a los miembros del personal para que estén conscientes de las causas de exposición involuntaria de datos. Los temas de ejemplo incluyen la entrega errónea de datos sensibles, la pérdida de dispositivos portátiles de usuario final o la publicación de datos a audiencias no deseadas.

Salvaguardas 14.6: Capacitar al Personal para Reconocer e Informar Incidentes de Seguridad

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Capacitar a los miembros del personal para que puedan reconocer un posible incidente y sepan cómo reportarlo.

Salvaguardas 14.7: Capacitar al Personal para Identificar y Reportar si sus Activos Empresariales Carecen de Actualizaciones de Seguridad

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Capacitar al personal para que comprenda cómo verificar y reportar la falta de actualizaciones de software o cualquier falla en los procesos y herramientas automatizadas. Parte de esta capacitación debe incluir cómo notificar al personal de TI sobre fallas en dichos procesos y herramientas.

Salvaguardas 14.8: Capacitar al Personal sobre los Riesgos de Conectarse y Transmitir Datos Empresariales a través de Redes Inseguras

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG1	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----	-----

Capacitar a los miembros del personal sobre los peligros de conectarse a redes inseguras o transmitir datos empresariales a través de ellas. Si la empresa cuenta con trabajadores remotos, la capacitación debe incluir orientación para asegurar que todos los usuarios configuren de manera segura la infraestructura de red de sus hogares.

Salvaguardas 14.9: Realizar Capacitación en Concientización sobre Seguridad y Habilidades Específicas para Cada Rol

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Realizar capacitación en concientización sobre seguridad y habilidades específicas según el rol. Ejemplos de implementación incluyen cursos sobre administración segura de sistemas para profesionales de TI, capacitación sobre concientización y prevención de vulnerabilidades OWASP® Top 10 para desarrolladores de aplicaciones web, y capacitación avanzada sobre ingeniería social para puestos de alto perfil.

Gestión de Proveedores de Servicios

Salvaguardass: 7	IG1: 1/7	IG2: 4/7	IG3: 7/7
------------------	----------	----------	----------

Descripción general

Desarrollar un proceso para evaluar a los proveedores de servicios que manejan datos sensibles o que son responsables de plataformas o procesos críticos de TI de la empresa, a fin de garantizar que estos proveedores estén protegiendo adecuadamente esas plataformas y datos.

¿Por qué es crítico este Control?

En nuestro mundo moderno e interconectado, las empresas dependen de proveedores y socios para ayudar a gestionar sus datos o para proporcionar infraestructura para aplicaciones o funciones clave.

Existen numerosos ejemplos donde las brechas de terceros han tenido un impacto significativo en las empresas; por ejemplo, desde finales de los años 2000, se comprometieron tarjetas de pago después de que atacantes infiltraron proveedores de servicios más pequeños en la industria minorista. Ejemplos más recientes incluyen ataques de ransomware que afectan indirectamente a una empresa debido a que uno de sus proveedores quedó inoperativo, causando interrupciones en el negocio. O peor aún, si existe una conexión directa, un ataque de ransomware podría cifrar los datos de la empresa principal.

La mayoría de las regulaciones de seguridad y privacidad de los datos requieren que su protección se extienda también a los proveedores de servicios, como es el caso de los acuerdos de asociados comerciales (Business Associate Agreements) bajo la Ley de Portabilidad y Responsabilidad de Seguros de Salud (HIPAA), los requisitos del Consejo de Examinadores de Instituciones Financieras Federales (FFIEC) para el sector financiero, y el programa Cyber Essentials del Reino Unido. La confianza en terceros es una función esencial de Gobernanza, Riesgo y Cumplimiento (GRC), ya que los riesgos no gestionados internamente se transfieren a entidades externas.

Aunque la revisión de la seguridad de terceros se ha llevado a cabo durante décadas, no existe un estándar universal para evaluar la seguridad; y muchos proveedores de servicios son auditados por sus clientes múltiples veces al mes, lo que impacta negativamente su productividad. Esto se debe a que cada empresa tiene una lista de verificación o conjunto de estándares diferente para calificar al proveedor. Solo existen unos pocos estándares industriales, como el programa Shared Assessments en el sector financiero, o la herramienta Higher Education Community Vendor Assessment Toolkit (HECVAT) en educación superior. Las compañías de seguros que ofrecen pólizas de ciberseguridad también emplean sus propias métricas.

Aunque una empresa podría enfocar mucho escrutinio en compañías grandes de alojamiento en la nube o de aplicaciones porque hospedan su correo electrónico o aplicaciones críticas, las empresas más pequeñas a menudo representan un mayor riesgo. Con frecuencia, un proveedor de servicios contrata a otras partes para ofrecer complementos o servicios adicionales, como cuando un tercero usa una plataforma o producto de un cuarto proveedor para respaldar a la empresa principal.

Procedimientos y herramientas

La mayoría de las empresas han utilizado tradicionalmente listas de verificación estándar, como las de ISO 27001 o los Controles CIS. A menudo, este proceso se gestiona a través de hojas de cálculo; sin embargo, actualmente existen plataformas en línea que permiten una gestión centralizada del proceso. No obstante, el enfoque de este Control CIS no está en la lista de verificación, sino en los fundamentos del programa. Asegúrese de revisarlo anualmente, ya que las relaciones y los datos pueden cambiar.

Independientemente del tamaño de la empresa, debe existir una política para revisar a los proveedores de servicios, un inventario de estos proveedores y una calificación de riesgo asociada con su impacto potencial en el negocio en caso de un incidente. También se debe incluir cláusulas contractuales que responsabilicen al proveedor si ocurre un incidente que afecte a la empresa.

Existen plataformas de evaluación de terceros que tienen inventarios de miles de proveedores de servicios, y que intentan ofrecer una vista centralizada de la industria para ayudar a las empresas a tomar decisiones de riesgo más informadas. Estas plataformas a menudo asignan una puntuación de riesgo dinámica a los proveedores de servicios, basada (generalmente) en evaluaciones técnicas pasivas, o enriquecidas mediante evaluaciones de terceros realizadas por otras empresas.

Al realizar evaluaciones, es importante enfocarse en los servicios o departamentos del proveedor que están brindando soporte a la empresa. Un proveedor de servicios que tiene un contrato de servicio de seguridad gestionado o de retención, y que cuenta con un seguro de ciberseguridad, también puede ayudar a reducir el riesgo.

También es importante desactivar de forma segura a los proveedores de servicios cuando los contratos se completen o se rescindan. Las actividades de desactivación pueden incluir la desactivación de cuentas de usuario y de servicio, la terminación de los flujos de datos y la eliminación segura de los datos de la empresa que se encuentren en los sistemas del proveedor de servicios.

- Para conocer pautas sobre la eliminación segura de medios, consulte NIST® 800-88r1: Guidelines for Media Sanitization, según corresponda: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r1.pdf>

Resguardo

Salvaguardas 15.1: Establecer y Mantener un Inventario de Proveedores de Servicios

Tipo de Activo:	Usuarios	Función de Seguridad:	Identificar	IG1	IG2	IG3
-----------------	----------	-----------------------	-------------	-----	-----	-----

Establecer y mantener un inventario de proveedores de servicios. El inventario debe listar todos los proveedores de servicios conocidos, incluir sus clasificaciones y designar un contacto dentro de la empresa para cada proveedor. Revisar y actualizar el inventario anualmente, o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvaguardas 15.2: Establecer y Mantener una Política de Gestión de Proveedores de Servicios

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Establecer y mantener una política de gestión de proveedores de servicios. Asegurarse de que la política aborde la clasificación, inventario, evaluación, monitoreo y desactivación de proveedores de servicios. Revisar y actualizar la política anualmente, o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvaguardas 15.3: Clasificar a los Proveedores de Servicios

Tipo de Activo:	Usuarios	Función de Seguridad:	Gobernar	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Clasificar a los proveedores de servicios. La clasificación puede considerar una o más características, tales como la sensibilidad de los datos, el volumen de datos, los requisitos de disponibilidad, las regulaciones aplicables, el riesgo inherente y el riesgo mitigado. Actualizar y revisar las clasificaciones anualmente, o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvaguardas 15.4: Asegurar que los Contratos con Proveedores de Servicios Incluyan Requisitos de Seguridad

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Asegurar que los contratos con proveedores de servicios incluyan requisitos de seguridad. Los requisitos de ejemplo pueden incluir requisitos mínimos del programa de seguridad, notificación y respuesta ante incidentes de seguridad y/o violaciones de datos, requisitos de cifrado de datos y compromisos de eliminación de datos. Estos requisitos de seguridad deben ser coherentes con la política de gestión de proveedores de servicios de la empresa. Revisar los contratos de los proveedores de servicios anualmente para asegurarse de que no falten requisitos de seguridad.

Salvaguardas 15.5: Evaluar a los Proveedores de Servicios

Tipo de Activo:	Usuarios	Función de Seguridad:	Gobernar	IG3
-----------------	----------	-----------------------	----------	-----

Evaluar a los proveedores de servicios de acuerdo con la política de gestión de proveedores de servicios de la empresa. El alcance de la evaluación puede variar según la(s) clasificación(es), e incluir la revisión de informes de evaluación estandarizados, como los informes de Control de Organización de Servicios 2 (SOC 2) y la Declaración de Cumplimiento (AoC) de la Industria de Tarjetas de Pago (PCI), cuestionarios personalizados u otros procesos rigurosos apropiados. Reevaluar a los proveedores de servicios al menos una vez al año, o con la firma de contratos nuevos o renovados.

Salvaguardas 15.6: Monitorear a los Proveedores de Servicios

Tipo de Activo:	Datos	Función de Seguridad:	Gobernar	IG3
-----------------	-------	-----------------------	----------	-----

Monitorear a los proveedores de servicios de acuerdo con la política de gestión de proveedores de servicios de la empresa. El monitoreo puede incluir la reevaluación periódica del cumplimiento del proveedor de servicios, el seguimiento de notas de versiones de los proveedores y el monitoreo de la dark web.

Salvaguardas 15.7: Desactivar de Forma Segura a los Proveedores de Servicios

Tipo de Activo:	Datos	Función de Seguridad:	Proteger	IG3
-----------------	-------	-----------------------	----------	-----

Desactivar de forma segura a los proveedores de servicios. Las consideraciones de ejemplo incluyen la desactivación de cuentas de usuario y de servicio, la finalización de flujos de datos y la eliminación segura de los datos de la empresa contenidos en los sistemas del proveedor de servicios.

Seguridad del Software de Aplicación

Salvaguardass: 14	IG1: 0/14	IG2: 11/14	IG3: 14/14
-------------------	-----------	------------	------------

Descripción general

Gestionar el ciclo de vida de seguridad del software desarrollado internamente, alojado o adquirido, para prevenir, detectar y remediar debilidades de seguridad antes de que puedan afectar a la empresa.

¿Por qué es crítico este Control?

Las aplicaciones proporcionan una interfaz amigable para que los usuarios accedan y gestionen datos de una manera alineada con las funciones empresariales. También minimizan la necesidad de que los usuarios interactúen directamente con funciones del sistema complejas (y potencialmente propensas a errores), como iniciar sesión en una base de datos para insertar o modificar archivos. Las empresas utilizan aplicaciones para gestionar sus datos más sensibles y controlar el acceso a los recursos del sistema. Por lo tanto, un atacante puede usar la propia aplicación para comprometer los datos, en lugar de un complejo ataque a la red y sistemas que intente eludir los controles de seguridad y sensores de red. Por esta razón, proteger las credenciales de usuario (específicamente las credenciales de aplicaciones), tal como se define en el Control CIS 6, es tan importante.

A falta de credenciales, los errores de la aplicación son el vector de ataque preferido. Sin embargo, las aplicaciones actuales se desarrollan, operan y mantienen en un entorno altamente complejo, diverso y dinámico. Las aplicaciones se ejecutan en múltiples plataformas: web, móviles, en la nube, etc., con arquitecturas más complejas que las estructuras heredadas de cliente-servidor o base de datos-servidor web. Los ciclos de desarrollo se han acortado, pasando de metodologías extensas tipo cascada a ciclos DevOps con actualizaciones frecuentes de código. Además, las aplicaciones rara vez se crean desde cero, y con frecuencia se “ensamblan” a partir de una mezcla compleja de frameworks de desarrollo, bibliotecas, código existente y nuevo. También existen normativas modernas y en evolución sobre protección de datos que abordan la privacidad del usuario, y que pueden requerir cumplimiento con requisitos regionales o específicos del sector.

Estos factores hacen que los enfoques tradicionales de seguridad —como el control (de procesos, fuentes de código, entorno de ejecución, etc.), la inspección y las pruebas— sean mucho más difíciles. Además, el riesgo que una vulnerabilidad de la aplicación introduce podría no comprenderse, excepto en un contexto operativo específico.

Las vulnerabilidades pueden existir por múltiples razones: diseño inseguro, infraestructura insegura, errores de codificación, autenticación débil y falta de pruebas para condiciones inusuales o inesperadas. Los atacantes pueden explotar vulnerabilidades específicas, incluyendo desbordamientos de búfer, exposición a inyecciones de lenguaje SQL (SQLi), scripts entre sitios (XSS), falsificación de solicitudes entre sitios (CSRF) y secuestro de clics (clickjacking) para obtener acceso a datos sensibles o tomar control de activos vulnerables como punto de partida para ataques posteriores.

Las aplicaciones y los sitios web también pueden ser utilizados para recolectar credenciales, datos o intentar instalar malware en los usuarios que acceden a ellos.

Finalmente, hoy en día es común adquirir plataformas de Software como Servicio (SaaS), donde el software se desarrolla y gestiona completamente a través de un tercero. Estas pueden estar alojadas en cualquier parte del mundo. Esto presenta desafíos para las empresas que necesitan comprender los riesgos que están aceptando al usar estas plataformas; muchas veces no tienen visibilidad sobre las prácticas de desarrollo y seguridad de estas aplicaciones. Algunas de estas plataformas permiten la personalización de sus interfaces y bases de datos. Las empresas que extienden estas aplicaciones deben seguir este Control CIS, como si estuvieran realizando desarrollo personalizado desde cero.

Procedimientos y herramientas

Para la Versión 8, CIS colaboró con SAFECode para ayudar a desarrollar los procedimientos y Salvaguardas para este Control actualizado de Seguridad del Software de Aplicación. Sin embargo, este es un tema amplio en sí mismo, por lo que (siguiendo los principios generales de los Controles CIS), aquí nos enfocamos en las Salvaguardas más críticas. Estas se derivan de un documento complementario desarrollado por SAFECode, el cual proporciona un tratamiento más profundo del tema y es coherente con su cuerpo de contenido existente.

SAFECode desarrolló un enfoque de tres niveles para ayudar a los lectores a identificar en qué Grupo de Desarrollo (DG) se encuentra su empresa como escala de madurez para programas de desarrollo. Los tres niveles de IG (Implementation Groups) usados en las Salvaguardas de CIS inspiraron este enfoque:

Grupo de Desarrollo 1

La empresa depende en gran medida de software comercial o de código abierto (OSS) y paquetes, con adiciones ocasionales de pequeñas aplicaciones o sitios web. La empresa es capaz de aplicar buenas prácticas operativas y procedimentales básicas, y de gestionar la seguridad del software provisto por el proveedor siguiendo las guías de los Controles CIS.

Grupo de Desarrollo 2

La empresa depende de algunas aplicaciones personalizadas (desarrolladas internamente o por contratistas), integradas con componentes de terceros, y que se ejecutan localmente o en la nube. El personal de desarrollo aplica buenas prácticas de desarrollo de software. La empresa presta atención a la calidad y mantenimiento del código abierto o comercial del que depende.

Grupo de Desarrollo 3

La empresa realiza una inversión significativa en software personalizado, necesario para operar su negocio y servir a sus clientes. Puede alojar el software en su propia infraestructura, en la nube o en ambos, e integrar una amplia gama de componentes de software comerciales y de código abierto. Los proveedores de software y empresas que ofrecen SaaS deben considerar el Grupo de Desarrollo 3 como el conjunto mínimo de requisitos.

El primer paso en el desarrollo de un programa de seguridad de aplicaciones es implementar un proceso de gestión de vulnerabilidades. Este proceso debe integrarse al ciclo de vida del desarrollo y debe ser lo suficientemente liviano como para insertarse dentro del flujo normal de corrección de errores. El proceso debe incluir análisis de causa raíz para corregir fallas subyacentes, reduciendo así futuras vulnerabilidades, y una calificación de severidad para priorizar la remediación.

Los desarrolladores deben ser capacitados en conceptos de seguridad de aplicaciones y prácticas de codificación segura. Esto incluye un proceso para adquirir o evaluar software, módulos y bibliotecas de terceros usados en la aplicación, asegurándose de que no introduzcan fallas de seguridad. Se debe enseñar a los desarrolladores qué tipos de módulos pueden usar con seguridad, de dónde adquirirlos de forma segura y qué componentes pueden o no deben desarrollar ellos mismos (por ejemplo, cifrado).

Las debilidades en la infraestructura que soporta estas aplicaciones pueden introducir riesgos. Los Controles CIS y el concepto de minimizar la superficie de ataque pueden ayudar a asegurar redes, sistemas y cuentas utilizadas dentro de la aplicación. La guía específica puede encontrarse en los Controles CIS 1-7, 12 y 13.

El programa ideal de seguridad de aplicaciones introduce seguridad desde las primeras etapas del ciclo de desarrollo de software. La gestión de los problemas de seguridad debe ser coherente e integrarse con la gestión estándar de errores/fallas de software, y no ser un proceso separado que compita por recursos de desarrollo. Equipos de desarrollo más grandes o maduros deben considerar la práctica del modelado de amenazas en la fase de diseño. Las vulnerabilidades a nivel de diseño son menos comunes que las de nivel de código; sin embargo, a menudo son más graves y más difíciles de corregir rápidamente. El modelado de amenazas es el proceso de identificar y abordar fallas de diseño en la seguridad de la aplicación antes de que se cree el código. Requiere capacitación específica, conocimiento técnico y conocimiento del negocio. Lo ideal es que cada equipo de desarrollo cuente con “líderes de seguridad” internos que guíen las prácticas de modelado de amenazas para su software. Esto también proporciona un contexto valioso para actividades posteriores como el análisis de causa raíz y las pruebas de seguridad.

Los equipos de desarrollo más grandes o comerciales también pueden considerar un programa de recompensas por errores (bug bounty), donde se remunera a individuos por encontrar fallas en sus aplicaciones. Dicho programa debe complementar un proceso interno de desarrollo seguro y puede proporcionar un mecanismo eficaz para identificar clases de vulnerabilidades que requieren atención especial.

Finalmente, en 2020, NIST® publicó su Marco de Desarrollo de Software Seguro (SSDF), que recopiló las mejores prácticas aprendidas por la industria sobre seguridad de software durante las últimas dos décadas, y creó un marco para planificar, evaluar y comunicar actividades de seguridad de software. Las empresas que adquieren software o servicios pueden usar este marco para definir sus requisitos de seguridad y comprender si el proceso de desarrollo del proveedor sigue buenas prácticas. Algunos recursos sobre seguridad de aplicaciones incluyen:

- **SAFECode Application Security Addendum:** <https://safecode.org/cis-controls/>
- **NIST® SSDF:** <https://csrc.nist.gov/News/2020/mitigating-risk-of-software-vulns-ssdf>
- **The Software Alliance:** <https://www.bsa.org/reports/updated-bsa-framework-for-secure-software>
- **OWASP®:** <https://owasp.org/>

Salvaguardass

Salvaguardas 16.1: Establecer y Mantener un Proceso de Desarrollo Seguro de Aplicaciones

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Establecer y mantener un proceso de desarrollo seguro de aplicaciones. En dicho proceso se deben abordar elementos como: estándares de diseño seguro de aplicaciones, prácticas de codificación segura, capacitación de desarrolladores, gestión de vulnerabilidades, seguridad del código de terceros y procedimientos de pruebas de seguridad en las aplicaciones. Revisar y actualizar la documentación anualmente o cuando ocurran cambios significativos en la empresa que puedan afectar esta Salvaguarda.

Salvavidas 16.2: Establecer y Mantener un Proceso para Aceptar y Abordar Vulnerabilidades de Software

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Establecer y mantener un proceso para aceptar y abordar reportes de vulnerabilidades de software, incluyendo un medio para que entidades externas puedan reportarlas. Este proceso debe incluir elementos como: una política de manejo de vulnerabilidades que identifique el proceso de reporte, la parte responsable de gestionar los reportes, así como un proceso para la recepción, asignación, remediación y prueba de remediación. Como parte del proceso, se debe utilizar un sistema de seguimiento de vulnerabilidades que incluya calificaciones de severidad y métricas para medir el tiempo de identificación, análisis y remediación. Revisar y actualizar la documentación anualmente o cuando ocurran cambios significativos que puedan impactar esta Salvavidas.

Los desarrolladores de aplicaciones de terceros deben considerar esto como una política de cara al exterior que ayude a establecer expectativas con las partes interesadas externas.

Salvavidas 16.3: Realizar Análisis de Causa Raíz de las Vulnerabilidades de Seguridad

Tipo de Activo:	Software	Función de Seguridad:	Detectar	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Realizar análisis de causa raíz sobre las vulnerabilidades de seguridad. Al revisar las vulnerabilidades, el análisis de causa raíz consiste en evaluar los problemas subyacentes que crean vulnerabilidades en el código, y permite que los equipos de desarrollo vayan más allá de simplemente corregir vulnerabilidades individuales a medida que surgen.

Salvavidas 16.4: Establecer y Gestionar un Inventario de Componentes de Software de Terceros

Tipo de Activo:	Software	Función de Seguridad:	Identificar	IG2	IG3
-----------------	----------	-----------------------	-------------	-----	-----

Establecer y gestionar un inventario actualizado de componentes de terceros utilizados en el desarrollo, conocido como “lista de materiales”, así como de componentes destinados a uso futuro. Este inventario debe incluir los riesgos potenciales que cada componente de terceros puede representar. Evaluar la lista al menos mensualmente para identificar cualquier cambio o actualización en estos componentes, y validar que el componente aún cuente con soporte.

Salvaguardas 16.5: Usar Componentes de Software de Terceros Confiables y Actualizados

Tipo de Activo:	Software	Función de Seguridad:	Proteger	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Usar componentes de software de terceros que sean confiables y estén actualizados. Cuando sea posible, elegir frameworks y bibliotecas establecidos y comprobados que ofrezcan una seguridad adecuada. Adquirir estos componentes de fuentes confiables o evaluar el software en busca de vulnerabilidades antes de su uso.

Salvaguardas 16.6: Establecer y Mantener un Sistema de Clasificación de Severidad y un Proceso para las Vulnerabilidades de Aplicaciones

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Establecer y mantener un sistema de clasificación de severidad y un proceso para las vulnerabilidades de las aplicaciones que facilite priorizar el orden en que se corrigen las vulnerabilidades detectadas. Este proceso incluye establecer un nivel mínimo de aceptabilidad de seguridad para liberar código o aplicaciones. Las clasificaciones de severidad permiten una manera sistemática de priorizar vulnerabilidades, mejorando la gestión del riesgo y ayudando a garantizar que los errores más graves se corrijan primero. Revisar y actualizar el sistema y el proceso anualmente.

Salvaguardas 16.7: Utilizar Plantillas Estándar de Configuración Reforzada para la Infraestructura de Aplicaciones

Tipo de Activo:	Software	Función de Seguridad:	Proteger	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Utilizar plantillas estándar de configuración reforzada recomendadas por la industria para los componentes de la infraestructura de aplicaciones. Esto incluye servidores, bases de datos y servidores web subyacentes, y se aplica también a contenedores en la nube, componentes de Plataforma como Servicio (PaaS) y componentes de Software como Servicio (SaaS). No permitir que el software desarrollado internamente debilite la configuración reforzada.

Salvaguardas 16.8: Separar los Sistemas de Producción y No Producción

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Mantener entornos separados para los sistemas de producción y los de no producción.

Salvaguardas 16.9: Capacitar a los Desarrolladores en Conceptos de Seguridad de Aplicaciones y Codificación Segura

Tipo de Activo:	Usuarios	Función de Seguridad:	Proteger	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Asegurar que todo el personal de desarrollo de software reciba capacitación para escribir código seguro dentro de su entorno de desarrollo y responsabilidades específicas. La capacitación puede incluir principios generales de seguridad y prácticas estándar de seguridad en aplicaciones. Realizar la capacitación al menos una vez al año, diseñada para promover la seguridad dentro del equipo de desarrollo y fomentar una cultura de seguridad entre los desarrolladores.

Salvaguardas 16.10: Aplicar Principios de Diseño Seguro en la Arquitectura de Aplicaciones

Tipo de Activo:	Software	Función de Seguridad:	Proteger	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Aplicar principios de diseño seguro en la arquitectura de las aplicaciones. Los principios de diseño seguro incluyen el concepto de menor privilegio y el refuerzo de la mediación para validar cada operación realizada por el usuario, promoviendo el concepto de “nunca confíes en la entrada del usuario”. Ejemplos incluyen asegurar que se realice y documente la validación explícita de errores para toda entrada, considerando tamaño, tipo de datos y rangos o formatos aceptables. El diseño seguro también implica minimizar la superficie de ataque de la infraestructura de la aplicación, como desactivar puertos y servicios no protegidos, eliminar programas y archivos innecesarios, y renombrar o eliminar cuentas predeterminadas.

Salvaguardas 16.11: Utilizar Módulos o Servicios Verificados para Componentes de Seguridad de Aplicaciones

Tipo de Activo:	Software	Función de Seguridad:	Proteger	IG2	IG3
-----------------	----------	-----------------------	----------	-----	-----

Utilizar módulos o servicios verificados para los componentes de seguridad de aplicaciones, como gestión de identidades, cifrado, auditoría y registro de eventos. Usar características de la plataforma en funciones críticas de seguridad reducirá la carga de trabajo de los desarrolladores y minimizará la probabilidad de errores de diseño o implementación. Los sistemas operativos modernos proporcionan mecanismos eficaces para la identificación, autenticación y autorización, y hacen que esos mecanismos estén disponibles para las aplicaciones. Usar únicamente algoritmos de cifrado estandarizados, actualmente aceptados y ampliamente revisados. Los sistemas operativos también ofrecen mecanismos para crear y mantener registros de auditoría seguros.

Salvaviduas 16.12: Implementar Verificaciones de Seguridad a Nivel de Código

Tipo de Activo:	Software	Función de Seguridad:	Proteger	IG3
-----------------	----------	-----------------------	----------	-----

Aplicar herramientas de análisis estático y dinámico dentro del ciclo de vida de la aplicación para verificar que se sigan las prácticas de codificación segura.

Salvaviduas 16.13: Realizar Pruebas de Penetración en Aplicaciones

Tipo de Activo:	Software	Función de Seguridad:	Detectar	IG3
-----------------	----------	-----------------------	----------	-----

Realizar pruebas de penetración en aplicaciones. Para aplicaciones críticas, las pruebas de penetración autenticadas son más adecuadas para encontrar vulnerabilidades de lógica empresarial que los escaneos de código y las pruebas de seguridad automatizadas. Las pruebas de penetración dependen de la habilidad del evaluador para manipular manualmente una aplicación como usuario autenticado y no autenticado.

Salvaviduas 16.14: Realizar Modelado de Amenazas

Tipo de Activo:	Software	Función de Seguridad:	Proteger	IG3
-----------------	----------	-----------------------	----------	-----

Realizar modelado de amenazas. El modelado de amenazas es el proceso de identificar y abordar fallas de diseño en la seguridad de una aplicación antes de que se cree el código. Se lleva a cabo mediante personas especialmente capacitadas que evalúan el diseño de la aplicación y miden los riesgos de seguridad para cada punto de entrada y nivel de acceso. El objetivo es mapear la aplicación, su arquitectura e infraestructura de manera estructurada para comprender sus debilidades.

Gestión de Respuesta ante Incidentes

Salvaguardass: 9	IG1: 3/9	IG2: 8/9	IG3: 9/9
------------------	----------	----------	----------

Descripción general

Establecer un programa para desarrollar y mantener una capacidad de respuesta ante incidentes (por ejemplo, políticas, planes, procedimientos, roles definidos, capacitación y comunicaciones) para prepararse, detectar y responder rápidamente a un ataque.

¿Por qué es crítico este Control?

Un programa integral de ciberseguridad incluye capacidades de protección, detección, respuesta y recuperación. Con frecuencia, los dos últimos aspectos son ignorados en empresas con programas de seguridad inmaduros, o la técnica de respuesta ante sistemas comprometidos se limita a restaurarlos a su estado original y continuar. El objetivo principal de la respuesta ante incidentes es identificar amenazas en la empresa, responder antes de que puedan propagarse y remediarlas antes de que causen daño. Si no se entiende el alcance completo de un incidente, cómo ocurrió y qué puede hacerse para prevenirlo en el futuro, los defensores caerán en un ciclo perpetuo de “golpear al topo”.

No podemos esperar que nuestras medidas de protección sean efectivas el 100 % del tiempo. Cuando ocurre un incidente, si la empresa no cuenta con un plan documentado —aunque cuente con personal capacitado— será casi imposible conocer los procedimientos adecuados de investigación, reporte, recopilación de datos, responsabilidades de gestión, protocolos legales y estrategia de comunicación que le permitan comprender, gestionar y recuperarse exitosamente del incidente.

Junto con la detección, contención y erradicación, la comunicación con las partes interesadas es clave. Si queremos reducir la probabilidad de un impacto significativo debido a un evento cibernético, los líderes de la empresa deben conocer el impacto potencial, de modo que puedan priorizar las decisiones de remediación o restauración que mejor respalden a la organización. Estas decisiones comerciales pueden basarse en el cumplimiento normativo, reglas de divulgación, acuerdos de nivel de servicio con socios o clientes, ingresos o el impacto en la misión.

El tiempo de permanencia, desde que ocurre un ataque hasta que se detecta, puede ser de días, semanas o meses. Cuanto más tiempo permanezca el atacante dentro de la infraestructura de la empresa, más incrustado estará y desarrollará más formas de mantener acceso persistente una vez que sea finalmente descubierto. Con el auge del ransomware —una fuente de ingresos estable para los atacantes— este tiempo de permanencia es crítico, especialmente con tácticas modernas que implican el robo de datos antes de cifrarlos para exigir un rescate.

Procedimientos y herramientas

Incluso si una empresa no cuenta con recursos internos para realizar una respuesta ante incidentes, sigue siendo fundamental contar con un plan documentado. Este debe incluir las fuentes de protección y detección, una lista de contactos a quienes recurrir para recibir asistencia y planes de comunicación sobre cómo transmitir información al liderazgo, empleados, reguladores, socios y clientes.

Después de definir los procedimientos de respuesta ante incidentes, el equipo de respuesta —o un tercero— debe participar en entrenamientos periódicos basados en escenarios, trabajando sobre una serie de situaciones ajustadas a las amenazas y posibles impactos que enfrenta la empresa. Estos escenarios ayudan a asegurar que el liderazgo empresarial y los miembros técnicos comprendan su rol en el proceso de respuesta ante incidentes, y los preparen para manejar situaciones reales. Es inevitable que estos ejercicios y entrenamientos revelen brechas en los planes y procesos, así como dependencias inesperadas, que pueden actualizarse en el plan.

Las empresas más maduras deben incluir inteligencia de amenazas y/o búsqueda proactiva de amenazas (“threat hunting”) en su proceso de respuesta ante incidentes. Esto ayudará al equipo a ser más proactivo, identificando atacantes clave o primarios en su empresa o industria para monitorear o buscar sus técnicas, tácticas y procedimientos (TTP). Esto permitirá enfocar las detecciones y definir procedimientos de respuesta que permitan identificar y remediar más rápidamente.

Las acciones del Control 17 de los CIS proporcionan pasos específicos de alta prioridad que pueden mejorar la seguridad de la empresa y deben formar parte de cualquier plan integral de respuesta ante incidentes. Además, se recomienda el siguiente recurso dedicado a este tema:

- Council of Registered Security Testers (CREST) – Guía de Respuesta ante Incidentes de Ciberseguridad: CREST proporciona orientación, estándares y conocimiento sobre una amplia variedad de temas de defensa cibernética. <https://www.crest-approved.org/wp-content/uploads/2022/04/CSIR-Procurement-Guide-1.pdf>

Salvaguardass

Salvaguardas 17.1: Designar Personal para Gestionar el Manejo de Incidentes

Tipo de Activo:	Usuarios	Función de Seguridad:	Responder	IG1	IG2	IG3
-----------------	----------	-----------------------	-----------	-----	-----	-----

Designar a una persona clave, y al menos un respaldo, que se encargue del proceso de manejo de incidentes de la empresa. El personal de gestión es responsable de coordinar y documentar los esfuerzos de respuesta y recuperación ante incidentes, y puede estar compuesto por empleados internos de la empresa, proveedores de servicios o un enfoque híbrido. Si se utiliza un proveedor de servicios, se debe designar al menos a una persona interna de la empresa para supervisar el trabajo de terceros. Revisar anualmente o cuando ocurran cambios significativos en la empresa que puedan impactar esta Salvaguarda.

Salvaguardas 17.2: Establecer y Mantener Información de Contacto para Reportar Incidentes de Seguridad

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y mantener información de contacto para las partes que deben ser informadas sobre incidentes de seguridad. Los contactos pueden incluir personal interno, proveedores de servicios, autoridades policiales, proveedores de seguros cibernéticos, agencias gubernamentales relevantes, socios de Centros de Intercambio y Análisis de Información (ISAC), u otras partes interesadas. Verificar los contactos anualmente para asegurar que la información esté actualizada.

Salvaguardas 17.3: Establecer y Mantener un Proceso Empresarial para Reportar Incidentes

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG1	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----	-----

Establecer y mantener un proceso empresarial documentado para que el personal reporte incidentes de seguridad. El proceso debe incluir el plazo de reporte, a quién se debe informar, el mecanismo de reporte y la información mínima que se debe proporcionar. Asegurar que el proceso esté disponible públicamente para toda la fuerza laboral. Revisar anualmente o cuando ocurran cambios significativos en la empresa que puedan impactar esta Salvaguarda.

Salvaguardas 17.4: Establecer y Mantener un Proceso de Respuesta ante Incidentes

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Establecer y mantener un proceso documentado de respuesta ante incidentes que contemple roles y responsabilidades, requisitos de cumplimiento normativo y un plan de comunicación. Revisar anualmente o cuando ocurran cambios significativos en la empresa que puedan impactar esta Salvaguarda.

Salvavidas 17.5: Asignar Roles y Responsabilidades Clave

Tipo de Activo:	Usuarios	Función de Seguridad:	Responder	IG2	IG3
-----------------	----------	-----------------------	-----------	-----	-----

Asignar roles y responsabilidades clave para la respuesta ante incidentes, incluyendo personal de los departamentos legal, TI, seguridad de la información, instalaciones, relaciones públicas, recursos humanos, respondedores de incidentes, analistas y terceros relevantes. Revisar anualmente o cuando ocurran cambios significativos en la empresa que puedan impactar esta Salvavidas.

Salvavidas 17.6: Definir Mecanismos para la Comunicación Durante la Respuesta ante Incidentes

Tipo de Activo:	Usuarios	Función de Seguridad:	Responder	IG2	IG3
-----------------	----------	-----------------------	-----------	-----	-----

Determinar cuáles serán los mecanismos primarios y secundarios que se utilizarán para comunicarse y reportar durante un incidente de seguridad. Los mecanismos pueden incluir llamadas telefónicas, correos electrónicos, chat seguro o cartas de notificación. Tener en cuenta que ciertos mecanismos, como los correos electrónicos, pueden verse afectados durante un incidente de seguridad. Revisar anualmente o cuando ocurran cambios significativos en la empresa que puedan impactar esta Salvavidas.

Salvavidas 17.7: Realizar Ejercicios de Respuesta ante Incidentes de Forma Rutinaria

Tipo de Activo:	Usuarios	Función de Seguridad:	Recuperar	IG2	IG3
-----------------	----------	-----------------------	-----------	-----	-----

Planificar y ejecutar ejercicios y escenarios rutinarios de respuesta ante incidentes para el personal clave involucrado en el proceso, con el fin de prepararlos para responder ante incidentes reales. Los ejercicios deben evaluar los canales de comunicación, la toma de decisiones y los flujos de trabajo. Realizar las pruebas al menos una vez al año.

Salvavidas 17.8: Realizar Revisiones Posteriores a los Incidentes

Tipo de Activo:	Usuarios	Función de Seguridad:	Recuperar	IG2	IG3
-----------------	----------	-----------------------	-----------	-----	-----

Realizar revisiones posteriores a los incidentes. Estas revisiones ayudan a prevenir la recurrencia de incidentes mediante la identificación de lecciones aprendidas y acciones de seguimiento.

Salvaguardas 17.9: Establecer y Mantener Umbrales para Incidentes de Seguridad

Tipo de Activo:	Documentación	Función de Seguridad:	Recuperar	IG3
-----------------	---------------	-----------------------	-----------	-----

Establecer y mantener umbrales para incidentes de seguridad, incluyendo, como mínimo, la diferenciación entre un incidente y un evento. Ejemplos pueden incluir: actividad anormal, vulnerabilidad de seguridad, debilidad de seguridad, filtración de datos, incidente de privacidad, etc. Revisar anualmente o cuando ocurran cambios significativos en la empresa que puedan impactar esta Salvaguarda.

CONTROL 18

Pruebas de Penetración

Salvaguardass: 5	IG1: 0/5	IG2: 3/5	IG3: 5/5
------------------	----------	----------	----------

Descripción general

Probar la eficacia y resiliencia de los activos empresariales mediante la identificación y explotación de debilidades en los controles (personas, procesos y tecnología), y simular los objetivos y acciones de un atacante.

¿Por qué es crítico este Control?

Una postura defensiva exitosa requiere un programa integral compuesto por políticas y gobernanza eficaces, defensas técnicas sólidas y una acción adecuada por parte de las personas. Sin embargo, rara vez es perfecta. En un entorno complejo donde la tecnología evoluciona constantemente y aparecen nuevas técnicas de ataque con regularidad, las empresas deben probar periódicamente sus controles para identificar brechas y evaluar su resiliencia. Esta prueba puede realizarse desde una perspectiva de red externa, red interna, aplicación, sistema o dispositivo. También puede incluir ingeniería social hacia los usuarios o eludir controles de acceso físico.

A menudo, las pruebas de penetración se realizan con fines específicos:

- Como una demostración “contundente” de un ataque, usualmente para convencer a los responsables de la toma de decisiones sobre las debilidades de su empresa.
- Como medio para probar el funcionamiento correcto de las defensas empresariales (“verificación”)
- Para verificar que la empresa haya construido las defensas adecuadas desde el principio (“validación”)

Las pruebas de penetración independientes pueden ofrecer perspectivas valiosas y objetivas sobre la existencia de vulnerabilidades en los activos y en las personas, y sobre la eficacia de las defensas y controles de mitigación para proteger contra impactos negativos en la empresa. Son parte de un programa continuo de gestión y mejora de la seguridad. También pueden revelar debilidades en los procesos, como una gestión de configuración incompleta o inconsistente, o deficiencias en la capacitación de los usuarios finales.

Las pruebas de penetración difieren de las pruebas de vulnerabilidad descritas en el Control CIS. Las pruebas de vulnerabilidad simplemente verifican la presencia de activos empresariales inseguros conocidos y se detienen ahí. Las pruebas de penetración van más allá, explotando esas debilidades para ver hasta dónde podría llegar un atacante y qué procesos empresariales o datos podrían verse afectados por la explotación de dicha vulnerabilidad. Este es un detalle importante, y a menudo se utilizan incorrectamente como sinónimos. Las pruebas de vulnerabilidad consisten exclusivamente en escaneos automatizados con validaciones manuales ocasionales de falsos positivos, mientras que las pruebas de penetración requieren más participación humana y análisis, a veces apoyados con herramientas o scripts personalizados. Sin embargo, las pruebas de vulnerabilidad suelen ser el punto de partida de una prueba de penetración.

Otro término común es “ejercicios de Red Team”. Estos son similares a las pruebas de penetración en cuanto a que se explotan vulnerabilidades; sin embargo, la diferencia radica en el enfoque. Los Red Teams simulan tácticas, técnicas y procedimientos (TTP) específicos de atacantes para evaluar cómo resistiría el entorno empresarial un ataque por parte de un adversario concreto o de una categoría de adversarios.

Procedimientos y herramientas

Las pruebas de penetración comienzan con el reconocimiento de la empresa y su entorno, seguido de escaneos para identificar vulnerabilidades que puedan servir como puntos de entrada a la empresa. Es importante asegurarse de que se descubran todos los activos empresariales que estén dentro del alcance, y no solo confiar en una lista estática que podría estar desactualizada o incompleta. A continuación, se identifican las vulnerabilidades en estos objetivos. Se ejecutan exploits sobre estas vulnerabilidades para demostrar específicamente cómo un adversario puede subvertir los objetivos de seguridad de la empresa (por ejemplo, la protección de datos sensibles) o alcanzar objetivos específicos del atacante (por ejemplo, establecer una infraestructura encubierta de Comando y Control - C2). Los resultados proporcionan información más profunda, mediante la demostración, sobre los riesgos empresariales de diversas vulnerabilidades. Esto puede aplicarse a controles de acceso físico, redes, sistemas o capas de aplicaciones, e incluso incluir componentes de ingeniería social.

Las pruebas de penetración son costosas, complejas y pueden introducir sus propios riesgos. Deben ser realizadas por personas con experiencia de proveedores reputados. Algunos riesgos incluyen la interrupción inesperada de sistemas que podrían ser inestables, exploits que podrían eliminar o corromper datos o configuraciones, y los informes de las pruebas que deben ser protegidos, ya que contienen instrucciones paso a paso para infiltrarse en la empresa y atacar activos o datos críticos.

Cada empresa debe definir claramente el alcance y las reglas de participación para las pruebas de penetración. El alcance de estos proyectos debe incluir, como mínimo, los activos empresariales que contienen la información de mayor valor y funcionalidades críticas en producción. También se pueden probar sistemas de menor valor para verificar si pueden ser utilizados como puntos de pivote para comprometer objetivos de mayor valor. Las reglas de participación deben describir, como mínimo, los horarios para realizar las pruebas, su duración y el enfoque general. Solo unas pocas personas dentro de la empresa deben saber cuándo se realiza una prueba de penetración, y debe designarse un punto de contacto principal en caso de que surjan problemas. Es cada vez más común realizar pruebas de penetración a través de un abogado externo, con el fin de proteger el informe de la prueba de divulgaciones legales.

Las Salvaguardas de este Control CIS proporcionan pasos específicos de alta prioridad que pueden mejorar la seguridad de la empresa, y deben ser parte de cualquier prueba de penetración. Además, se recomienda utilizar algunos de los excelentes recursos dedicados a este tema para apoyar la planificación, gestión y generación de informes de pruebas de seguridad:

- Metodologías de Pruebas de Penetración de OWASP: https://www.owasp.org/index.php/Penetration_testing_methodologies
- Consejo de Normas de Seguridad de PCI: https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf

Salvaguardass

Salvaguardas 18.1: Establecer y Mantener un Programa de Pruebas de Penetración

Tipo de Activo:	Documentación	Función de Seguridad:	Gobernar	IG2	IG3
-----------------	---------------	-----------------------	----------	-----	-----

Establecer y mantener un programa de pruebas de penetración adecuado al tamaño, complejidad, industria y nivel de madurez de la empresa. Las características del programa de pruebas de penetración incluyen el alcance (por ejemplo, red, aplicaciones web, interfaces de programación de aplicaciones (API), servicios alojados y controles físicos del recinto); frecuencia; limitaciones (como horarios aceptables y tipos de ataques excluidos); información de contacto; remediación (por ejemplo, cómo se distribuirán internamente los hallazgos); y requisitos retrospectivos.

Salvaguardas 18.2: Realizar Pruebas de Penetración Externas Periódicas

Tipo de Activo:	Red	Función de Seguridad:	Detectar	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Realizar pruebas de penetración externas periódicas de acuerdo con los requisitos del programa, al menos una vez al año. Las pruebas de penetración externas deben incluir actividades de reconocimiento empresarial y del entorno para detectar información explotable. Las pruebas de penetración requieren habilidades y experiencia especializadas, y deben ser realizadas por una parte calificada. Las pruebas pueden realizarse en modalidad de caja blanca o caja negra.

Salvaguardas 18.3: Remediar los Hallazgos de las Pruebas de Penetración

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG2	IG3
-----------------	-----	-----------------------	----------	-----	-----

Remediar los hallazgos de las pruebas de penetración conforme al proceso documentado de remediación de vulnerabilidades de la empresa. Esto debe incluir la determinación de una línea de tiempo y el nivel de esfuerzo requerido, en función del impacto y la priorización de cada hallazgo identificado.

Salvaguardas 18.4: Validar las Medidas de Seguridad

Tipo de Activo:	Red	Función de Seguridad:	Proteger	IG3
-----------------	-----	-----------------------	----------	-----

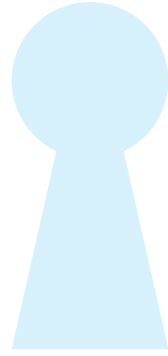
Validar las medidas de seguridad después de cada prueba de penetración. Si se considera necesario, modificar las reglas y capacidades para detectar las técnicas utilizadas durante la prueba.

Salvaguardas 18.5: Realizar Pruebas de Penetración Internas Periódicas

Tipo de Activo:	Red	Función de Seguridad:	Detectar	IG3
-----------------	-----	-----------------------	----------	-----

Realizar pruebas de penetración internas periódicas de acuerdo con los requisitos del programa, al menos una vez al año. Las pruebas pueden realizarse en modalidad de caja blanca o caja negra.

Apéndice



Acrónimos y Abreviaciones

AAA	Autenticación, Autorización y Auditoría	CVE	Vulnerabilidades y Exposiciones Comunes (Common Vulnerabilities and Exposures)
ACL	Lista de Control de Acceso	CVSS	Sistema de Puntuación de Vulnerabilidad Común (Common Vulnerability Scoring System)
AD	Active Directory	DBIR	Informe de Investigaciones de Violación de Datos (Data Breach Investigations Report)
AoC	Declaración de Cumplimiento (Attestation of Compliance)	DEP	Prevención de Ejecución de Datos (Data Execution Prevention)
API	Interfaz de Programación de Aplicaciones (Application Programming Interface)	DG	Grupo de Desarrollo (Development Group)
BEC	Compromiso de Correo Electrónico Empresarial (Business Email Compromise)	DHCP	Protocolo de Configuración Dinámica de Host (Dynamic Host Configuration Protocol)
C2	Comando y Control (Command and Control)	DKIM	Correo Identificado con Claves de Dominio (DomainKeys Identified Mail)
CCE	Enumeración Común de Configuración (Common Configuration Enumeration)	DLP	Prevención de Pérdida de Datos (Data Loss Prevention)
CDM	Modelo de Defensa Comunitaria (Community Defense Model)	DMARC	Autenticación de Mensajes Basada en Dominio, Reportes y Conformidad (Domain-based Message Authentication, Reporting, and Conformance)
CIA	Confidencialidad, Integridad y Disponibilidad	DMS	Sistema de Gestión de Bases de Datos (Database Management System)
CIS	Centro para la Seguridad de Internet (Center for Internet Security)	DNS	Sistema de Nombres de Dominio (Domain Name System)
CIS-CAT	Herramienta de Evaluación de Configuración CIS (CIS Configuration Assessment Tool)	DPI	Inspección Profunda de Paquetes (Deep Packet Inspection)
COTS	Software Comercial Listo para Usarse (Commercial off-the-Shelf)	EDR	Detección y Respuesta en el Punto Final (Endpoint Detection and Response)
CPE	Enumeración Común de Plataformas (Common Platform Enumeration)	EOL	Fin de Vida Útil (End of Life)
CREST	Consejo de Evaluadores de Seguridad Registrados (Council of Registered Security Testers)	FFIEC	Consejo de Examinadores de Instituciones Financieras Federales (Federal Financial Institutions Examination Council)
CSA	Alianza de Seguridad en la Nube (Cloud Security Alliance)		
CSP	Proveedor de Servicios en la Nube (Cloud Service Provider)		

FIRST	Foro de Equipos de Respuesta ante Incidentes y Seguridad (Forum of Incident Response and Security Teams, Inc.)
FISMA	Ley de Modernización de Seguridad de la Información Federal (Federal Information Security Modernization Act)
GRC	Gobernanza, Riesgo y Cumplimiento (Governance Risk and Compliance)
HECVAT	Herramienta de Evaluación de Proveedores de la Comunidad de Educación Superior (Higher Education Community Vendor Assessment Toolkit)
HIPAA	Ley de Portabilidad y Responsabilidad del Seguro de Salud (Health Insurance Portability and Accountability Act)
HTTP	Protocolo de Transferencia de Hipertexto (Hypertext Transfer Protocol)
HTTPS	Protocolo Seguro de Transferencia de Hipertexto (Hypertext Transfer Protocol Secure)
IaaS	Infraestructura como Servicio (Infrastructure as a Service)
IaC	Infraestructura como Código (Infrastructure as Code)
IAM	Gestión de Identidad y Acceso (Identity and Access Management)
IDS	Sistema de Detección de Intrusos (Intrusion Detection System)
IG	Grupo de Implementación (Implementation Group)
IOCs	Indicadores de Compromiso (Indicators of Compromise)
IoT	Internet de las Cosas (Internet of Things)
IP	Internet Protocol
IPS	Sistema de Prevención de Intrusos (Intrusion Prevention System)
ISAC	Centro de Compartición y Análisis de Información (Information Sharing and Analysis Center)

ISO	Organización Internacional de Normalización (International Organization for Standardization)
IT	Tecnologías de la Información (Information Technology)
LotL	Vivir de la Tierra (Living off the Land)
MDM	Gestión de Dispositivos Móviles (Mobile Device Management)
MFA	Autenticación Multifactor (Multi-Factor Authentication)
MITRE ATT&CK	Tácticas, Técnicas y Conocimientos Comunes de Adversarios de MITRE (MITRE Adversarial Tactics, Techniques, and Common Knowledge®)
MS-ISAC	Centro Multiestatal de Compartición y Análisis de Información (Multi-State Information Sharing and Analysis Center)
NaaS	Red como Servicio (Network as a Service)
NCSA	Alianza Nacional de Ciberseguridad (National Cyber Security Alliance)
NIDS	Sistema de Detección de Intrusiones en la Red (Network Intrusion Detection System)
NIST	Instituto Nacional de Estándares y Tecnología (National Institute of Standards and Technology)
OS	Sistema Operativo (Operating System)
OSS	Software de Código Abierto (Open Source Software)
OVAL	Lenguaje de Evaluación y Vulnerabilidad Abierta (Open Vulnerability and Assessment Language)
OWASP	Proyecto Abierto de Seguridad de Aplicaciones Web (Open Web Application Security Project)
PaaS	Plataforma como Servicio (Platform as a Service)
PAM	Gestión de Accesos con Privilegios (Privileged Access Management)
PCI	Industria de Tarjetas de Pago (Payment Card Industry)

SaaS	Software como Servicio (Software as a Service)
SAFECode	Foro de Aseguramiento de Software para la Excelencia en el Código (Software Assurance Forum for Excellence in Code)
SCADA	Control de Supervisión y Adquisición de Datos (Supervisory Control and Data Acquisition)
SIEM	Gestión de Información y Eventos de Seguridad (Security Information and Event Management)
SIP	Protección de Integridad del Sistema (System Integrity Protection)
SMS	Servicio de Mensajes Cortos (Short Messaging Service)
SOC	Centro de Operaciones de Seguridad (Security Operations Center)
SOC 2	Control de Organización de Servicio Tipo 2 (Service Organization Control 2)
SPF	Marco de Políticas del Remitente (Sender Policy Framework)

SQL	Lenguaje de Consulta Estructurada (Structured Query Language)
SSDF	Marco de Desarrollo de Software Seguro (Secure Software Development Framework)
SSH	Shell Seguro (Secure Shell)
SSO	Inicio de Sesión Único (Single Sign-On)
Telnet	Red de Teléfonos de Escritura (Teletype Network)
TLS	Seguridad de la Capa de Transporte (Transport Layer Security)
TTPs	Tácticas, Técnicas y Procedimientos
U.K.	Reino Unido
URL	Localizador Uniforme de Recursos (Uniform Resource Locator)
USB	Bus Universal en Serie (Universal Serial Bus)
VPN	Red Privada Virtual (Virtual Private Network)
WDEG	Protección contra Explotaciones de Windows Defender (Windows Defender Exploit Guard)
WPA2	Acceso Protegido Wi-Fi 2 (Wi-Fi Protected Access 2)
XCCDF	Formato Extensible de Descripción de Listas de Verificación de Configuración (Extensible Configuration Checklist Description Format)

Registro de Cambios

Dos versiones menores (v8.1.1 – agosto de 2024 y v8.1.2 – marzo de 2025) han dado lugar a los siguientes cambios:

- Corrección de algunos errores tipográficos menores en nuestra sección de Clases de Activos (pág. 8) y en el Glosario (Apéndice A3)
- Actualización de hipervínculos en todo el documento, basada en la reciente publicación de la página de Recursos de los Controles CIS
- Corrección de dos errores tipográficos en Funciones de Seguridad – Salvaguardas 16.11 (Proteger) y 16.13 (Detectar)
- Corrección de algunos errores tipográficos menores en las Salvaguardas 5.1, 8.9, 11.1, 16.11 y 17.5.

Glosario

Accounts (Cuentas)

Un perfil, identidad o membresía creada para una persona, grupo o entidad de máquina que otorga acceso a recursos o funcionalidades dentro de un sistema informático o red. Un sistema de cuentas es importante para gestionar permisos y niveles de seguridad en toda la empresa. Una persona puede tener acceso a múltiples cuentas dependiendo de su rol laboral y requerimientos de seguridad. Las cuentas de usuario están destinadas a usuarios individuales y se ajustan a las tareas específicas que requieren sus funciones y responsabilidades. Las cuentas de usuario, de administrador y de servicio son subconjuntos de cuentas.

Administrator accounts (Cuentas de administrador)

Cuentas para usuarios que requieren privilegios elevados. Estas cuentas se utilizan para administrar aspectos de una computadora, dominio o toda la infraestructura de tecnologías de la información (TI) de la empresa. Cada cuenta de administrador debe asignarse a un único usuario. Los subtipos comunes incluyen cuentas root, administrador local, administrador de dominio y cuentas de administrador de dispositivos de red o de seguridad.

Application Programming Interface (API) (Interfaz de Programación de Aplicaciones)

Conjunto de reglas e interfaces que permiten la interacción estandarizada entre componentes de software. Las APIs permiten que las aplicaciones accedan y se comuniquen con recursos internos y externos.

Applications (Aplicaciones)

Un programa o conjunto de programas que se ejecutan sobre un sistema operativo alojado en un activo empresarial. Ejemplos de tipos de aplicaciones incluyen aplicaciones web, de base de datos, en la nube y móviles. En este documento, las aplicaciones se consideran activos de software.

Asset Class (Clase de Activo)

Grupo de activos de información que se evalúan como un conjunto con base en su similitud. Ejemplos incluyen dispositivos, software, datos, usuarios, red y documentación.

Authentication systems (Sistemas de autenticación)

Sistema o mecanismo utilizado para identificar a un usuario asociando una solicitud entrante con un conjunto de credenciales de identificación. Las credenciales proporcionadas se comparan con las registradas en una base de datos del sistema operativo local, un servicio de directorio de usuarios o un servidor de autenticación. Ejemplos incluyen Active Directory, autenticación multifactor (MFA), biometría y tokens.

Authorization systems (Sistemas de autorización)

Sistema o mecanismo utilizado para determinar niveles de acceso o privilegios de usuario/cliente en relación con recursos del sistema, incluidos archivos, servicios, programas informáticos, datos y funciones de aplicaciones. Un sistema de autorización concede o deniega acceso a un recurso en función de la identidad del usuario. Ejemplos incluyen Active Directory, listas de control de acceso (ACL) y control de acceso basado en roles (RBAC).

Bi-annually (Bianualmente)

Cada seis meses. Las tareas que deban realizarse bianualmente también deben repetirse siempre que ocurra un cambio significativo que afecte la red o los dispositivos en cuestión, como actualizaciones de hardware o fusiones y adquisiciones.

Breach (Violación de seguridad)

Pérdida de control, compromiso, divulgación no autorizada, adquisición no autorizada o cualquier hecho similar en el cual una persona no autorizada accede o potencialmente accede a información confidencial o sensible, o un usuario autorizado accede a dicha información para fines no autorizados.

Cloud environment (Entorno en la nube)

Entorno virtualizado que proporciona acceso bajo demanda a una red compartida de recursos configurables, como red, computación, almacenamiento, aplicaciones y servicios. Las cinco características esenciales incluyen: autoservicio bajo demanda, acceso amplio a la red, agrupamiento de recursos, elasticidad rápida y servicio medido. Los servicios ofrecidos incluyen SaaS, PaaS e IaaS.

Data (Datos)

Conjunto de hechos que pueden ser examinados, considerados y utilizados para la toma de decisiones. Aunque los datos pueden ser físicos, los Controles CIS se centran en la protección de datos digitales que pueden almacenarse, transferirse y procesarse mediante activos empresariales.

Data Exposure (Exposición de datos)

Violación de datos no intencionada.

Database (Base de datos)

Colección organizada de datos almacenados y accedidos electrónicamente desde un sistema informático. Las bases de datos pueden residir de forma remota o local. Los sistemas de gestión de bases de datos (DMS) se utilizan para administrar las bases de datos y no se consideran parte de ellas para este documento.

Devices (Dispositivos)

Activos empresariales que procesan o almacenan datos, incluidos dispositivos de usuario final, dispositivos portátiles, móviles, servidores, dispositivos IoT y dispositivos que no realizan cómputo, dispositivos de red y medios removibles. Pueden encontrarse en espacios físicos, infraestructura virtual o en entornos en la nube.

Documentation (Documentación)

Material escrito (físico o digital) como políticas, procesos, procedimientos, planes, diagramas, etc. Ejemplos incluyen métodos de gobernanza, procesos de usuarios o descripciones de la arquitectura de red.

Dwell Time (Tiempo de permanencia)

Periodo entre un ataque inicial y la detección de una intrusión, durante el cual un atacante tiene acceso no autorizado al entorno y los datos.

End-user devices (Dispositivos de usuario final)

Activos de TI utilizados por los miembros de una empresa durante su jornada laboral o fuera de ella. Incluyen computadoras de escritorio, estaciones de trabajo, laptops, smartphones y tablets. Para este documento, se consideran un subconjunto de los activos empresariales.

Enterprise (Empresa)

Cualquier negocio u organización que utilice sistemas informáticos, redes y dispositivos.

Enterprise assets (Activos empresariales)

Activos con potencial de almacenar o procesar datos. Incluyen dispositivos de usuario final, dispositivos de red, dispositivos IoT y servidores, ya sean físicos, virtuales o en la nube.

Externally-exposed applications (Aplicaciones expuestas externamente)

Aplicaciones visibles públicamente y detectables mediante escaneo de red desde internet fuera de la red de la empresa.

Externally-exposed enterprise assets (Activos empresariales expuestos externamente)

Activos empresariales visibles públicamente y detectables mediante reconocimiento de DNS o escaneo de red desde internet fuera de la red de la empresa.

Firmware

Software almacenado en la memoria no volátil de un dispositivo, como ROM o memoria flash. Permite la comunicación entre el hardware y el sistema operativo. Su actualización generalmente ocurre fuera del proceso de actualización de sistema operativo o aplicaciones.

Govern (Gobernar)

Según la función de seguridad "Govern" del NIST CSF 2.0, implica establecer, comunicar y supervisar la estrategia de gestión de riesgos de ciberseguridad, expectativas y políticas de la organización. Informa lo que debe hacerse para lograr los resultados de otras funciones en el contexto de su misión y expectativas de las partes interesadas.

Hybrid environment (Entorno híbrido)

Entorno que utiliza una combinación de infraestructura de nube pública, nube privada y centros de datos locales para proporcionar servicios de TI. Permite que los datos y las aplicaciones se compartan entre ellos.

Internally-managed enterprise assets (Activos empresariales gestionados internamente)

Activos empresariales configurados y administrados por personal de la empresa o un proveedor contratado directamente por la empresa.

IoT devices (Dispositivos IoT)

Dispositivos físicos con la capacidad de conectarse a internet y comunicarse con otros dispositivos o sistemas. Los dispositivos IoT incluyen sensores, cámaras de vigilancia, electrodomésticos inteligentes y dispositivos portátiles.

Lifecycle (Ciclo de vida)

Fase completa de existencia de un activo, desde la adquisición e instalación, pasando por la operación y el mantenimiento, hasta la eliminación o retiro.

Mobile devices (Dispositivos móviles)

Dispositivos de usuario final que son portátiles y pueden acceder a redes inalámbricas. Incluyen smartphones, tablets, lectores electrónicos y dispositivos similares.

Network (Red)

Infraestructura que proporciona conectividad entre sistemas informáticos, dispositivos y otros recursos. Puede incluir switches, routers, puntos de acceso inalámbrico, firewalls y otros dispositivos relacionados.

Network infrastructure (Infraestructura de red)

Conjunto de dispositivos y servicios utilizados para habilitar la conectividad y comunicación entre sistemas. Incluye routers, switches, firewalls, puntos de acceso inalámbrico y otros componentes de hardware y software que gestionan el tráfico de red.

Offboarding (Proceso de desvinculación)

Proceso formal de retiro o terminación de una persona del entorno empresarial. Incluye revocar accesos, recuperar activos y archivar datos relacionados.

Onboarding (Proceso de incorporación)

Proceso formal de integración de una nueva persona al entorno empresarial. Incluye la creación de cuentas, asignación de dispositivos y capacitación en políticas y procedimientos.

Operating system (Sistema operativo)

Software que administra el hardware y software de un dispositivo. Proporciona servicios esenciales para ejecutar aplicaciones y controlar dispositivos. Ejemplos incluyen Microsoft Windows, macOS, Linux y Android.

Organization (Organización)

Término general que hace referencia a una empresa, agencia gubernamental, institución académica o cualquier otra entidad legal.

Patching (Aplicación de parches)

Proceso de aplicar actualizaciones de software a sistemas, aplicaciones o dispositivos para corregir vulnerabilidades de seguridad, mejorar funcionalidad o solucionar errores.

Policies (Políticas)

Declaraciones formales que definen principios, reglas y expectativas para guiar decisiones y acciones dentro de una organización.

Privilege escalation (Escalada de privilegios)

Técnica mediante la cual un atacante obtiene niveles de acceso más altos del que le fue originalmente otorgado, comprometiendo así sistemas o datos adicionales.

Privileged accounts (Cuentas privilegiadas)

Cuentas con niveles de acceso elevados que permiten realizar acciones administrativas en sistemas y redes. Pueden incluir cuentas de administrador, root o cuentas de servicio con acceso extendido.

Processes (Procesos)

Conjunto de actividades interrelacionadas que transforman entradas en salidas. Dentro de la ciberseguridad, pueden incluir procesos de gestión de incidentes, revisión de vulnerabilidades o auditorías de acceso.

Removable media (Medios removibles)

Dispositivos portátiles que se pueden conectar a un sistema informático para transferir datos. Incluyen unidades USB, discos duros externos, CD/DVD y tarjetas SD.

Risk (Riesgo)

Probabilidad de que una amenaza explote una vulnerabilidad y cause un impacto negativo. El riesgo se evalúa en función de la probabilidad y el impacto.

Role-based access control (Control de acceso basado en roles - RBAC)

Modelo de control de acceso en el que los permisos se asignan a roles y los usuarios reciben privilegios en función de su rol asignado.

Security Function (Función de Seguridad)

Categoría funcional de las Salvaguardas de los Controles CIS basada en el marco NIST CSF. Las funciones son: Gobernar (Govern), Identificar, Proteger, Detectar, Responder y Recuperar.

Security Function: Govern (Función de Seguridad: Gobernar)

Actividades de supervisión y establecimiento de políticas y expectativas para la gestión de riesgos de ciberseguridad.

Security Function: Identify (Función de Seguridad: Identificar)

Actividades para desarrollar una comprensión organizacional para gestionar el riesgo de ciberseguridad.

Security Function: Protect (Función de Seguridad: Proteger)

Actividades para implementar salvaguardas apropiadas para asegurar la prestación de servicios críticos.

Security Function: Detect (Función de Seguridad: Detectar)

Actividades para identificar la ocurrencia de un evento de ciberseguridad.

Security Function: Respond (Función de Seguridad: Responder)

Actividades para tomar acción respecto a un incidente de ciberseguridad detectado.

Security Function: Recover (Función de Seguridad: Recuperar)

Actividades para mantener planes de resiliencia y restaurar capacidades o servicios que se vieron afectados por incidentes de ciberseguridad.

Security Function Mapping (Mapeo de Función de Seguridad)

Asignación de Salvaguardas de los Controles CIS a una o más funciones de seguridad del NIST CSF.

Service accounts (Cuentas de servicio)

Cuentas utilizadas para ejecutar servicios o aplicaciones, en lugar de estar asociadas a usuarios individuales. Deben gestionarse y auditarse cuidadosamente debido a sus privilegios potenciales.

Software (Software)

Conjunto de instrucciones o programas que se ejecutan en dispositivos para realizar tareas específicas. Puede incluir sistemas operativos, aplicaciones, scripts, utilidades y controladores.

Standard Operating Procedure (Procedimiento Operativo Estándar - SOP)

Documento detallado que describe cómo realizar una tarea específica de manera consistente y conforme a los requisitos establecidos.

Threat (Amenaza)

Persona, entidad, acción o evento con el potencial de causar daño explotando una vulnerabilidad.

Threat actor (Actor de amenazas)

Individuo o grupo que realiza actividades maliciosas dirigidas a explotar activos empresariales.

Unmanaged asset (Activo no gestionado)

Activo que no está bajo el control directo o visibilidad de la empresa. Puede incluir dispositivos personales, sistemas heredados no monitoreados o hardware conectado sin autorización.

User accounts (Cuentas de usuario)

Cuentas asignadas a individuos para permitir el acceso a sistemas, redes y aplicaciones. Pueden ser cuentas estándar o cuentas con privilegios específicos según el rol.

Users (Usuarios)

Individuos que interactúan con los activos empresariales. Esto incluye empleados, contratistas, socios y otras partes autorizadas.

Virtual machine (Máquina virtual)

Instancia emulada de un sistema informático que se ejecuta sobre una plataforma de virtualización, permitiendo múltiples entornos operativos en una sola máquina física.

Vulnerability (Vulnerabilidad)

Debilidad o falla en un sistema, aplicación o proceso que puede ser explotada por una amenaza para comprometer la seguridad.

Persona (Workforce)

Todos los individuos que están empleados o contratados por una organización y que tienen acceso a sus sistemas de información, activos o recursos. Incluye a todos los empleados tanto en sitio como remotos, excluyendo a los proveedores de servicios y consultores.

Recursos y Referencias

- A Roadmap to the CIS Critical Security Controls: <https://www.cisecurity.org/insights/white-papers/roadmap-cis-critical-security-controls>
- CIS Benchmarks®: <http://www.cisecurity.org/cis-benchmarks/>
- CIS Controls Cloud Companion Guide: <https://www.cisecurity.org/insights/white-papers/cis-controls-v8-1-cloud-companion-guide>
- Mapeos de los CIS Controls: <https://www.cisecurity.org/controls/resources?crc=other-security-frameworks>
- CIS Controls Navigator: <https://www.cisecurity.org/controls/cis-controls-navigator>
- Plantillas de Políticas de los CIS Controls: <https://www.cisecurity.org/controls/resources?crc=implementation-tools-guidance>
- Recursos de los CIS Controls: <https://www.cisecurity.org/controls/resources?crc=about-the-cis-critical-security-controls>
- Modelo de Defensa Comunitaria de CIS (CDM): <https://www.cisecurity.org/insights/white-papers/cis-community-defense-model-2-0>
- Herramienta de Evaluación de Configuración CIS (CIS-CAT®): <https://learn.cisecurity.org/cis-cat/>
- Especificación de Evaluación de los CIS Controls: <https://cas.docs.cisecurity.org/en/latest/>
- Guía de Implementación de Sistemas de Control Industrial de los CIS Controls: <https://www.cisecurity.org/insights/white-papers/cis-critical-security-controls-v8-1-industrial-control-systems-ics-guide>
- Guía Complementaria de IoT de los CIS Controls: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>
- Guía Complementaria Móvil de los CIS Controls: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>
- Herramienta de Autoevaluación de los CIS Controls (CSAT): <https://www.cisecurity.org/controls/cis-controls-self-assessment-tool-cis-csat/>
- Guía de Seguridad para Teletrabajo y Redes de Oficinas Pequeñas de los CIS Controls: <https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>
- Herramienta de Análisis de Impacto Empresarial (BIA) de Ransomware de CIS CSAT: <https://www.cisecurity.org/cis-securesuite/business-impact-analysis-tool>

- CIS WorkBench: <https://www.cisecurity.org/insights/blog/how-to-get-up-and-running-with-cis-workbench>
- Guía de Políticas de Contraseña de CIS: <https://www.cisecurity.org/white-papers/cis-password-policy-guide>
- Método de Evaluación de Riesgos de CIS (RAM): <https://www.cisecurity.org/insights/white-papers/cis-ram-risk-assessment-method>
- Cloud Security Alliance (CSA): <https://cloudsecurityalliance.org/>
- Costo de la Defensa Cibernética para IG1: <https://www.cisecurity.org/controls/resources?crc=assess-and-measure>
- Guía de Respuesta ante Incidentes de Seguridad Cibernética de CREST: <https://www.crest-approved.org/wp-content/uploads/2022/04/CSIR-Procurement-Guide-1.pdf>
- EDUCAUSE: <https://www.educause.edu/focus-areas-and-initiatives/policy-and-security/cybersecurity-program/awareness-campaigns>
- Establecimiento de Higiene Cibernética Esencial (v8.1): <https://www.cisecurity.org/insights/white-papers/establishing-essential-cyber-hygiene-version-8-1>
- Guía de Clases de Activos: <https://www.cisecurity.org/insights/white-papers/guide-to-asset-classes-cis-critical-security-controls-v8-1>
- Guía de Grupos de Implementación (IG) - CIS Controls v8.1: <https://www.cisecurity.org/insights/white-papers/guide-implementation-groups-ig-cis-critical-security-controls-v8-1>
- Organización Internacional de Normalización: <https://www.iso.org/home.html>
- Alianza Nacional de Ciberseguridad (NCSA): <https://staysafeonline.org/>
- Centro Nacional de Ciberseguridad (U.K.): <https://www.ncsc.gov.uk/guidance/10-steps-user-education-and-awareness>
- Instituto Nacional de Estándares y Tecnología (NIST®): <https://www.nist.gov/>
- Marco de Ciberseguridad 2.0 del NIST® (CSF): <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- Guía de Identidad Digital del NIST®: <https://pages.nist.gov/800-63-3/>
- NIST® FIPS 140-2: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.140-2.pdf>
- NIST® FIPS 140-3: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.140-3.pdf>
- Repositorio del Programa Nacional de Listas de Verificación del NIST®: <https://nvd.nist.gov/ncp/repository>

- NIST® SP 800-50 Capacitación en Concientización sobre Seguridad Informática: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-50r1.pdf>
- NIST® SP 800-88r1 – Guías para la Sanitización de Medios: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r1.pdf>
- NIST® SP 800-126r3 – Especificación Técnica para el Protocolo de Automatización de Contenido de Seguridad (SCAP): <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-126r3.pdf>
- NIST® SSDF – Marco de Desarrollo de Software Seguro: <https://csrc.nist.gov/News/2020/mitigating-risk-of-software-vulns-ssdf>
- OWASP®: <https://owasp.org/>
- Metodologías de Pruebas de Penetración de OWASP®: https://www.owasp.org/index.php/Penetration_testing_methodologies
- Consejo de Normas de Seguridad de PCI: https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf
- Guía Complementaria de Privacidad para los Controles v8: <https://www.cisecurity.org/insights/white-papers/cis-controls-v8-privacy-companion-guide>
- Apéndice de Seguridad de Aplicaciones SAFECode: <https://safecode.org/cis-controls/>
- SANS: <https://www.sans.org/security-awareness-training/resources>
- Guía para PYMEs sobre los Controles v8: <https://www.cisecurity.org/insights/white-papers/implementation-guide-for-small-and-medium-sized-enterprises-cis-controls-ig1>
- The Software Alliance: <https://www.bsa.org/reports/updated-bsa-framework-for-secure-software>
- Cursos de Capacitación Trailhead para los CIS Controls: <https://www.cisecurity.org/controls/trailhead-training-courses>
- Informe de Investigaciones sobre Violaciones de Datos de Verizon: <https://www.verizon.com/business/resources/reports/dbir/>

The Center for Internet Security, Inc. (CIS®) makes the connected world a safer place for people, businesses, and governments through our core competencies of collaboration and innovation.

We are a community-driven nonprofit, responsible for the CIS Controls® and CIS Benchmarks®, globally recognized best practices for securing IT systems and data. We lead a global community of IT professionals to continuously evolve these standards and provide products and services to proactively safeguard against emerging threats. Our CIS Hardened Images® provide secure, on-demand, scalable computing environments in the cloud.

CIS is home to the Multi-State Information Sharing and Analysis Center® (MS-ISAC®), the trusted resource for cyber threat prevention, protection, response, and recovery for U.S. State, Local, Tribal, and Territorial government entities, and the Elections Infrastructure Information Sharing and Analysis Center® (EI-ISAC®), which supports the rapidly changing cybersecurity needs of U.S. elections offices.



 www.cisecurity.org
 info@cisecurity.org
 518-266-3460
 Center for Internet Security

 CenterforIntSec
 @CISecurity
 TheCISecurity
 cisecurity